WEB應用程式安全參考指引
(V3.2)

修訂歷史紀錄表

項次	版次	修訂日期	說明
1	V1.0	106/9/12	新編
2	V2.0	107/1/17	1.依據資安處意見修訂。 2.新增 OWASP TOP10:2017 章節介紹。 3.其餘酌作文字修正。
3	V3.0	108/6/17	依據資通安全管理法子法之資通安全責任等級分級辦法(附表十)資通系統防護基準文字修正。
4	V3.1	112/11/27	1.依據 ISO 27001/27002 改版，修訂相關說明與控制措施。 2.修改 OWASP TOP 10 章節介紹。
5	V3.2	114/12/31	增修 4.5.3.4　HTTP 安全標頭防護與設定及附件 3. HTTP 安全標頭防護設定

目　次

1. 前言 1
1.1 目的 1
1.2 適用對象 1
1.3 章節架構 5
1.4 修訂內容說明 6
1.5 使用建議 6
2. 安全系統發展生命週期介紹 7
2.1 傳統系統發展生命週期 7
2.2 安全系統發展生命週期 8
2.3 相關國際標準 11
3. Web 應用程式安全威脅與防護 17
3.1 資訊系統安全特性 17
3.2 Web 應用程式常見威脅介紹 19
3.3 資通安全責任等級分級辦法(附表十)資通系統防護基準 31
4. Web 應用程式安全開發實務 33
4.1 存取控制(Access Control) 33
4.2 稽核與可歸責性(Audit and Accountability) 61
4.3 營運持續計畫(Contingency Planning) 96
4.4 識別與鑑別(Identification and Authentication) 100
4.5 系統與服務獲得(System and Services Acquisition) 151
4.6 系統與通訊保護(System and Communications Protection) 211
4.7 系統與資訊完整性(System and Information Integrity) 234
5. 結論 242
6. 參考文獻 243
7. 附件 244
附件 1. Web 應用程式安全查檢表 ..... 附件 1-1
附件 2.專有名詞英中對照表 ..... 附件 2-1
附件 3. HTTP 安全標頭防護設定 ..... 附件 3-1

圖 目 次

圖 1 微軟 SDL 9
圖 2 NIST SP 800-64 系統發展生命週期示意圖 14
圖 3 程序及服務不以系統管理員或最高權限執行(.NET)圖 1 48
圖 4 程序及服務不以系統管理員或最高權限執行(.NET)圖 2 49
圖 5 新增系統帳號並刪除權限 50
圖 6 程序及服務不以系統管理員或最高權限執行(Java) 51
圖 7 Visual Studio 建立身分鑑別圖 1 53
圖 8 Visual Studio 建立身分鑑別圖 2 54
圖 9 Visual Studio 建立身分鑑別圖 3 55
圖 10 Visual Studio 建立身分鑑別圖 4 56
圖 11 檢視磁碟空間容量 73
圖 12 檢視資料庫資料表磁碟空間用量 74
圖 13 雙擊日期與時間 82
圖 14 變更日期和時間設定值 83
圖 15 網際網路時間 83
圖 16 網際網路時間變更設定 84
圖 17 與網際網路時間伺服器同步處理 85
圖 18 設定 IIS Log 目錄存取權限 88
圖 19 Microsoft Threat Modeling Tool 2016 執行畫面 154
圖 20 CAPTCHA 167
圖 21 Anti-CSRF Token 168
圖 22 ViewState 168
圖 23 AntiForgery Token 171
圖 24 Windows Server 2016 IIS 安裝 HTTPS 支援圖 1 213
圖 25 Windows Server 2016 IIS 安裝 HTTPS 支援圖 2 214
圖 26 Windows Server 2016 IIS 安裝 HTTPS 支援圖 3 214
圖 27 Windows Server 2016 IIS 安裝 HTTPS 支援圖 4 215
圖 28 Windows Server 2016 IIS 安裝 HTTPS 支援圖 5 216
圖 29 Windows Server 2016 IIS 安裝 HTTPS 支援圖 6 216
圖 30 Windows Server 2016 IIS 安裝 HTTPS 支援圖 7 217

圖 31　Windows Server 2016 IIS 建立憑證要求圖 1 218
圖 32　Windows Server 2016 IIS 建立憑證要求圖 2 219
圖 33　Windows Server 2016 IIS 建立憑證要求圖 3 220
圖 34　Windows Server 2016 IIS 建立憑證要求圖 4 221
圖 35　Windows Server 2016 IIS 建立憑證要求圖 5 222
圖 36　Windows Server 2016 IIS 建立憑證要求圖 6 223

表 目 次

表 1 WEB 應用程式安全參考指引適用對象對照表 1
表 2 OWASP Top 10:2021 版與安控措施的對應 20
表 3 WASC Threat Classification v2.0: Attack list 22
表 4 WASC Threat Classification v2.0: Weaknesses list 26
表 5 CWE / SANS Top 25 28
表 6 資安防護基準類別 31
表 7 帳號管理-實作建議 1 34
表 8 帳號管理-程式範例 1 35
表 9 帳號管理-實作建議 2 37
表 10 帳號管理-程式範例 2 38
表 11 帳號管理-實作建議 3 40
表 12 帳號管理-程式範例 3 41
表 13 最小權限-實作建議 1 45
表 14 最小權限-實作建議 2 46
表 15 最小權限-程式範例 2 47
表 16 遠端存取-實作建議 1 52
表 17 遠端存取-程式範例 1 53
表 18 稽核事件-實作建議 61
表 19 稽核事件-程式範例 62
表 20 稽核紀錄內容-實作建議與範例 1 65
表 21 稽核紀錄內容-實作建議與範例 2 68
表 22 稽核儲存容量-實作建議 70
表 23 稽核儲存容量-程式範例 70
表 24 稽核處理失效之回應-實作建議 76
表 25 稽核處理失效之回應-程式範例 77
表 26 時戳及校時-實作建議 81
表 27 時戳及校時-實作範例 82
表 28 稽核資訊之保護-實作建議 1 86
表 29 稽核資訊之保護-實作範例 1 87
表 30 稽核資訊之保護-實作建議 2 90

表 31　稽核資訊之保護-程式範例 2 90
表 32　稽核資訊之保護-實作建議 3 92
表 33　稽核資訊之保護-程式範例 3 93
表 34　資訊系統備份-實作建議 97
表 35　資訊系統備份-實作範例 98
表 36　資訊系統備援-實作建議 99
表 37　資訊系統備援-實作範例 100
表 38　內部使用者之識別與鑑別-實作建議 1 101
表 39　內部使用者之識別與鑑別-實作建議 2 102
表 40　內部使用者之識別與鑑別-程式範例 1 103
表 41　身分鑑別管理-實作建議 1 108
表 42　身分鑑別管理-程式範例 1 109
表 43　身分鑑別管理-實作建議 2 111
表 44　身分鑑別管理-程式範例 2 111
表 45　身分鑑別管理-實作建議 3 114
表 46　身分鑑別管理-程式範例 3 115
表 47　身分鑑別管理-實作建議 4 125
表 48　身分鑑別管理-實作建議 5 126
表 49　身分鑑別管理-程式範例 5 127
表 50　身分鑑別管理-實作建議 6 133
表 51　身分鑑別管理-程式範例 6 134
表 52　鑑別資訊回饋-實作建議 140
表 53　鑑別資訊回饋-程式範例 141
表 54　加密模組鑑別-實作建議 142
表 55　加密模組鑑別-程式範例 143
表 56　安全系統發展生命週期需求階段-實作建議與範例 152
表 57　安全系統發展生命週期設計階段-實作建議 153
表 58　安全系統發展生命週期設計階段-程式範例 154
表 59　安全系統發展生命週期開發階段-實作建議 1 156
表 60　安全系統發展生命週期開發階段-程式範例 1 157
表 61　安全系統發展生命週期開發階段-實作建議 2 161

表 62　安全系統發展生命週期開發階段-程式範例 2 161
表 63　安全系統發展生命週期開發階段-實作建議 3 166
表 64　安全系統發展生命週期開發階段-程式範例 3 167
表 65　安全系統發展生命週期開發階段-實作建議 4 183
表 66　安全系統發展生命週期開發階段-程式範例 4 183
表 67　安全系統發展生命週期開發階段-實作建議 5 187
表 68　安全系統發展生命週期開發階段-程式範例 5 188
表 69　安全系統發展生命週期開發階段-實作建議 6 192
表 70　安全系統發展生命週期開發階段-程式範例 6 192
表 71　安全系統發展生命週期開發階段-實作建議 7 198
表 72　安全系統發展生命週期開發階段-程式範例 6 199
表 73　安全系統發展生命週期測試階段-實作建議與範例 202
表 74　安全系統發展生命週期部署與維運階段-實作建議 1 204
表 75　安全系統發展生命週期部署與維運階段-實作範例 1 204
表 76　安全系統發展生命週期部署與維運階段-實作建議與範例 2 205
表 77　安全系統發展生命週期部署與維運階段-實作建議 3 207
表 78　安全系統發展生命週期部署與維運階段-程式範例 3 207
表 79　安全系統發展生命週期委外階段-實作建議 208
表 80　獲得程序-實作建議 209
表 81　資訊系統文件-實作建議與範例 210
表 82　傳輸之機密性與完整性-實作建議 1 212
表 83　傳輸之機密性與完整性-實作範例 1 212
表 84　傳輸之機密性與完整性-實作建議 2 225
表 85　傳輸之機密性與完整性-程式範例 2 225
表 86　資料儲存之安全-實作建議 1 230
表 87　資料儲存之安全-程式範例 1 231
表 88　資料儲存之安全-實作建議 2 232
表 89　資料儲存之安全-程式範例 2 233
表 90　資訊系統監控-實作建議 235
表 91　軟體及資訊完整性-實作建議 236
表 92　軟體及資訊完整性-程式範例 237

1. 前言

本章節說明本指引之目的、適用對象、章節架構、修訂內容說明及使用建議。

1.1 目的

本指引之目的為協助政府機關瞭解系統開發階段相關安全議題，提供政府機關實作安全控制措施項目時之參考依據，故針對 Web 應用程式可能存在的安全弱點進行介紹，依據「資通安全責任等級分級辦法(附表十)資通系統防護基準」之分類方式，詳列相關安全需求項目，對於各項安全需求皆提供參考之實作方法，並且以 ASP.NET、Java 與 PHP 等程式語言撰寫實作範例。本指引係屬建議性質，當政府機關需要自行撰寫或是委由軟體廠商開發 Web 應用程式時，可參考本指引所提供之安全需求項目與實作方式，強化 Web 應用程式之安全性，降低資安事件發生的機會。

1.2 適用對象

本指引適用於政府機關運用資訊科技從事「業務維運」之所有人員，為便於閱讀與使用，特將適用對象區分為「一般主管」、「資訊人員」及「資安人員」，並針對不同對象建議閱讀之重點，適用對象對照表，詳見表 1 所示。

表1　WEB 應用程式安全參考指引適用對象對照表

章	節	款	一般主管	資訊人員	資安人員
2. 安全	2.1 傳統系統發展生命週期		△	△	△
	2.2 安全系統發	2.2.1 微軟 SDL	△	△	△

本文件之智慧財產權屬數位發展部資通安全署擁有。

章	節	款	一般主管	資訊人員	資安人員
系統發展生命週期介紹	展生命週期	2.2.2 OWASP CLASP			
	2.3 相關國際標準	2.3.1 ISO/IEC 27001:2022 2.3.2 ISO/IEC 27034:2011 2.3.3 NIST SP800-64 2.3.4 NIST SP800-44	△	△	△
3. Web 應用程式安全威脅與防護	3.1 資訊系統安全特性		△	○	○
	3.2 Web 應用程式常見威脅介紹	3.2.1 OWASP Top 10 3.2.2 WASC 威脅分類 3.2.3 CWE / SANS Top 25	△	○	○
	3.3 資通安全責任等級分級辦法(附表十)資通系統防護基準		△	○	○
4. Web 應用程	4.1 存取控制 (Access Control)	4.1.1 帳號管理(Account Management) 4.1.2 最小權限(Least Privilege) 4.1.3 遠端存取(Remote Access)	△	○	○
	4.2 稽核與可歸	4.2.1 稽核事件(Audit Events)	△	○	○

本文件之智慧財產權屬數位發展部資通安全署擁有。

章	節	款	一般主管	資訊人員	資安人員
式安全開發實務	責性(Audit and Accountability)	4.2.2 稽核紀錄內容(Content of Audit Records) 4.2.3 稽核儲存容量(Audit Storage Capacity) 4.2.4 稽核處理失效之回應(Response to Audit Processing Failures) 4.2.5 時戳及校時(Time Stamps) 4.2.6 稽核資訊之保護(Protection of Audit Information)			
	4.3 營運持續計畫(Contingency Planning)	4.3.1 資訊系統備份(Information System Backup) 4.3.2 資訊系統備援(Redundancy of Information Systems)	△	○	○
	4.4 識別與鑑別(Identification and Authentication)	4.4.1 內部使用者之識別與鑑別(Identification and Authentication for Organizational Users) 4.4.2 身分鑑別管理(Authenticator Management) 4.4.3 鑑別資訊回饋(Authenticator Feedback) 4.4.4 加密模組鑑別(Cryptographic Module Authentication) 4.4.5 非內部使用者之識別與鑑別(Identification and Authentication for Non-Organizational Users)	△	○	○
	4.5 系統與服務	4.5.1 安全系統發展生命週期需求階	△	○	○

本文件之智慧財產權屬數位發展部資通安全署擁有。

章	節	款	一般主管	資訊人員	資安人員
	獲得(System and Services Acquisition)	段(Secure System Development Life Cycle-Requirement) 4.5.2 安全系統發展生命週期設計階段(Secure System Development Life Cycle-Design) 4.5.3 安全系統發展生命週期開發階段(Secure System Development Life Cycle-Develop) 4.5.4 安全系統發展生命週期測試階段(Secure System Development Life Cycle-Test) 4.5.5 安全系統發展生命週期部署與維運階段(Secure System Development Life Cycle-Deployment and Maintenance) 4.5.6 安全系統發展生命週期委外階段(Secure System Development Life Cycle-Outsourcing) 4.5.7 獲得程序(Acquisition Process) 4.5.8 資訊系統文件(Information System Documentation)			
	4.6 系統與通訊保護(System and Communications Protection)	4.6.1 傳輸之機密性與完整性(Transmission Confidentiality and Integrity) 4.6.2 資料儲存之安全(Protection of Information at Rest)	△	○	○
	4.7 系統與資訊	4.7.1 漏洞修復(Flaw Remediation)	△	○	○

本文件之智慧財產權屬數位發展部資通安全署擁有。

章	節	款	一般主管	資訊人員	資安人員
	完整性(System and Information Integrity)	4.7.2 資訊系統監控(Information System Monitoring) 4.7.3 軟體及資訊完整性(Software, Firmware, and Information Integrity)			
附記	各項符號代表意義說明如后： ◯：詳閱；△：參考				

資料來源：本計畫整理

政府機關開發 Web 應用程式時，不論採內部自行開發或委外，「資訊人員」皆可參考本指引所列之安全需求範例，制定符合系統需求之安全需求，或依據本指引所提供之安全需求項目實作方式，進行 Web 應用程式開發工作。「資安人員」在詳閱第 4 章「Web 應用程式安全開發實務」後，將對於 Web 應用程式的安全防護有整體性瞭解，有助於分析機關內 Web 應用程式安全相關威脅與問題，並因應新型態之威脅進行防範，例如透過攻擊威脅讓資訊人員與資安人員對 OWASP Top 10 的弱點風險有初步的瞭解，經由安全防護讓資訊與資安人員對滲透測試、源碼檢測及 Web 應用程式防火牆有更進一步的認識。

1.3 章節架構

第 1 章「前言」，說明本指引之目的、適用對象及指引章節架構介紹。

第 2 章「安全系統發展生命週期介紹」，說明傳統系統發展生命週期與安全系統發展生命週期差異，並介紹安全系統發展生命週期相關國際標準。

第 3 章「Web 應用程式安全威脅與防護」，說明資訊安全特性、Web 應用程式常見威脅介紹、資通安全責任等級分級辦法(附表十)資通系統防護基

本文件之智慧財產權屬數位發展部資通安全署擁有。

準等內容。

第 4 章「Web 應用程式安全開發實務」為本指引重點，以「資通安全責任等級分級辦法(附表十)資通系統防護基準」為分類架構，說明適用分級(普、中、高)、控制措施、實作指導及實作範例等資訊。

第 5 章「結論」，總結各章節摘要。

第 6 章「參考文獻」，詳列本指引所參考的文件或資料。

第 7 章「附件」，詳列本報告所納編之附件內容。

1.4 修訂內容說明

第 3 章「Web 應用程式常見威脅介紹」調修「3.2.1 OWASP Top 10」、「3.2.2 WASC 威脅分類」、「3.2.3 CWE / SANS Top 25」等內容。

第 4 章「Web 應用程式安全開發實務」以「資通安全責任等級分級辦法(附表十)資通系統防護基準」的控制措施為架構，增加「資訊系統委外開發 RFP 資安需求範本 V1.0」、「安全資訊系統開發(SSDLC)實作研習-教材」，以及其他相關實務技術內容。讓資訊人員及資安人員能強化機關本身之網站或系統，達到「資通安全責任等級分級辦法(附表十)資通系統防護基準」之要求。

1.5 使用建議

機關於 Web 應用程式開發或改版時，請依指引之流程，於第 2 章瞭解安全系統發展生命週期(SSDLC)之精神，於第 3 章瞭解安全威脅與防護等基本知識概念，參考第 4 章之開發實務資訊，強化系統安全防護。

本文件之智慧財產權屬數位發展部資通安全署擁有。

2. 安全系統發展生命週期介紹

本章節說明資訊系統傳統發展生命週期與安全系統發展生命週期之區別，並介紹安全系統發展生命週期相關國際標準。

2.1 傳統系統發展生命週期

系統發展生命週期(System Development Life Cycle, SDLC)意指發展一套系統的順序，用以開發完善的資訊系統。一般可分為如下幾個階段：

●研究規劃

此階段目的為找出問題及可被資訊系統滿足的機會，其任務包含界定目標與範疇、實施單位之權責與權限、可行性研究、明確辨認問題之性質及範圍(包括人、事、組織、經費、系統架構、相關技術)等。

●需求分析

此階段著重需求定義，以符合業務內容及使用者需求為目的。需求分析指的是在建立一個新的或改變一個現存的系統或產品時，確定新系統的目的、範圍、定義、功能及所要做的所有工作。

●系統設計

系統設計是一個解決問題和規劃軟體解決方案的過程，在確定軟體目的和需求後，軟體開發者需提出解決方案的計畫，包括軟體架構、邏輯模型、演算法及底層的軟體組件組成方式等。

●系統開發

系統開發為解決特定問題程式的過程，為建構活動中的重要階段，程式設計往往以某種程式語言為工具，實現相關的軟體功能。

本文件之智慧財產權屬數位發展部資通安全署擁有。

- 系統測試

  系統測試為確保軟體的正確性、完整性、安全性和品質的過程，常見測試類型包含功能測試、使用者介面測試、效能測試、設定測試及安裝測試等。

- 系統部署

  泛指使系統或軟體可上線正式運作的所有必要活動。包含硬體建置、軟體安裝、系統配置設定、上線測試及教育訓練等。

- 系統維護

  系統維護包含系統服務之運作維持和更新，確保穩定的服務品質。對於系統或軟體產品在交付上線後，為修正錯誤、增進效能或其他品質所進行的修改。

2.2 安全系統發展生命週期

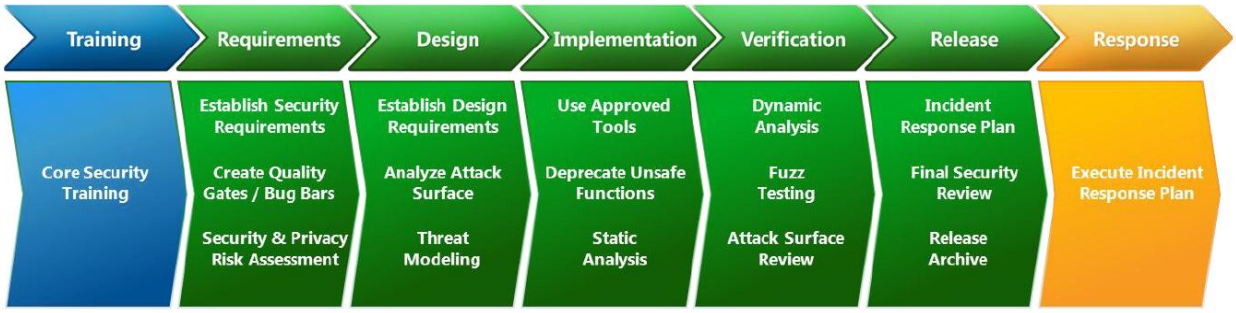
傳統系統發展生命週期為功能性導向，期望在最短的時間完成系統的開發與上線，於設計時容易缺乏安全性考量，常僅依賴外部的安全機制，例如防火牆、入侵偵測系統等抵禦資安威脅，然而這些機制並不能解決所有資安問題，尤其是系統設計上、邏輯層次的安全瑕疵及缺點。

安全系統發展生命週期(Secure System Development Life Cycle, SSDLC)則強調在考量系統功能性的同時，應導入安全性的思維，於系統發展生命週期中，進行各項必要的安全活動，雖拉長了各階段的時程，卻降低了系統後續維護的成本，以及遭受到攻擊損失的可能性。以下針對安全系統發展生命週期相關方法論進行介紹。

2.2.1 微軟 SDL

本文件之智慧財產權屬數位發展部資通安全署擁有。

微軟(Microsoft)於 2004 年開始，將自行發展的「安全發展生命週期」作為全公司實行的政策作法，該作法區分為安全教育訓練(Training)、需求管理(Requirements)、設計管理(Design)、實作(Implementation)、進行驗證程序(Verification)、發布(Release)及回應(Response)等 7 個階段，並於各階段分別進行相關安全實務活動，詳見圖 1。



資料來源：[2]

圖1　微軟 SDL

2.2.2 OWASP CLASP

OWASP(The Open Web Application Security Project)是一個全球性、非營利的組織，專注在增進軟體的安全。CLASP(Comprehensive, Lightweight Application Security Process)為 OWASP 組織所發起計畫，是一套將安全性應用到組織內軟體開發流程的方法。

CLASP 定義以下 7 個最佳實務(Best Practices)：

●安全意識宣導方案

基礎的安全觀念與技術，對於組織內的軟體開發者或相關人員可能是相

本文件之智慧財產權屬數位發展部資通安全署擁有。

當陌生的，因此，在專案初期有必要對相關人員進行相關教育訓練。

●施行應用程式評鑑

雖然軟體安全無法僅透過測試活動而建立，軟體測試與評鑑仍然是整體安全策略的重要元素之一。安全評鑑(特別是自動化的測試)可以發現安全問題，找出於實際運作環境的安全風險，亦可作為縱深防禦機制，協助找到設計、規格或實作上的錯誤。

●捕捉安全軟體需求

開發專案於定義需求階段，很容易著重在功能需求而忽略安全考量，故將軟體安全需求作為發展階段明確的部分極為重要。

●實作安全開發實務

軟體基本的安全目標為創造及維護可重用的程式碼，強化組織中軟體的基本安全與提供可重複使用性。此目標可透過組織整體的軟體發展生命週期中實施安全開發實務來達成。安全開發實務提供明確定義，以角色為基礎的活動。如協助專案團隊應用軟體安全法則在設計階段、整合動態與靜態安全分析到程式碼管理流程。安全開發實務亦提供程式碼撰寫規範，用以避免及排除程式碼中的安全漏洞。

●建置漏洞修補程序

定義如何鑑別、評鑑、設定優先權及漏洞修補的步驟，對於提升軟體安全相當重要。漏洞修補程序將會透過事先定義好處理漏洞的角色、職責及程序，來提升識別漏洞後的回應速度及最小化風險程度。

●定義監測安全量測指標

軟體開發專案若無法量測，則無法妥善進行專案管理。量測軟體的安全

本文件之智慧財產權屬數位發展部資通安全署擁有。

情勢，有助於把心力著重在最嚴重的漏洞上，並顯示組織在投入資源後對於安全程度的產出表現。

●發布作業安全指引

軟體安全的工作並非在開發完成並部署上線到正式環境後結束，要使大部分的網路或作業安全的措施有效，需要持續監看及管理上線系統的安全性。日常作業程序中，需要建議及指引該軟體所建立的安全措施如何被正確的使用，以確保其目的確實達成。

2.3 相關國際標準

本章節介紹與安全系統發展生命週期相關的國際標準。ISO/IEC 27001:2022 資訊安全管理系統(ISMS)為目前國際上最廣泛採用之資訊安全管理規範。ISO/IEC 27034-1:2011/Cor 1:2014「應用程式安全」(Application Security)是微軟實行安全發展生命週期多年後，進一步推動的國際標準。NIST SP 800-64「資訊系統發展生命週期的安全考量」，為美國國家標準與技術研究院所推出的標準，針對系統發展生命週期所需要注意的安全事項進行探討。NIST SP 800-44「公開 Web 伺服器安全指引」，為美國國家標準與技術研究院針對公開之 Web 伺服器所發展的安全防護參考指引。

2.3.1 ISO/IEC 27001:2022

國際標準組織(International Organization for Standardization , ISO)於 2022 年公布最新版 ISO/IEC 27001:2022「資訊安全管理系統(ISMS)」，其中有關系統發展的相關控制措施摘要說明如下。

●A.8.25「安全開發生命週期(Secure development lifecycle)」

應建立並施行安全開發軟體及系統之規則。

本文件之智慧財產權屬數位發展部資通安全署擁有。

●A. 8.26「應用系統安全要求事項(Application security requirements)」

開發或獲取應用系統時，應識別、規定並核可資訊安全要求事項。

●A. 8.27「安全系統架構及工程原則(Secure system architecture and engineering principles) 」

應建立、書面記錄及維護工程化安全系統之原則，並套用於所有資訊系統開發活動。

●8.28「安全程式設計(Secure coding) 」

軟體開發應施行安全程式設計原則。

●8.29「開發及驗收中之安全測試(Security testing in development and acceptance)」

應於開發生命週期中定義並實作安全測試過程。

●8.31「開發、測試與運作環境之區隔(Separation of development, test and production environments)」

應區隔開發環境、測試環境與生產環境，並保全之。

●A.14.3「測試資訊(Test information)」

應適切選擇、保護及管理測試資訊。

2.3.2 ISO/IEC 27034-1:2011/Cor 1:2014

ISO/IEC 27034-1:2011/Cor 1:2014 (Information technology — Security techniques — Application security) 為第一套針對系統發展安全性所需流程與框架之國際標準，除提供了通用的驗證型態及簡單扼要之大綱，也提供了採購者，得以要求各產業、各平台與不同區域之供應商遵循與落實系統安全發

本文件之智慧財產權屬數位發展部資通安全署擁有。

展，亦協助開發商將安全系統流程精神導入日常業務中。ISO/IEC 27034-1:2011/Cor 1:2014 主要針對系統安全開發流程提供一實作之指引，包含：

- 針對軟體安全制定流程作為應用程式系統於設計、開發、測試、實施和維護過程中對於功能安全的控制遵循使用，提供組織選用流程中合適的控制措施與衡量指標作為軟體開發的風險管理使用。
- 提供與測試計畫概念相符之信任層級(Target Level of Trust)，作為應用程式之設計、建置與驗證使用。
- 提供政府與軍事系統如評估共通準則(Common Criteria)方案之稽核與驗收通用標準。

ISO/IEC 27034-1:2011/Cor 1:2014 制定管理組織規範架構的流程，透過建立雙向的溝通管道達到組織之持續營運。ISO/IEC 27034-1:2011/Cor 1:2014 雖不與 ISO/IEC 27001:2022 規範相依，但其補足 ISO/IEC 27001:2022 中未具體提及的應用程式安全性實務守則，故 ISO/IEC 27034-1:2011/Cor 1:2014 與 ISO/IEC 27002:2022 之定位相似，可成為實踐 PDCA(Plan-Do-Check-Act)品質保證之參考方案。

2.3.3 NIST SP 800-64

美國國家標準與技術研究院(National Institute of Standards and Technology, NIST)提出特刊(Special Publication, SP) 800 系列是有關於資訊技術的安全標準。其中 SP 800-64 資訊系統發展生命週期的安全考量(Security Considerations in the Information System Development Life Cycle)，是針對系統發展生命週期所需要注意的安全事項進行探討。SP 800-64 協助機構建置基本的安全活動，將其整合至系統發展生命週期的建立，並能更符合成本效益、風險適當的安全控制識別、開發與測試。NIST 將一個典型的系統發展生命週期分為初始(Initiation)、需求與獲取

本文件之智慧財產權屬數位發展部資通安全署擁有。

(Development/Acquisition)、建置與評鑑(Implementation/Assessment)、運作與維護(Operations/Maintenance)及汰除(Disposal)等 5 個階段。在系統開發過程中，每個階段都需要有效的將安全納入最低限度的安全任務內，且有可能會在整個系統發展生命週期內持續重複。有關系統發展生命週期 5 個階段的示意圖，詳見圖 2。



資料來源：本計畫整理

圖2　NIST SP 800-64 系統發展生命週期示意圖

SP 800-64 指引提供系統發展生命週期各個階段實用的文件，包含主要的活動與里程碑、決策點或控制閘、在系統設計時提供重要資訊的預期輸出、專案成果、以及系統維護與安全和運作方面的考量等。

2.3.4 NIST SP 800-44

SP 800-44 公開 Web 伺服器安全指引(Guidelines on Securing Public Web

本文件之智慧財產權屬數位發展部資通安全署擁有。

Servers)為 NIST 針對公開之 Web 伺服器所發展的安全防護參考指引，其目的為針對 Web 伺服器安全提供防護參考建議，包含設計、實作及維運，包含相關網路基礎設施議題，並且提供查檢表輔助組織查核安全防護現況，安全防護設定主要分為以下 7 個面向：

●Web 伺服器計畫與管理

內容涵蓋人員管理、管理最佳實務、系統安全計畫、人力資源管理及平台選擇等安全注意事項。

●Web 伺服器作業系統安全

內容涵蓋作業系統的安裝與組態設定，包含修補更新、移除不必要的服務及應用程式、身分鑑別相關組態設定、存取控制，其他附加安全控制的安裝與組態設定，以及作業系統安全測試。

●Web 伺服器安全

說明安裝 Web 伺服器的安全注意事項及相關存取控制設定。

●Web 內容安全

– 說明於公開網站公布資訊的注意事項

– 觀察收集到個資的規律性

– 如何減緩對內容進行間接攻擊，包含釣魚(Phishing)及網址嫁接(Pharming)

– 介紹主動式內容安全及內容產生技術，例如 ActiveX、JavaScript、AJAX 等，並討論相關弱點，例如 XSS

●使用鑑別及加密技術

本文件之智慧財產權屬數位發展部資通安全署擁有。

說明如何決定安全需求，身分鑑別的方式，包含以位址為依據、基本鑑別、摘要(Digest)鑑別等，並介紹 SSL/TLS 加密技術及窮舉法攻擊等。

●安全網路基礎設施實作

介紹網路基礎設施及元件組態(例如：路由器與防火牆設定、交換器、負載平衡等)。

●Web 伺服器進階管理

說明 Log 相關注意事項。

本文件之智慧財產權屬數位發展部資通安全署擁有。

3. Web 應用程式安全威脅與防護

Web 應用程式由於需要在網路環境中提供使用者存取服務，故遭受惡意攻擊的風險比一般封閉性的資訊系統高，這也造成 Web 系統資安事件層出不窮。綜觀近年發生的重大資安事件，其發生的根本原因往往都與 Web 應用程式源碼的安全性有關，若應用程式本身在安全設計上不夠周延或是開發時的疏忽，就會造成 Web 應用程式存在弱點而被駭客所利用；例如 103 年 iCloud 服務，因為身分鑑別安全機制的瑕疵，造成多名好萊塢女星私密照片外洩；106 年 3 月則爆發 Apache Struts 2 的重大漏洞 S2-045 (CVE-2017-5638)，若網頁伺服器使用這項不安全的軟體元件，就可能導致網站資料外洩、被植入木馬程式等風險。

本章節首先針對資訊系統的安全特性進行說明，並探討 Web 應用程式常見資安威脅及弱點。本章節亦說明「資通安全責任等級分級辦法(附表十)資通系統防護基準」，其目的是作為政府機關於開發及維護資訊系統時之遵循依據。

3.1 資訊系統安全特性

資訊安全的基本目的在提供資料與系統之機密性(Confidentiality)、完整性(Integrity)及可用性(Availability)，這三項要素稱為資訊安全三原則，簡稱 CIA。除了基本的資訊安全三原則外，軟體安全特性亦包含身分鑑別、授權與存取控制、日誌紀錄、會談管理、錯誤與例外管理及組態管理等，共計 9 大安全特性，詳細說明如下：

●機密性

資訊系統發生資安事件時，可能造成未經授權之資訊揭露，對於機關之業務運作、資產或信譽等方面造成不同程度之負面影響。機密性之目的

本文件之智慧財產權屬數位發展部資通安全署擁有。

為確保資訊不會洩露給非經授權的人員。

●完整性

資訊系統委外開發與營運時，若未有效地落實資安防護作為，可能造成系統之完整性遭受破壞，對機關之業務運作、資產或信譽等方面造成不同程度之負面影響。完整性之目的為保護資訊或程序不會被非經授權的變更。

●可用性

使用資訊系統之目的在輔助機關提升業務效能與服務品質，是業務運作不可或缺的一環。因此一旦系統發生故障或異常運作等情事，可能導致業務執行效能降低或中斷。可用性之目的為確保授權使用者在需要時可以存取系統服務及資源。

●身分鑑別

身分鑑別之目的在確認實體(Entity)要求身分之真實性的程序。實體可能是人、程序或硬體裝置等。身分鑑別要求實體提供憑據以證明其確實為所聲稱的主體。

●授權

授權之目的在確認已通過身分鑑別的實體是否被允許對特定資源進行特定存取動作的程序。

●稽核

稽核之目的為協助建構使用者行為的歷史紀錄，依律定之時間週期及紀錄，保留相關紀錄並符合法規要求。資訊系統產生之稽核紀錄至少應包含事件類型、何時發生、何處發生及事件相關之使用者身分識別等資

本文件之智慧財產權屬數位發展部資通安全署擁有。

訊。

●會談管理

會談(Session)是用來維持軟體中的狀態，成功的身分鑑別後，會談的識別碼(Session Identifier，Session ID)會配發給使用者，用來追蹤使用者並維持其已進行身分鑑別的狀態，直到其身分鑑別失效或會談過期。無狀態的協定(如 HTTP)沒有使用會談，使用者每一次進行動作就必須重新進行身分鑑別，這樣的作法通常無法被使用者接受。然而，使用會談的作法，又面臨會談識別碼若被竊取，則有被身分偽冒的風險，因此必須設計安全的會談管理方式。

●錯誤及例外處理

錯誤(Error)及例外(Exception)是資訊洩漏的潛在來源之一。詳細的錯誤訊息與未處理的例外報告，可能會導致洩漏內部應用程序架構、設計和設定的資訊，因此必須在安全需求中明確說明處理錯誤及例外的要求，以避免資訊洩漏威脅。

●組態管理

組態管理是用來建立或維持軟體功能、效能及相關特性的一致性與穩定。軟體所依賴的底層元件，須注意其安全組態設定以確保較高的安全性。對於軟體的設定參數，應加以保護並管理其變更。

3.2 Web 應用程式常見威脅介紹

本章節針對 OWASP Top 10 及 SANS Top 25 等各個項目進行介紹及說明。OWASP 十大弱點列表(OWASP Top 10)為 OWASP 組織知名計畫之一，其重點是發布對於網頁應用程式最具威脅性或最常見的十大弱點，讓開發人員、設計師、架構師及資訊主管等相關人員了解 Web 應用程序安全漏洞的

本文件之智慧財產權屬數位發展部資通安全署擁有。

後果及防禦技術，不僅可作為驗證網路服務資安風險之參考依據，也可透過教育訓練強化資訊系統之安全性。

3.2.1 OWASP Top 10

OWASP Top 10 首次公布版本為 OWASP Top 10:2003，歷經 2004、2007 的小幅度修正改版，2010 版本則調整名稱為十大最關鍵的 Web 應用程式安全風險(Top 10 Most Critical Web Application Security Risks)，一改過去以弱點角度出發的觀點，將層級拉高至風險角度，更符合資安風險管理的趨勢與實務導入需求，這種方式一直延續到 2021 年版。目前 OWASP Top 10 版本仍持續不定期進行更新，更新現況可查閱 OWASP TOP 10 官方網頁 https://owasp.org/Top10/zh_TW/。

本指引所描述的多項安全控制措施，內容已涵蓋所有 OWASP Top 10:2021 所條列的重大威脅，相關章節整理詳見表 2。

表2　OWASP Top 10:2021 版與安控措施的對應

項次	項目類別	安全控制措施相關章節
1	權限控制失效 (Broken Access Control)	4.1 存取控制(Access Control)
2	加密機制失 (Cryptographic Failures)	4.6 系統與通訊保護(System and Communications Protection)
3	注入 (Injection)	4.5.3.1 應注意避免軟體常見漏洞(如 OWASP TOP 10) 及實作必要控制措施
4	不安全設計 (Insecure Design)	4.5.2 安全系統發展生命週期設計階段 (Secure System Development Life Cycle-Design)
5	安全設定缺陷 (Security	4.5.5 安全系統發展生命週期部署與維運

本文件之智慧財產權屬數位發展部資通安全署擁有。

項次	項目類別	安全控制措施相關章節
	Misconfiguration)	階段(Secure System Development Life Cycle-Deployment and Maintenance)
6	危險或過舊的元件 (Vulnerable and Outdated Components)	4.7.1 漏洞修復(Flaw Remediation)
7	認證及驗證機制失效 (Identification and Authentication Failures)	4.4 識別與鑑別(Identification and Authentication)
8	軟體及資料完整性失效 (Software and Data Integrity Failures)	4.7.3 軟體及資訊完整性(Software, Firmware, and Information Integrity)
9	資安記錄及監控失效 (Security Logging and Monitoring Failures)	4.7.2 資訊系統監控(Information System Monitoring)
10	伺服端請求偽造(Server-Side Request Forgery)	4.5.3.1 應注意避免軟體常見漏洞(如 OWASP TOP 10) 及實作必要控制措施

資料來源：本計畫整理

3.2.2 WASC 威脅分類

WASC (Web Application Security Consortium) 是由許多資訊安全專家及組織所組成的非營利聯盟，該聯盟持續發布與 Web 應用程序的安全性相關之技術資訊、安全指引，以供企業、教育機構、政府部門及應用程序開發人員等使用。其提出 WASC Threat Classification v2.0，將網站的安全威脅進行分類(以字典順序排序)，本指引所描述的多項安全控措施，內容已涵蓋

本文件之智慧財產權屬數位發展部資通安全署擁有。

WASC Threat Classification v2.0 之項目，相關章節整理詳見表 3。

表3　WASC Threat Classification v2.0: Attack list

編號	WASC 攻擊列表	安全控制措施相關章節
1	功能濫用(Abuse of Functionality)	4.1 存取控制(Access Control)
2	窮舉法攻擊(Brute Force)	4.4.2 身分鑑別管理 (Authenticator Management)
3	緩衝區溢位(Buffer Overflow)	4.5.3.2 應針對資訊系統之錯誤與例外進行適當處理
4	內容偽冒(Content Spoofing)	4.7.3 軟體及資訊完整性 (Software, Firmware, and Information Integrity)
5	認證與會談辨識碼的預測 (Credential/Session Prediction)	4.1.1 帳號管理(Account Management)
6	跨站腳本攻擊(Cross-Site Scripting, XSS)	▪ 4.5.3.1 應注意避免軟體常見漏洞(如 OWASP TOP 10)及實作必要控制措施 ▪ 4.7.3 軟體及資訊完整性 (Software, Firmware, and Information Integrity)
7	跨站請求偽造(Cross-Site Request Forgery, CSRF)	4.5.3.1 應注意避免軟體常見漏洞(如 OWASP TOP 10) 及實作必要控制措施
8	阻絕服務(Denial of Service)	4.7.2 資訊系統監控 (Information System Monitoring)

本文件之智慧財產權屬數位發展部資通安全署擁有。

編號	WASC 攻擊列表	安全控制措施相關章節
9	指紋探索與辨識(Fingerprinting)	4.1.3 遠端存取(Remote Access)
10	格式化字串(Format String)	4.7.3 軟體及資訊完整性 (Software, Firmware, and Information Integrity)
11	HTTP 回應偷渡(HTTP Response Smuggling)	4.7.3 軟體及資訊完整性 (Software, Firmware, and Information Integrity)
12	HTTP 回應分割(HTTP Response Splitting)	4.7.3 軟體及資訊完整性 (Software, Firmware, and Information Integrity)
13	HTTP 請求偷渡(HTTP Request Smuggling)	4.7.3 軟體及資訊完整性 (Software, Firmware, and Information Integrity)
14	HTTP 請求分割(HTTP Request Splitting)	4.7.3 軟體及資訊完整性 (Software, Firmware, and Information Integrity)
15	整數溢位(Integer Overflows)	4.5.2 應針對資訊系統之錯誤與例外進行適當處理
16	LDAP 注入(LDAP Injection)	4.7.3 軟體及資訊完整性 (Software, Firmware, and Information Integrity)
17	郵件命令注入(Mail Command Injection)	4.7.3 軟體及資訊完整性 (Software, Firmware, and Information Integrity)

本文件之智慧財產權屬數位發展部資通安全署擁有。

編號	WASC 攻擊列表	安全控制措施相關章節
18	空字元注入(Null Byte Injection)	4.7.3 軟體及資訊完整性(Software, Firmware, and Information Integrity)
19	未經授權執行作業系統命令(OS Commanding)	4.7.3 軟體及資訊完整性(Software, Firmware, and Information Integrity)
20	路徑尋訪(Path Traversal)	4.1 存取控制(Access Control)
21	可預測的資源位置(Predictable Resource Location)	4.1 存取控制(Access Control)
22	遠端檔案含入(Remote File Inclusion, RFI)	4.7.3 軟體及資訊完整性(Software, Firmware, and Information Integrity)
23	路由迂迴(Routing Detour)	4.7 系統與資訊完整性(System and Information Integrity)
24	會談固定(Session Fixation)	4.1.1 帳號管理(Account Management)
25	SOAP 陣列濫用(SOAP Array Abuse)	4.7.3 軟體及資訊完整性(Software, Firmware, and Information Integrity)
26	SSI 注入(Server-Side Include Injection)	4.7.3 軟體及資訊完整性(Software, Firmware, and Information Integrity)
27	SQL 命令注入(SQL Injection)	4.5.3.1 應注意避免軟體常見漏洞(如 OWASP TOP 10) 及實作必要控制措施

本文件之智慧財產權屬數位發展部資通安全署擁有。

編號	WASC 攻擊列表	安全控制措施相關章節
28	URL 重定導向濫用(URL Redirector Abuse)	4.7.3 軟體及資訊完整性 (Software, Firmware, and Information Integrity)
29	XPath 注入(XPath Injection)	4.7.3 軟體及資訊完整性 (Software, Firmware, and Information Integrity)
30	XML 屬性爆毀(XML Attribute Blowup)	4.7.3 軟體及資訊完整性 (Software, Firmware, and Information Integrity)
31	XML 外部實體(XML External Entities)	4.7.3 軟體及資訊完整性 (Software, Firmware, and Information Integrity)
32	XML 實體擴張(XML Entity Expansion)	4.7.3 軟體及資訊完整性 (Software, Firmware, and Information Integrity)
33	XML 注入 (XMLInjection)	4.7.3 軟體及資訊完整性 (Software, Firmware, and Information Integrity)
34	XQuery 注入(XQuery Injection)	4.7.3 軟體及資訊完整性 (Software, Firmware, and Information Integrity)

資料來源：[3]

WASC Threat Classification v2.0 亦將常見的弱點進行以下分類(以字典順序)，詳見表 4。

本文件之智慧財產權屬數位發展部資通安全署擁有。

表4　WASC Threat Classification v2.0: Weaknesses list

編號	威脅	安全控制措施相關章節
1	應用程式設定不正確(Application Misconfiguration)	4.5.5 安全系統發展生命週期部署與維運階段(Secure System Development Life Cycle-Deployment and Maintenance)
2	目錄索引(Directory Indexing)	4.1 存取控制(Access Control)
3	不當的檔案系統使用權限(Improper Filesystem Permissions)	4.1 存取控制(Access Control)
4	不當的輸出處理(Improper Output Handling)	4.7.3 軟體及資訊完整性(Software, Firmware, and Information Integrity)
5	資訊外洩(Information Leakage)	▪ 4.1.3 遠端存取(Remote Access) ▪ 4.6 系統與通訊保護(System and Communications Protection)
6	不安全的索引(Insecure Indexing)	4.1 存取控制(Access Control)
7	應用程式不足以因應自動化攻擊(Insufficient Anti-automation)	4.7.2 資訊系統監控(Information System Monitoring)
8	驗證機制安全性不足(Insufficient Authentication)	4.4 識別與鑑別(Identification and Authentication)
9	授權機制安全性不足(Insufficient Authorization)	4.1 存取控制(Access Control)

本文件之智慧財產權屬數位發展部資通安全署擁有。

編號	威脅	安全控制措施相關章節
10	密碼還原機制安全性不足(Insufficient Password Recovery)	4.4.2 身分鑑別管理 (Authenticator Management)
11	應用程式流程驗證與控制不足 (Insufficient Process Validation)	4.1 存取控制(Access Control)
12	會談過期機制安全性不足(Insufficient Session Expiration)	4.1.1 帳號管理(Account Management)
13	傳輸層保護機制安全性不足 (Insufficient Transport Layer Protection)	4.6.1 傳輸之機密性與完整性 (Transmission Confidentiality and Integrity)
14	伺服器設定不當(Server Misconfiguration)	4.5.5 安全系統發展生命週期部署與維運階段(Secure System Development Life Cycle-Deployment and Maintenance)

資料來源：[3]

3.2.3 CWE / SANS Top 25

CWE (Common Weakness Enumeration) 是由 US-CERT 所資助的 MITRE 組織所發布有關網頁應用程式安全弱點的類別。SANS (SysAdmin, Audit, Networking, and Security) 則是專門進行資訊安全培訓、認證與研究的機構，該機構對於資安領域有著深入地研究及分析，網站上提供最新資訊安全相關研究。CWE / SANS Top 25 就是由 MITRE 和 SANS 合作，共同發布網頁應用程式前 25 大的威脅，詳見表 5。

本文件之智慧財產權屬數位發展部資通安全署擁有。

表5　CWE / SANS Top 25

等級	威脅	安全控制措施相關章節
1	SQL 命令注入(SQL Injection)	4.5.3.1 應注意避免軟體常見漏洞(如 OWASP TOP 10) 及實作必要控制措施
2	作業系統命令注入(OS Command Injection)	4.5.3.1 應注意避免軟體常見漏洞(如 OWASP TOP 10) 及實作必要控制措施
3	緩衝區溢位(Buffer Overflow)	4.7.3 軟體及資訊完整性 (Software, Firmware, and Information Integrity)
4	跨站腳本攻擊(Cross-site Scripting, XSS)	▪ 4.5.3.1 應注意避免軟體常見漏洞(如 OWASP TOP 10) 及實作必要控制措施 ▪ 4.7.3 軟體及資訊完整性 (Software, Firmware, and Information Integrity)
5	重要功能缺乏鑑別(Missing Authentication for Critical Function)	4.4 識別與鑑別(Identification and Authentication)
6	缺乏授權機制(Missing Authorization)	4.1 存取控制(Access Control)
7	將驗證的機密性資料直接寫入(Use of Hard-coded Credentials)	4.4.4 加密模組鑑別 (Cryptographic Module Authentication)
8	敏感性資料缺乏加密機制(Missing Encryption of Sensitive Data)	▪ 4.4.4 加密模組鑑別 (Cryptographic Module Authentication)

本文件之智慧財產權屬數位發展部資通安全署擁有。

等級	威脅	安全控制措施相關章節
		▪ 4.6.2 資料儲存之安全 (Protection of Information at Rest)
9	沒有限制危險類型的檔案上傳 (Unrestricted Upload of File with Dangerous Type)	4.7.3 軟體及資訊完整性 (Software, Firmware, and Information Integrity)
10	安全決策依靠不可信任的輸入 (Reliance on Untrusted Inputs in a Security Decision)	4.7.3 軟體及資訊完整性 (Software, Firmware, and Information Integrity)
11	非必要的執行權限(Execution with Unnecessary Privileges)	4.1.2 最小權限(Least Privilege)
12	跨站請求偽造(Cross-Site Request Forgery, CSRF)	4.5.3.1 應注意避免軟體常見漏洞(如 OWASP TOP 10) 及實作必要控制措施
13	路徑尋訪(Path Traversal)	4.1 存取控制(Access Control)
14	下載源碼時未做完整性檢查 (Download of Code Without Integrity Check)	4.6.1 傳輸之機密性與完整性 (Transmission Confidentiality and Integrity)
15	不正確的授權(Incorrect Authorization)	4.1 存取控制(Access Control)
16	包含了非信任及非控制範圍的功能 (Inclusion of Functionality from Untrusted Control Sphere)	4.1 存取控制(Access Control)
17	對重要資源不正確的權限指派 (Incorrect Permission Assignment for Critical Resource)	4.1 存取控制(Access Control)

本文件之智慧財產權屬數位發展部資通安全署擁有。

等級	威脅	安全控制措施相關章節
18	使用有潛在危險性的函式(Use of Potentially Dangerous Function)	4.5.3.1 應注意避免軟體常見漏洞(如 OWASP TOP 10) 及實作必要控制措施
19	使用具瑕疵或具風險的加密演算法(Use of a Broken or Risky Cryptographic Algorithm)	4.6.1 傳輸之機密性與完整性(Transmission Confidentiality and Integrity)
20	緩衝區大小計算不正確(Incorrect Calculation of Buffer Size)	4.5.3 安全系統發展生命週期開發階段(Secure System Development Life Cycle-Develop)
21	沒有適當的限制不斷的驗證企圖(Improper Restriction of Excessive Authentication Attempts)	4.4.2 身分鑑別管理(Authenticator Management)
22	URL 重新導向至非信賴的網站(URL Redirection to Untrusted Site ('Open Redirect'))	4.7.3 軟體及資訊完整性(Software, Firmware, and Information Integrity)
23	未控制的字串格式(Uncontrolled Format String)	4.7.3 軟體及資訊完整性(Software, Firmware, and Information Integrity)
24	整數溢位或越界繞回(Integer Overflow or Wraparound)	4.5.3 安全系統發展生命週期開發階段(Secure System Development Life Cycle-Develop)
25	雜湊加密時未加上 salt 搗亂(Use of a One-Way Hash without a Salt)	4.4.4 加密模組鑑別(Cryptographic Module Authentication)

本文件之智慧財產權屬數位發展部資通安全署擁有。

等級	威脅	安全控制措施相關章節

資料來源：[4]

3.3 資通安全責任等級分級辦法(附表十)資通系統防護基準

依據之「資通安全責任等級分級辦法附表九」，機關依機密性、完整性、可用性及法律遵循性四大影響構面，分別考量資訊系統於發生資安事件時可能造成之衝擊，即衡量資訊系統資料外洩、資料遭竄改、系統故障等情事時可能造成的後果嚴重程度，並據以評估，將資訊系統的安全等級分為【普】、【中】、【高】三級。機關完成資訊系統分級後，應依「資通安全責任等級分級辦法(附表十)資通系統防護基準」，執行相對應之控制措施。機關可依其資源，調整控制措施之優先順序。資安防護基準類別分為7 大類別，共計 29 項控制措施，詳見表 6。

表6　資安防護基準類別

項次	項目類別	控制措施
1	存取控制(3 項)	▪帳號管理 ▪最小權限 ▪遠端存取
2	稽核與可歸責性(6 項)	▪稽核事件 ▪稽核紀錄內容 ▪稽核儲存容量 ▪稽核處理失效之回應 ▪時戳及校時稽核資訊之保護
3	營運持續計畫(2 項)	▪資訊系統備份 ▪資訊系統備援

本文件之智慧財產權屬數位發展部資通安全署擁有。

項次	項目類別	控制措施
4	識別與鑑別(5 項)	▪內部使用者之識別與鑑別 ▪身分鑑別管理 ▪鑑別資訊回饋 ▪加密模組鑑別 ▪非內部使用者之識別與鑑別
5	系統與服務獲得(8 項)	▪安全系統發展生命週期需求階段 ▪安全系統發展生命週期設計階段 ▪安全系統發展生命週期開發階段 ▪安全系統發展生命週期測試階段 ▪安全系統發展生命週期部署與維運階段 ▪安全系統發展生命週期委外階段 ▪獲得程序 ▪系統文件
6	系統與通訊保護(2 項)	▪傳輸之機密性與完整性 ▪資料儲存之安全
7	系統與資訊完整性(3 項)	▪漏洞修復 ▪資訊系統監控 ▪軟體及資訊完整性

資料來源：本計畫整理

本文件之智慧財產權屬數位發展部資通安全署擁有。

4. Web 應用程式安全開發實務

本章節依據「資通安全責任等級分級辦法(附表十)資通系統防護基準」之內容，資安防護基準類別可分為「存取控制」、「稽核與可歸責性」、「營運持續計畫」、「識別與鑑別」、「系統與服務獲得」、「系統與通訊保護」及「系統與資訊完整性」等 7 個類別。分別針對各類別詳細說明各項控制措施適用的安全等級(普、中、高)及實作指導等資訊，並且以目前最常用的 Web 應用系統開發語言(.NET、Java 及 PHP)撰寫實作範例，提供政府機關或委外廠商開發 Web 應用系統時之參考。與資料庫相關之實作範例，.NET 程式碼是搭配 Microsoft SQL，而 Java 及 PHP 則是使用 MySQL。

4.1 存取控制(Access Control)

存取控制分為「帳號管理」、「最小權限」，以及「遠端存取」等 3 項控制措施，說明如下。

4.1.1 帳號管理(Account Management)

帳號管理類別之控制措施包含以下 7 項：

- 建立帳號管理機制，包含帳號之申請、開通、停用及刪除之程序。
- 資訊系統已逾期之臨時或緊急帳號應刪除或禁用。
- 應禁用資訊系統閒置帳號。
- 應定期審核資訊系統帳號之建立、修改、啟用、禁用及刪除動作。
- 當超過機關所規定之預期閒置時間或可使用期限時，系統應自動將使用者登出。
- 資訊系統應依照機關所規定之情況及條件(如特定時間或指定 IP 來源)，

本文件之智慧財產權屬數位發展部資通安全署擁有。

使用資訊系統。

●監控資訊系統帳號以發現違常使用，並於發現帳號違常使用時回報管理者。

與帳號管理控制措施相關的應用程式技術面項目，整理如下：

4.1.1.1 當超過機關所規定之預期閒置時間或可使用期限時，系統應自動將使用者登出

本項目實作項目包含以下 2 項：

●使用者的會談階段，設定該帳號在合理的時間(至多 30 分鐘)內未活動即自動失效。

– 相關實作建議，詳見表 7。

表7　帳號管理-實作建議 1

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	帳號管理	使用者的會談階段，設定該帳號在合理的時間(至多 30 分鐘)內未活動即自動失效
查核方式：☐自動化工具檢測　☒人工審查				
控制措施： 會談(Session)機制目的為管理使用者與伺服器之間的連線狀態，通常於客戶端首次連線伺服器即建立一會談識別碼(Session ID)，並將使用者後續於系統中的相關資訊與該會談識別碼關聯，以維持使用者相關資訊狀態。使用者於系統中若一段時間未進行活動，系統應有自動機制將該使用者的會談階段設為失效，以避免資安風險。				

本文件之智慧財產權屬數位發展部資通安全署擁有。

實作指導：

當使用者在時間內沒有回應時，可利用預設的會談管理控制設定，將會談在使用者閒置操作一段時間後自動清除，讓使用者在閒置後可以回到未登入的狀態，以保護使用者的登入操作。

資料來源： 本計畫整理

– 相關程式範例，詳見表 8。

表8 帳號管理-程式範例 1

ASP.NET 實作範例：
ASP.NET 網站中，可以直接在 Web.Config 設置 Session Time 的項目值，其範例如下： ▪ 在 System.web 區段加上 sessionState 節點，並加上 timeout 的屬性，該值未設置時，預設值為 20 分鐘，也就是當使用者在 20 分時間內沒有回應時，系統的會談就會過期，可將設定時間改為 30 分鐘。 <system.web> <sessionState timeout ="30" /> </system.web> 參考連結： ▪ sessionState Element (ASP.NET Settings Schema) http://msdn.microsoft.com/en-us/library/h6bb9cz9.aspx ▪ 工作階段狀態模式 https://msdn.microsoft.com/zh-tw/library/ms178586(v=vs.100).aspx ▪ ASP.NET 工作階段狀態概觀 https://msdn.microsoft.com/zh-tw/library/ms178581(v=vs.100).aspx ▪ HttpSessionState.Timeout 屬性 https://msdn.microsoft.com/zh-tw/library/system.web.sessionstate.httpsessionstate.timeout(v=vs.110).aspx

本文件之智慧財產權屬數位發展部資通安全署擁有。

Java 實作範例：

在 Java 網站中，可以直接在 web.xml 設置 session-timeout 的項目值，代表會談可存活的時間，單位為分鐘。除非 WEB 應用程式於程式源碼內設定會談存活時間，否則 web.xml 內的會談設定值會影響到所有伺服器端部署之 Web 應用程式。

```
<?xml version="1.0" encoding="UTF-8"?>
<web-app ...>
    ...
    <session-config>
        <session-timeout>30</session-timeout>
    </session-config>
</web-app>
```

第二種方法則是在 Servlet 中使用 HttpSession 物件的 setMaxInactiveInterval()方法，這邊的設定會覆寫掉 web.xml 中的設定。與在 web.xml 中設定的差異是，這裡傳入的數字時間單位為秒，且影響範圍也僅限於這個 session 物件，故不會影響到其他的 Web 應用程式。其範例如下：

```
HttpSession session = request.getSession(); //取得 session 物件
session.setMaxInactiveInterval(1800); //將此 session 的生命週期設定為 1800 秒
```

參考連結：

- Creating and Configuring Servlets
  https://docs.oracle.com/cd/E13222_01/wls/docs92/webapp/configureservlet.html

PHP 實作範例：

PHP 的 Session timeout 時間設定，可在 php.ini 檔案中根據 session.gc_maxlifetime 值而決定，預設值 1440，單位秒，也就是 24 分

本文件之智慧財產權屬數位發展部資通安全署擁有。

鐘。若設定為 30 分鐘，則為 1800 秒。

; After this number of seconds, stored data will be seen as 'garbage' and

; cleaned up by the garbage collection process.

; http://php.net/session.gc-maxlifetime

session.gc_maxlifetime = 1800

參考連結：

▪ PHP: Runtime Configuration - Manual

http://php.net/manual/en/session.configuration.php

資料來源： 本計畫整理

●使用者的會談階段在登出後失效。

– 相關實作建議，詳見表 9。

表9 帳號管理-實作建議 2

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	帳號管理	使用者的會談階段在登出後失效
查核方式：☐自動化工具檢測 ☒人工審查				
控制措施： 系統應有手動機制，使用者明確進行登出後，將該使用者的會談階段設為失效。 **實作指導：** 使用者登出時，應使用預設的會談管理控制，將該使用者所使用會談清除，以明確執行登出功能，讓使用者能正確回到未登入的狀況。				

資料來源： 本計畫整理

本文件之智慧財產權屬數位發展部資通安全署擁有。

– 相關程式範例，詳見表 10。

表10 帳號管理-程式範例 2

ASP.NET 實作範例：
ASP.NET 網站中，Session 的控制方式示範如下： ▪ 登出清除會談後，並將使用者頁面轉為首頁。 Session.Abandon(); Response.Redirect("~/"); 參考連結： ▪ Session.Abandon Method http://msdn.microsoft.com/zh-tw/library/ms524310.aspx ▪ HttpSessionState.Abandon Method () https://msdn.microsoft.com/en-us/library/system.web.sessionstate.httpsessionstate.abandon(v=vs.110).aspx ▪ Session.Contents.Remove Method https://msdn.microsoft.com/en-us/library/ms524566(v=vs.90).aspx ▪ IHttpSessionState.Abandon Method () https://msdn.microsoft.com/en-us/library/system.web.sessionstate.ihttpsessionstate.abandon(v=vs.110).aspx
Java 實作範例：

若欲清除會談可使用 invalidate()方法，並且另外將使用者頁面重新導向至登入頁面，範例如下：
public class LogoutServlet extends HttpServlet {
protected void doPost(HttpServletRequest request, HttpServletResponse response) throws ServletException, IOException {
//讓會談失效

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
            request.getSession().invalidate();
            //導向登入頁面
            response.sendRedirect(request.getContextPath() + "/Login.jsp");
        }
}
```

參考連結：

- How to Use Sessions
  https://docs.oracle.com/cd/E19857-01/819-6518/gcxvp/index.html
- Invalidating a Session
  https://docs.oracle.com/cd/E19146-01/821-1830/abxdj/index.html

PHP 實作範例：

```
<?php
session_start();
$_SESSION = array();
if (ini_get("session.use_cookies")) {
        $params = session_get_cookie_params();
        setcookie(session_name(), '', time() - 42000,
                $params["path"], $params["domain"],
                $params["secure"], $params["httponly"]
        );
}

// Finally, destroy the session.
session_destroy();
?>
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

參考連結：

- proper way to logout from a session in PHP
  https://stackoverflow.com/questions/3512507/proper-way-to-logout-from-a-session-in-php
- PHP: session_unset - Manual
  http://php.net/manual/en/function.session-unset.php
- PHP: session_destroy - Manual
  http://php.net/manual/en/function.session-destroy.php

資料來源： 本計畫整理

4.1.1.2 資訊系統應依照機關所規定之情況及條件(如上班時間或指定 IP 來源)，使用資訊系統

本項目實作項目包含以下 1 項：

●管理者介面限制存取來源或不允許遠端存取。

– 相關實作建議，詳見表 11。

表11 帳號管理-實作建議 3

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	帳號管理	管理者介面限制存取來源或不允許遠端存取
查核方式：☒自動化工具檢測 ☒人工審查				
控制措施： 說明：管理者介面通常可執行系統中較高權限的功能(例如權限與人員管理)，其相對風險較高，因此應盡可能不允許遠端存取，僅允許透過				

本文件之智慧財產權屬數位發展部資通安全署擁有。

內部網路存取，以避免有心人士從外部嘗試攻擊之可能。若有必要允許外部遠端存取管理者介面，應限制特定存取來源 IP，避免全面性開放存取。

實作指導：

管理者介面存取時，檢查來源 IP 是本機或特定 IP 來源。

資料來源： 本計畫整理

– 相關程式範例，詳見表 12。

表12 帳號管理-程式範例 3

ASP.NET 實作範例：

以下範例可以取得連線本系統之用戶端 IP：

```
public static string GetClientIP()
{
    if (null == HttpContext.Current.Request.ServerVariables["HTTP_VIA"])
    {
        return HttpContext.Current.Request.ServerVariables["REMOTE_ADDR"];
     }
    else
    {
        return
HttpContext.Current.Request.ServerVariables["HTTP_X_FORWARDED_FOR"];
     }
}
public static string GetClientIPv4()
{
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
string ipv4 = String.Empty;
foreach (IPAddress ip in Dns.GetHostAddresses(GetClientIP()))
{
    if (ip.AddressFamily.ToString() == "InterNetwork")
    {
            ipv4 = ip.ToString();
            break;
     }
}

if (ipv4 != String.Empty)
{
      return ipv4;
 }
 //利用 Dns.GetHostEntry 方法，由獲取的 IPv6 位址反查 DNS 紀錄，
 //再逐一判斷何者屬 IPv4 協定，即可轉為 IPv4 位址。
 foreach (IPAddress ip in Dns.GetHostEntry(GetClientIP()).AddressList)
 {
       if (ip.AddressFamily.ToString() == "InterNetwork")
       {
           ipv4 = ip.ToString();
           break;
        }
  }
   return ipv4;
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
}
```

參考連結：

- How to obtain IP address of a client behind proxy via web service
  https://blogs.msdn.microsoft.com/asiatech/2009/08/27/how-to-obtain-ip-address-of-a-client-behind-proxy-via-web-service/
- Dns.GetHostEntry 方法 (IPAddress) (System.Net)
  https://msdn.microsoft.com/zh-tw/library/ms143997(v=vs.110).aspx
- Dns.GetHostEntry 方法 (String) (System.Net)
  https://msdn.microsoft.com/zh-tw/library/ms143998(v=vs.110).aspx

Java 實作範例：

當使用者試圖遠端存取管理者介面時，取得來源 IP 資訊，驗證其合法性。

```
public static boolean isIpAllow(HttpServletRequest httpServletRequest) {
        String userIP = httpServletRequest.getRemoteAddr();//取得使用者 IP
        String allowedIP = Property.getString("all.ip.allow.reg");//取得允許列表
        //用正規表示式描述允許的 ip
        Pattern p = Pattern.compile(allowedIP);
        Matcher m = p.matcher(userIP);
        //ip 來源的檢查動作
        return m.matches( );
}
```

- Interface ServletRequest
  http://docs.oracle.com/javaee/6/api/javax/servlet/ServletRequest.html

PHP 實作範例：

PHP 可用以下方法取得使用者 IP：

本文件之智慧財產權屬數位發展部資通安全署擁有。

$_SERVER["REMOTE_ADDR"];

但使用者若使用代理伺服器上網時，則上面的語法會取得代理伺服器 IP，並非使用者真正的 IP，因此必須先檢查以下兩個變數：

$_SERVER["HTTP_CLIENT_IP"];

$_SERVER["HTTP_X_FORWARDED_FOR"];

若上述的兩個變數沒有數值存在，表示使用者並非透過 Proxy Server 上網，可使用『REMOTE_ADDR』直接取得 IP。 完整範例如下：

```
<?php
if (!empty($_SERVER['HTTP_CLIENT_IP']))
{
   $ip=$_SERVER['HTTP_CLIENT_IP'];
}
else if (!empty($_SERVER['HTTP_X_FORWARDED_FOR']))
{
   $ip=$_SERVER['HTTP_X_FORWARDED_FOR'];
}
else
{
   $ip=$_SERVER['REMOTE_ADDR'];
}
?>
```

參考連結：

- PHP: $_SERVER - Manual
  http://php.net/manual/en/reserved.variables.server.php

資料來源： 本計畫整理

本文件之智慧財產權屬數位發展部資通安全署擁有。

4.1.2 最小權限(Least Privilege)

最小權限類別之控制措施包含以下項目：

●採用最小權限原則，只允許使用者(或代表使用者行為的程序)依據機關任務和業務功能，完成指派任務所需之授權存取。

與最小權限控制措施相關的應用程式技術面項目，整理如下：

4.1.2.1 採用最小權限原則，只允許使用者(或代表使執用者行為的程序)依據機關任務和業務功能，完成指派任務所需之授權存取

本項目實作項目包含以下 2 項：

●對使用者/角色，僅賦予所需要的最低權限。

– 相關實作建議，詳見表 13。

表13 最小權限-實作建議 1

適用分級			類別	實作項目
普	中	高		
	◎	◎	最小權限	對使用者/角色，僅賦予所需要的最低權限
查核方式：☐自動化工具檢測　☒人工審查				
控制措施： 明確定義系統中角色及對應的權限，系統上線驗收時，應審查使用者賦予的角色及其取得的權限是否適當，系統上線後亦定期審查使用者所擁有的角色與權限清單。相關資訊宜提供系統介面以供查詢或匯出。 **實作指導：**				

本文件之智慧財產權屬數位發展部資通安全署擁有。

略，此為實作規劃設計問題，與實際技術無關。
實作範例：略，此為實作規劃設計問題，與實際技術無關。
參考連結： ▪ Least privilege - OWASP https://www.owasp.org/index.php/Least_privilege ▪ Least Privilege Violation - OWASP https://www.owasp.org/index.php/Least_Privilege_Violation

資料來源： 本計畫整理

●軟體程序(process)及伺服器服務，以一般使用者權限執行，不以系統管理員或最高權限。

– 相關實作建議，詳見表 14。

表14 最小權限-實作建議 2

適用分級			類別	實作項目
普	中	高		
	◎	◎	最小權限	軟體程序(process)及伺服器服務，以一般使用者權限執行，不以系統管理員或最高權限執行
查核方式：☐自動化工具檢測 ☒人工審查				
控制措施： 系統之軟體程序或伺服器服務，若以系統最高權限或管理員權限啟動，將造成攻擊者成功入侵伺服器時，可以取得作業系統最高權限。應於作業系統增加服務專用之使用者，並授予執行伺服器服務及讀寫相關檔案的有限範圍權限，使其可以正常執行軟體程序作業，同時避免過高權限之風險。				

本文件之智慧財產權屬數位發展部資通安全署擁有。

實作指導：
以較低權限的使用者去啟動軟體程序或伺服器服務。

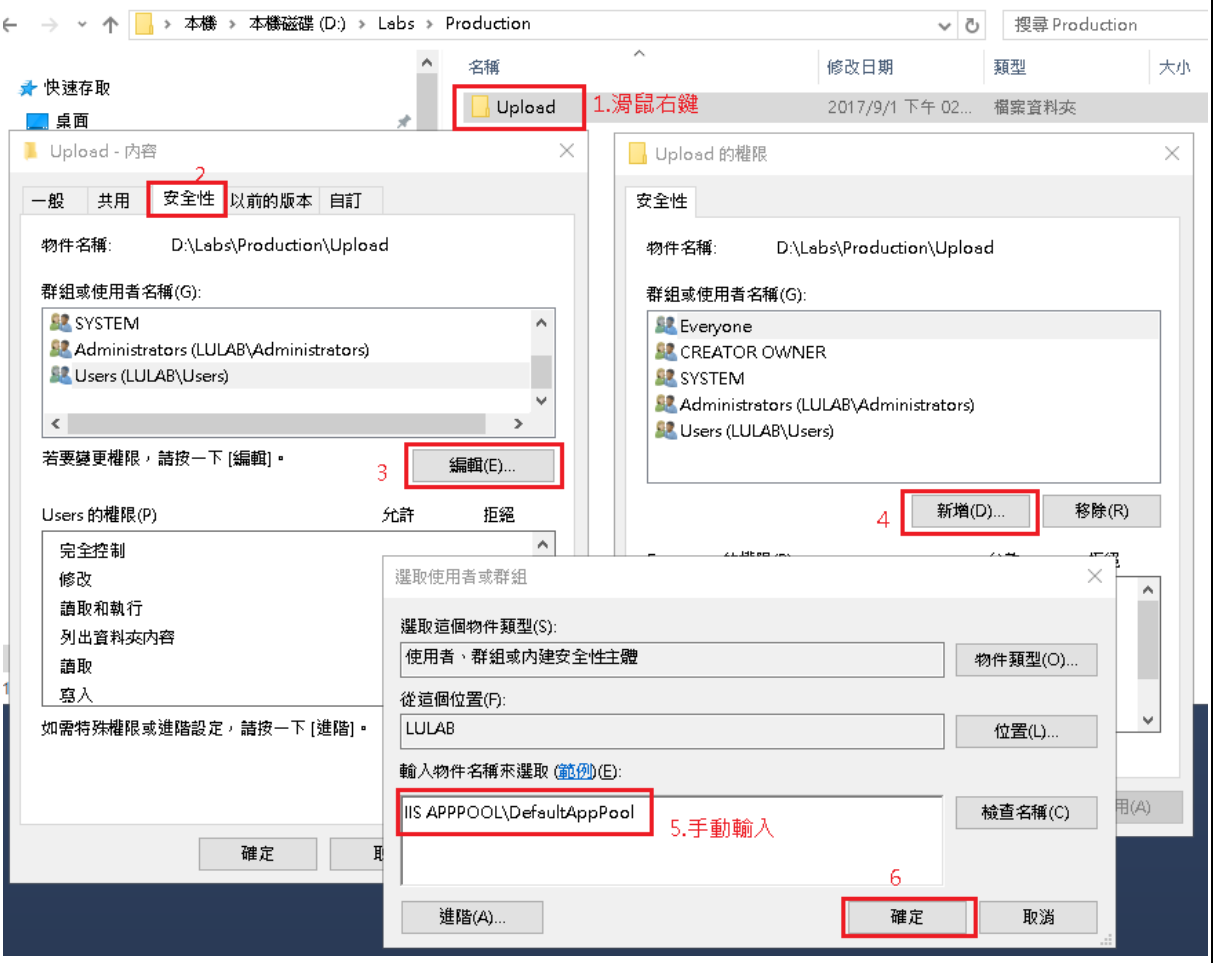
資料來源： 本計畫整理

– 相關程式範例，詳見表 15。

表15 最小權限-程式範例 2

IIS 實作範例：
IIS 應用程式執行權限預設為 IIS_IUSRS，可以存取該主機上所有網站；但實際上有一權限更小的帳號，也就是 IIS APPPOOL\DefaultAppPool 應用程式集區虛擬帳號(注意 IIS 和 AppPool 之間有一個空白，此帳號只能手動直接輸入，無法搜尋得到)，只能存取使用該應用程式集區的網站。畫面詳見圖 3。

本文件之智慧財產權屬數位發展部資通安全署擁有。

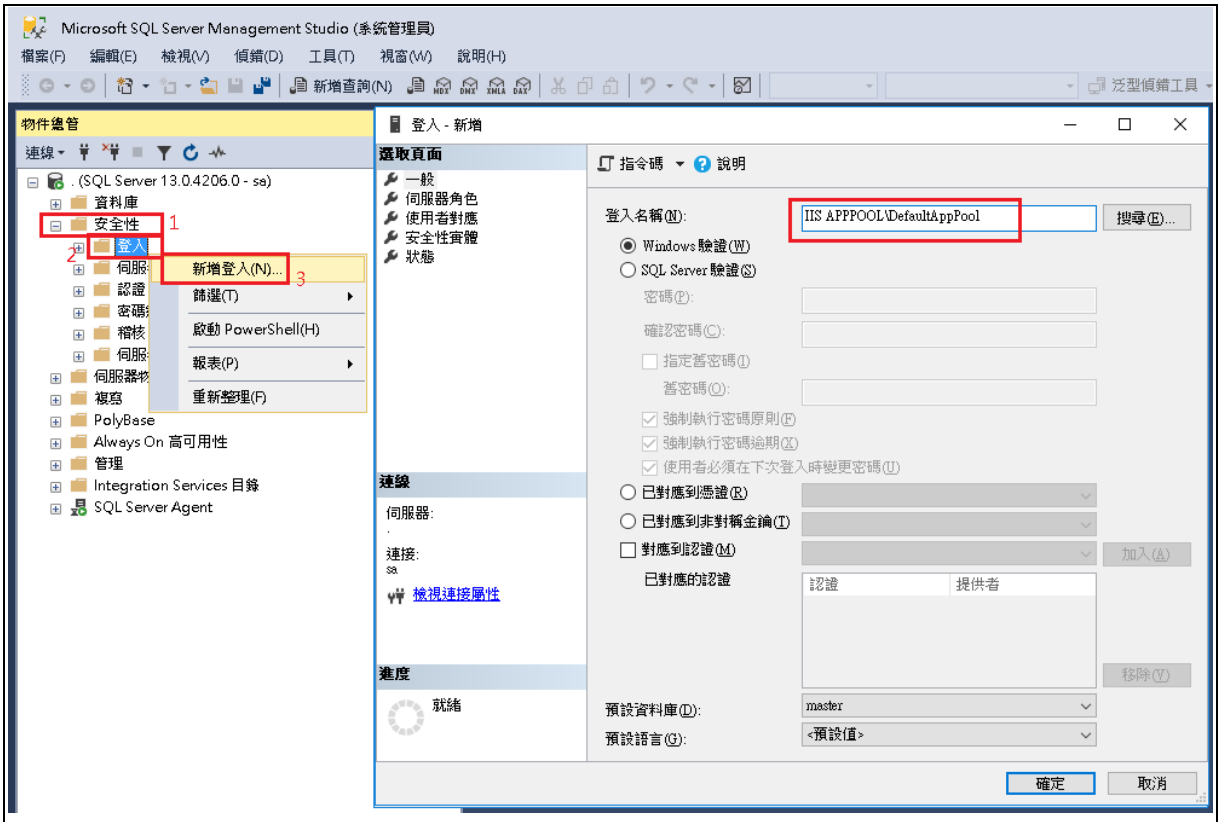


資料來源：本計畫整理

圖3　程序及服務不以系統管理員或最高權限執行(.NET)圖 1

網站的 SQL Server 的資料庫存取帳號，可以變更 IIS APPPOOL\DefaultAppPool；IIS 網站的執行使用者也設定為 IIS APPPOOL\DefaultAppPool，以較小的權限進行執行。畫面詳見圖 4。

本文件之智慧財產權屬數位發展部資通安全署擁有。



資料來源：本計畫整理

圖4　程序及服務不以系統管理員或最高權限執行(.NET)圖 2

對於主機上只有一個網站的情況下，使用 IIS_IUSRS 或 IIS APPPOOL\DefaultAppPool 帳號並無差別，而對於主機上有多網站的情況下，後者的權限略小於前者。

參考連結：

- Application Pool Identities
  https://docs.microsoft.com/en-us/iis/manage/configuring-security/application-pool-identities
- 設定 ASP.NET 處理序識別
  https://msdn.microsoft.com/zh-tw/library/dwc1xthy(v=vs.100).aspx

Java 實作範例：

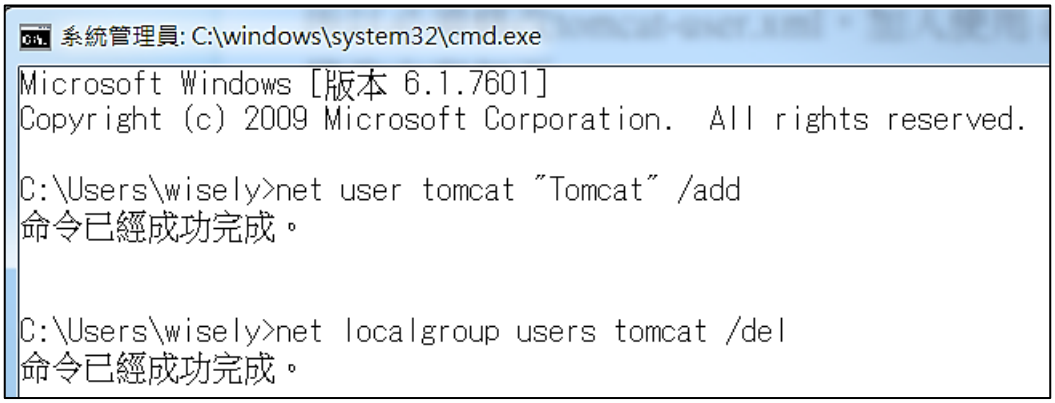
本文件之智慧財產權屬數位發展部資通安全署擁有。

以常用的 Apache Tomcat 為範例：

可執行以下指令新增系統帳號"Tomcat"，並刪除其權限。設定畫面詳見圖 5。

C:\>net user tomcat "Tomcat"　/add

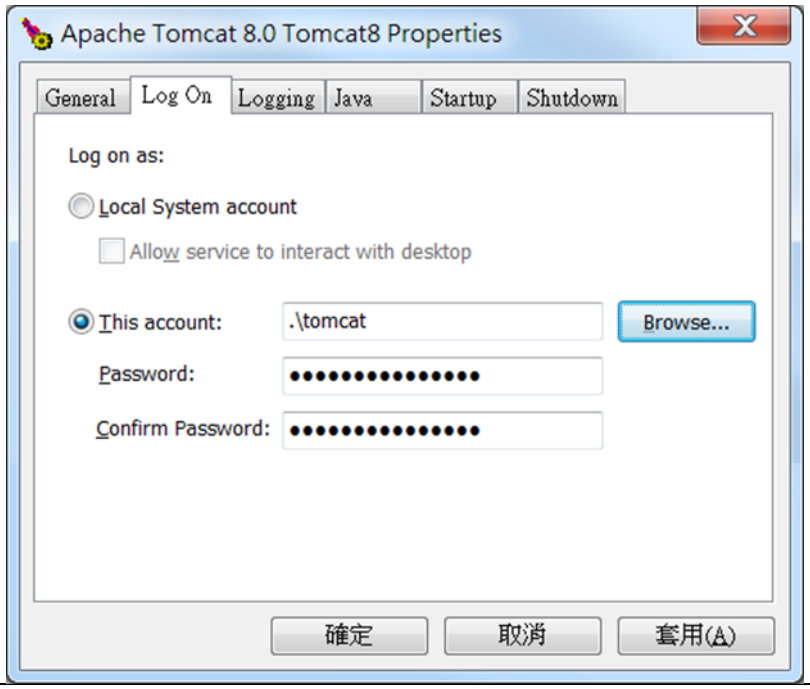
C:\>net localgroup users tomcat　/del



資料來源：本計畫整理

圖5　新增系統帳號並刪除權限

設定啟動 Tomcat 程序所使用的帳號，詳見圖 6。



本文件之智慧財產權屬數位發展部資通安全署擁有。

資料來源：本計畫整理

圖6　程序及服務不以系統管理員或最高權限執行(Java)

參考連結：

- Net localgroup

  https://technet.microsoft.com/en-us/library/bb490706.aspx

PHP 實作範例：

建立 apache 使用者和群組，範例如下：

```
# groupadd –r apache
# useradd apache -r -g apache -d /var/www -s /sbin/nologin
```

在 apache 設定檔(httpd.conf)中設定僅有 apache 使用者和群組可使用，範例如下：

```
User apache
Group apache
```

參考連結：

- Least privilege - OWASP

  https://www.owasp.org/index.php/Least_privilege
- Principle of least privilege - Wikipedia

  https://en.wikipedia.org/wiki/Principle_of_least_privilege
- SCG WS Apache - OWASP

  https://www.owasp.org/index.php/SCG_WS_Apache#Run_Apache_with_least_privilege_user

資料來源： 本計畫整理

4.1.3 遠端存取(Remote Access)

遠端存取類別之控制措施包含以下 6 項：

本文件之智慧財產權屬數位發展部資通安全署擁有。

●對於每一種允許之遠端存取類型，都應先取得授權，建立使用限制、組態需求、連線需求及文件化。

●資訊系統使用者授權檢查應於伺服端集中過濾。

●應監控資訊系統遠端連線。

●資訊系統應採用加密機制來保護遠端存取連線的機密性。

●資訊系統遠端存取之來源應為機關已預先定義及管理之存取控制點。

●依維運需求，授權透過遠端執行特定之功能及存取相關資訊。

與遠端存取控制措施相關的應用程式技術面項目，整理如下：

4.1.3.1 對於每一種允許之遠端存取類型，都應先取得授權，建立使用限制、組態需求、連線需求及文件化

本項目實作項目包含以下 1 項：

●採用伺服端的集中過濾機制檢查使用者授權。

– 相關實作建議，詳見表 16。

表16 遠端存取-實作建議 1

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	遠端存取	採用伺服端的集中過濾機制檢查使用者授權
查核方式：☐自動化工具檢測　☒人工審查				
控制措施：				

本文件之智慧財產權屬數位發展部資通安全署擁有。

針對呼叫外部授權服務的存取應集中編寫於函式庫，以集中管理存取控制，避免各自實作時，忽略存取控制的驗證而造成系統安全上的危害。

實作指導：

叫用外部授權服務時，應避免直接叫用導致未經授權的直接存取，叫用外部服務的方式應集中管理於函式庫，以確實管理外部服務資料，避免因直接叫用導致驗證處理不一致，造成未經授權的直接存取。

資料來源： 本計畫整理

– 相關程式範例，詳見表 17。

表17 遠端存取-程式範例 1

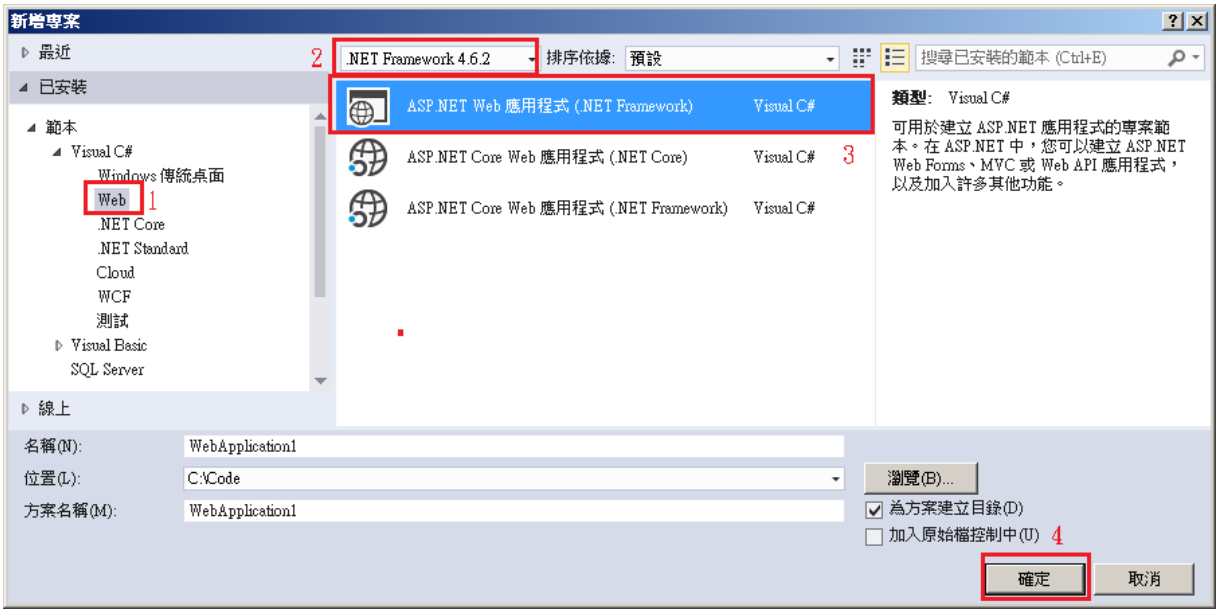
ASP.NET 實作範例：
微軟自.NET 2.0 開始提供 ASP.NET Membership(成員資格)驗證授權機制，可以讓使用者不用寫一行程式碼，在建立方案時候就自動建立驗證授權機制。 Visual Studio 2013 和.NET 4.5 時改版提供了 ASP.NET Identity(身分)驗證授權機制。 在 Visual Studio 2017 點選「檔案」下拉選單，點選「新增」，點選「專案」，畫面詳見圖 7。    資料來源：本計畫整理

圖7 Visual Studio 建立身分鑑別圖 1

點選畫面左邊的「Web」，.NET Framework 點選 4.5 或更新版本，選擇

本文件之智慧財產權屬數位發展部資通安全署擁有。

「ASP.NET Web 應用程式(.NET Framework)」，按下「確定」按鈕，畫面詳見圖 8。

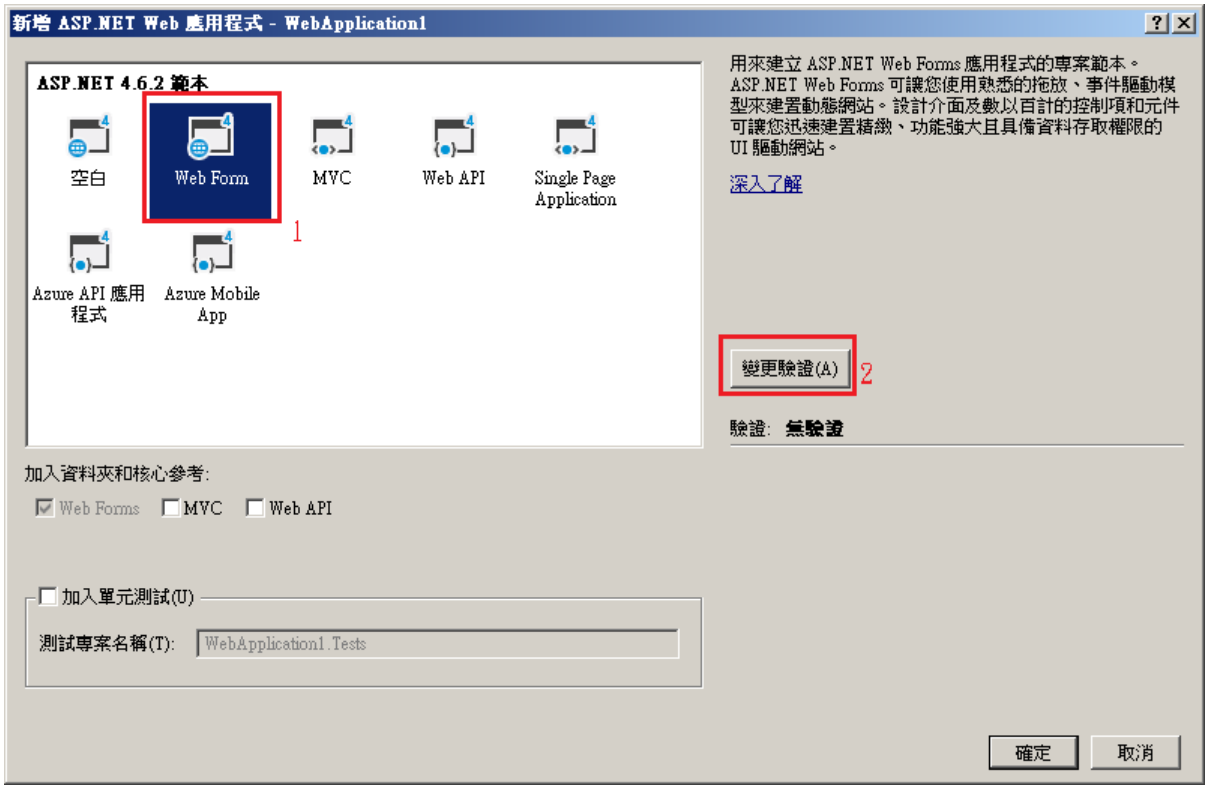


資料來源：本計畫整理

圖8　Visual Studio 建立身分鑑別圖 2

點選「Web Form」，按下「變更驗證」按鈕，畫面詳見圖 9。

本文件之智慧財產權屬數位發展部資通安全署擁有。



資料來源：本計畫整理

圖9　Visual Studio 建立身分鑑別圖 3

從「無驗證」改選為「個別使用者帳號」即可，Visual Studio 會自動建立身分鑑別相關登入網頁畫面、資料庫資料表、相關程式碼和設定，畫面詳見圖 10。



本文件之智慧財產權屬數位發展部資通安全署擁有。

資料來源：本計畫整理

圖10 Visual Studio 建立身分鑑別圖 4

參考連結：

- ASP.NET Identity | The ASP.NET Site
  https://www.asp.net/identity
- Introducing ASP.NET Identity – A membership system for ASP.NET applications https://blogs.msdn.microsoft.com/webdev/2013/06/27/introducing-asp-net-identity-a-membership-system-for-asp-net-applications/
- Microsoft.AspNet.Identity 命名空間 https://msdn.microsoft.com/zh-tw/library/microsoft.aspnet.identity(v=vs.111).aspx
- HttpContext.User 屬性
  https://msdn.microsoft.com/zh-tw/library/system.web.httpcontext.user(v=vs.110).aspx
- Explained: Forms Authentication in ASP.NET 2.0
  http://msdn.microsoft.com/en-us/library/aa480476.aspx
- FormsAuthentication 類別
  https://msdn.microsoft.com/zh-tw/library/system.web.security.formsauthentication(v=vs.110).aspx
- HOW TO：實作簡單表格驗證
  https://msdn.microsoft.com/zh-tw/library/xdt4thhy(v=vs.100).aspx
- How to: Implement Simple Forms Authentication
  https://msdn.microsoft.com/en-us/library/xdt4thhy.aspx
- ASP.NET Forms Authentication Overview
  https://msdn.microsoft.com/en-us/library/7t6b43z4(v=vs.100).aspx

Java 實作範例：

本文件之智慧財產權屬數位發展部資通安全署擁有。

web.xml 示例：

```
<filter>
    <filter-name>AccCtrlFilter</filter-name>
    <filter-class>demo.AccCtrlFilter</filter-class>
</filter>
<filter-mapping>
    <filter-name>AccCtrlFilter</filter-name>
    <url-pattern>/Main.jsp</url-pattern>
</filter-mapping>
```

LoginAction.java 程式示例：

```
Request.getSession().setAttribute(“id”,id);
Map m = new HashMap();
m.put(“/Main.jsp”,”read”);
request.getSession().setAttrubute(“priv”,m);
```

AccCtrlFilter.java 程式示例：

```
HttpServletRequest req = (HttpServletRequest) request;
HttpServletResponse res = (HttpServletResponse) response;
String user_id = (String) session.getAttribute("id");
Map priv = (Map) session.getAttribute("priv");
if (user_id == null || priv == null){
    res.sendRedirect(req.getContextPath()+"/Login.jsp");
    return;
}

String uri = req.getRequestURI();
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
//檢查權限
if (priv.containKey(uri)){
	chain.doFilter(request, response);
}else{
	res.sendRedirect(req.getContextPath()+"/Error.jsp");
	return;
}
```

參考連結：

- Creating and Configuring Servlets
  https://docs.oracle.com/cd/E13222_01/wls/docs92/webapp/configureservlet.html

PHP 實作範例：

```
<?php
$name = $_POST['name'];
$password = $_POST['password'];

if(!isset($name) || !isset($password)){ ?>
	<form method="post" action="test.php">
		<p>UserName:<input type="text" name="name" /></p>
		<p>Password:<input type="password" name="password" /></p>
		<p><input type="submit" name="submit" value="Login" /></p>
	</form>

<?php
}else{

$link = mysqli_connect("localhost", "root", "password", "my_db");
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
/* check connection */
if (mysqli_connect_errno()) {
    printf("Connect failed: %s\n", mysqli_connect_error());
    exit();
}

/* create a prepared statement */
$stmt = mysqli_stmt_init($link);
if (mysqli_stmt_prepare($stmt, 'SELECT count(*) as counts FROM accounts WHERE
Name=? and Password=Password(?) ')) {

    /* bind parameters for markers */
    mysqli_stmt_bind_param($stmt, "ss", $name, $password);

    /* execute query */
    mysqli_stmt_execute($stmt);

    /* bind result variables */
    mysqli_stmt_bind_result($stmt, $counts);

    /* fetch value */
    mysqli_stmt_fetch($stmt);

//printf("counts : %s <br \>", $counts);

    /* close statement */
    mysqli_stmt_close($stmt);
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
        if($counts>0){
                printf("Login Success !\n");
        }else{
                printf("Account or Password does not exist !\n");
        }
}

/* close connection */
mysqli_close($link);
}
?>
```

參考連結：

- Category:Access Control - OWASP
  https://www.owasp.org/index.php/Category:Access_Control
- PHP Security for Developers - OWASP
  https://www.owasp.org/index.php/PHP_Security_for_Developers
- OWASP Secure Coding Practices Checklist - OWASP
  https://www.owasp.org/index.php/OWASP_Secure_Coding_Practices_Checklist
- SQL Injection Prevention Cheat Sheet - OWASP
  https://www.owasp.org/index.php/SQL_Injection_Prevention_Cheat_Sheet
- PHP: mysqli::prepare - Manual
  http://php.net/manual/en/mysqli.prepare.php
- PHP: mysqli_stmt::prepare - Manual
  http://php.net/manual/en/mysqli-stmt.prepare.php

資料來源： 本計畫整理

4.1.3.2 採用伺服端的集中過濾機制檢查資訊系統使用者授權

相關實作建議與 4.1.3.1 相同，詳見表 16。

本文件之智慧財產權屬數位發展部資通安全署擁有。

4.2 稽核與可歸責性(Audit and Accountability)

稽核與可歸責性分為「稽核事件」、「稽核紀錄內容」，「稽核儲存容量」、「稽核處理失效之回應」、「時戳及校時」及「稽核資訊之保護」等 6 項控制措施，說明如下。

4.2.1 稽核事件(Audit Events)

稽核事件類別之控制措施包含以下 4 項：

- 依律定之時間週期及紀錄留存政策，保留稽核紀錄，並滿足法規要求。
- 確保資訊系統有稽核特定事件(如更改密碼、登錄失敗、資訊系統存取失敗)之能力，並決定有哪些特定事件在資訊系統中應該被稽核。
- 應稽核資訊系統管理者帳號所執行之各項功能。
- 應定期審查稽核事件。

與稽核事件控制措施相關的應用程式技術面項目，整理如下：

4.2.1.1 確保資訊系統有稽核特定事件(如更改密碼、登錄失敗、資訊系統存取失敗)之能力，並決定有哪些特定事件在資訊系統中應該被稽核

本項目實作項目包含以下 1 項：

- 針對身分鑑別失敗、存取資源失敗、重要行為、重要資料異動、功能錯誤及管理者行為進行日誌記錄。

– 相關實作建議，詳見表 18。

表18 稽核事件-實作建議

適用分級	類別	實作項目

本文件之智慧財產權屬數位發展部資通安全署擁有。

普	中	高		
◎	◎	◎	稽核事件	針對身分鑑別失敗、存取資源失敗、重要行為、重要資料異動、功能錯誤及管理者行為進行日誌記錄
查核方式：☐自動化工具檢測　☒人工審查				
控制措施： 系統留存日誌紀錄之目的包含程式除錯、行為歸責、稽核取證及法規要求等。記錄身分鑑別失敗、存取資源失敗、重要行為、重要資料異動、功能錯誤及管理者行為等，將有助於定期稽核系統行為及資安事件追查。 **實作指導：** 程式語言例如 ASP.NET、Java，以及 PHP 等，皆提供原生 API 或元件可將訊息紀錄寫入檔案進行留存，亦可使用第三方元件。				

資料來源： 本計畫整理

– 相關程式範例，詳見表 19。

表19 稽核事件-程式範例

ASP.NET 實作範例：

以下為使用第三方元件 Nlog 進行驗證記錄之範例：
NLog.Logger logger = NLog.LogManager.GetCurrentClassLogger();
if (UserLogin(this.TextBoxAccount.Text, this.TextBoxPassword.Text)){
//登入成功的處理
logger.Info(TextBoxAccount.Text + "登入成功!!");
}
else{

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
//登入失敗的處理
logger.Warn(TextBoxAccount.Text + "登入失敗!!");
}
```

參考連結：

- NLog
  NLog 是第三方的開放原始碼專案，提供免費下載。
  http://nlog-project.org/
  http://nlog.codeplex.com/
- Default Log File Settings for Web Sites <logFile> | Microsoft Docs
  https://docs.microsoft.com/en-us/iis/configuration/system.applicationhost/sites/sitedefaults/logfile/
- Enhanced Logging for IIS 8.5 | Microsoft Docs
  https://docs.microsoft.com/en-us/iis/get-started/whats-new-in-iis-85/enhanced-logging-for-iis85
- Advanced Logging for 2016
  https://social.technet.microsoft.com/Forums/en-US/af22607e-54f0-48d4-98e0-5910af38cc83/advanced-logging-for-2016?forum=ws2016
- IIS 10 with Advanced Logging RSS
  https://forums.iis.net/t/1234416.aspx?IIS+10+with+Advanced+Logging
- HTTP Logging <httpLogging> | Microsoft Docs
  https://docs.microsoft.com/en-us/iis/configuration/system.webServer/httpLogging

Java 實作範例：

可使用 Apache Log4j 進行日誌記錄，Log4j 的級別分為 DEBUG、INFO、WARN、ERROR，以及 FATAL，預設只顯示 INFO 等級以上的紀錄。

```
package demo.log4j;
import org.apache.log4j.Logger;
public class Log4jDemo {
    static public void main(String args[]) {
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
        Logger logger = Logger.getLogger(Log4jDemo.class);
        logger.debug("This is a debug message");
        logger.info("This is an info message");
        logger.error("This is an error message");
    }
}
```

參考連結：

- Apache log4j
  https://logging.apache.org/log4j

PHP 實作範例：

可使用 Apache Log4php 進行日誌記錄。

```
// Insert the path where you unpacked log4php
include('log4php/Logger.php');
// Tell log4php to use the configuration file
Logger::configure('config.xml');
// Fetch a logger, it will inherit settings from the root logger
$log = Logger::getLogger('myLogger');
// Start logging
$log->trace("My first message.");
$log->debug("My second message.");
$log->info("My third message.");
$log->warn("My fourth message.");
$log->error("My fifth message.");
$log->fatal("My sixth message.");
```

參考連結：

- Apache log4php
  https://logging.apache.org/log4php/quickstart.html

本文件之智慧財產權屬數位發展部資通安全署擁有。

資料來源： 本計畫整理

4.2.1.2 應稽核資訊系統管理者帳號所執行之各項功能

相關實作建議與 4.2.1.1 相同，詳見表 18。

4.2.2 稽核紀錄內容(Content of Audit Records)

稽核紀錄內容類別之控制措施包含以下 2 項：

- 資訊系統產生之稽核紀錄至少應包含以下資訊：事件類型、何時發生、何處發生及任何與事件相關之使用者之身分識別，並採用單一的日誌紀錄機制，確保輸出格式的一致性。
- 資訊系統產生的稽核紀錄，應依需求納入額外的資訊。

與稽核紀錄內容控制措施相關的應用程式技術面項目，整理如下：

4.2.2.1 資訊系統產生之稽核紀錄至少應包含以下資訊：事件類型、何時發生、何處發生及任何與事件相關之使用者之身分識別，並採用單一的日誌紀錄機制，確保輸出格式的一致性

本項目實作項目包含以下 2 項：

- 日誌紀錄包含以下項目：1.識別使用者之 ID(不可為個資類型)。2.經系統校時後的時間戳記。3.執行的功能或存取的資源。4.事件類型或等級(priority)。5.事件描述。

  – 相關實作建議與範例，詳見表 20。

表20 稽核紀錄內容-實作建議與範例 1

適用分級	類別	實作項目

本文件之智慧財產權屬數位發展部資通安全署擁有。

普	中	高		
◎	◎	◎	稽核紀錄內容	日誌紀錄包含以下項目：1.識別使用者之ID(不可為個資類型)。2.經系統校時後的時間戳記。3.執行的功能或存取的資源。4.事件類型或等級(priority)。5.事件描述

查核方式：☐自動化工具檢測　☒人工審查

控制措施：

日誌紀錄宜考慮包含以下項目：1.使用者 ID，不可為個資類型，避免共用帳號之情況。2.時間，系統應設定定期校時。3.執行之功能或存取之資源名稱。4.事件類型或優先等級。5.執行結果或事件描述。6.事件發生當下相關物件資訊。7.網路來源與目的位址。8.錯誤代碼，便於事件追查。

實作指導：

在記錄事件時，應考慮記錄上述所列的欄位，以便日後追查。

ASP.NET 實作範例：

以下為使用第三方元件 Nlog 進行驗證記錄之範例：

```
NLog.Logger logger = NLog.LogManager.GetCurrentClassLogger();
string msg = this.TextBoxAccount.Text;
msg = msg + "," + DateTime.Now.ToString();
msg = msg + "," + resourceName;
msg = msg + "," + priority;
msg = msg + "," + executeResultDesc;
msg = msg + "," + relativeObject;
msg = msg + "," + myIP;
msg = msg + "," + errorCode;
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

logger.Info(msg);

參考連結：

▪NLog

NLog 是第三方的開放原始碼專案，提供免費下載。

http://nlog-project.org/

http://nlog.codeplex.com/

▪Default Log File Settings for Web Sites <logFile> | Microsoft Docs

Java 實作範例：

可使用 Apache Log4j 進行日誌紀錄，以下為使用者登入失敗的日誌紀錄範例：

```
Logger logger = Logger.getLogger(Log4jDemo.class);
logger.info("帳號:"+ demo.getAccount( ));
logger.info("時間:"+ Calendar.getInstance( ).get(Calendar.MILLISECOND));
logger.info("來源 IP:"+ httpServletRequest.getRemoteAddr( ));
logger.info("Action:"+"ValidateAuth( )");
logger.info("事件:"+"身分驗證錯誤");
```

參考連結：

▪ Apache log4j

https://logging.apache.org/log4j

PHP 實作範例：

可使用 Apache Log4php 進行日誌記錄。

```
// Insert the path where you unpacked log4php
include('log4php/Logger.php');
// Tell log4php to use the configuration file
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
Logger::configure('config.xml');
// Fetch a logger, it will inherit settings from the root logger
$log = Logger::getLogger('myLogger');
// Start logging
$datetime = date ("Y-m-d H:i:s" , mktime(date('H')+8, date('i'), date('s'), date('m'), date('d'), date('Y'))) ; //台灣當地時區
$log->info($userid . ", " . $time . ", " . $datetime . ", " . $func_name . ", " . $priority. ", " . $event_desc . ", " . $event_relative . ", " . $myip . ", " . $error_code );
```

參考連結：

▪Apache log4php

https://logging.apache.org/log4php/quickstart.html

資料來源： 本計畫整理

●採用單一的日誌紀錄機制，確保輸出格式的一致性

– 相關實作建議與範例，詳見表 21。

表21 稽核紀錄內容-實作建議與範例 2

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	稽核紀錄內容	採用單一的日誌紀錄機制，確保輸出格式的一致性
查核方式：☐自動化工具檢測 ☒人工審查				
控制措施： 系統日誌紀錄應盡可能採用單一的 Log 機制，例如同一伺服器軟體應產出相同格式之日誌紀錄，以便於事件比對與追查。				

本文件之智慧財產權屬數位發展部資通安全署擁有。

實作指導： 在 ASP.NET 的程式中，可將重要的資料檔案存放在 App_Data 中，這個目錄是 ASP.NET 規範中規劃用來存放資料的，可放置任何類型的檔案(XML、Database File、Text File…)，這個目錄的特性是可經由程式控制存取，卻不會被網頁伺服器的要求下載，可確保在此目錄中檔案的安全。
ASP.NET 實作範例：
詳見表 19。
Java 實作範例：
詳見表 19。
PHP 實作範例：
詳見表 19。

資料來源： 本計畫整理

4.2.3 稽核儲存容量(Audit Storage Capacity)

稽核事件類別之控制措施包含：

●依據稽核紀錄儲存需求，配置稽核紀錄所需之儲存容量。

與稽核儲存容量控制措施相關的應用程式技術面項目，整理如下：

4.2.3.1 依據稽核紀錄儲存需求，配置稽核紀錄所需之儲存容量

本項目實作項目包含以下 1 項：

●依據稽核紀錄儲存需求，配置稽核紀錄所需之儲存容量。

– 相關實作建議，詳見表 22。

本文件之智慧財產權屬數位發展部資通安全署擁有。

表22 稽核儲存容量-實作建議

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	稽核儲存容量	依據稽核紀錄儲存需求，配置稽核紀錄所需之儲存容量。
查核方式：☒自動化工具檢測　☒人工審查				
控制措施： 依據稽核紀錄儲存需求，配置稽核紀錄所需之儲存容量。 **實作指導：** 檢視磁碟剩餘空間和資料庫中稽核紀錄使用空間，評估配置稽核紀錄所需之儲存容量。				

資料來源： 本計畫整理

– 相關程式範例，詳見表 23。

表23 稽核儲存容量-程式範例

ASP.NET+SQL Server 實作範例：

顯示硬碟剩餘空間程式範例如下：

```
protected void Page_Load(object sender, EventArgs e)
{
    //顯示硬碟空間
    Label1.Text = Label1.Text + "==============================" + "<br />";
    Label1.Text = Label1.Text + "<b>磁碟空間</b><br /><br />";

    DriveInfo[] allDrives = DriveInfo.GetDrives();
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
    foreach (DriveInfo d in allDrives)
    {
        Label1.Text = Label1.Text + "---------------------------------------" + "<br />";
        Label1.Text = Label1.Text + "Drive : " + d.Name + "<br />";
        Label1.Text = Label1.Text + "Drive Type : " + d.DriveType + "<br />";
        if (d.IsReady == true)
        {
            Label1.Text = Label1.Text + "Volume label : " + d.VolumeLabel + "<br />";
            Label1.Text = Label1.Text + "File system : " + d.DriveFormat + "<br />";

            Label1.Text = Label1.Text + "Available space : " +
d.AvailableFreeSpace.ToString("###,###,###,###,###.##") + " Bytes <br />";
            Label1.Text = Label1.Text + "Available space : " +
(Decimal.Divide(d.AvailableFreeSpace, 1024)).ToString("###,###,###,###,###.##") + "
KB <br /> ";
            Label1.Text = Label1.Text + "Available space : " +
(Decimal.Divide(d.AvailableFreeSpace, 1024) / 1024).ToString("###,###,###,###,###.##")
+ " MB <br /> ";
            Label1.Text = Label1.Text + "Available space : " +
((double)d.AvailableFreeSpace / 1024 / 1024 / 1024).ToString("###,###,###,###,###.##")
+ " GB <br /> ";
            Label1.Text = Label1.Text + "Available space : " + (d.AvailableFreeSpace /
1024.0 / 1024 / 1024 / 1024).ToString("###,###,###,###,###.##") + " TB <br /> ";

            Label1.Text = Label1.Text + "Total available space : " +
d.TotalFreeSpace.ToString("###,###,###,###,###") + " Bytes<br />";
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
                Label1.Text = Label1.Text + "Total size of drive : " +
d.TotalSize.ToString("###,###,###,###,###") + " Bytes<br />";
            }
        }
        Label1.Text = Label1.Text + "----------------------------------------" + "<br />";
}
```

執行畫面詳見圖 11。

```
==================================
磁碟空間

---------------------------------------
Drive : C:\
Drive Type : Fixed
Volume label :
File system : NTFS
Available space : 66,673,643,520 Bytes
Available space : 65,110,980 KB
Available space : 63,584.94 MB
Available space : 62.09 GB
Available space : .06 TB
Total available space : 66,673,643,520 Bytes
Total size of drive : 106,848,841,728 Bytes
---------------------------------------
Drive : D:\
Drive Type : Fixed
Volume label :
File system : NTFS
Available space : 79,980,646,400 Bytes
Available space : 78,106,100 KB
Available space : 76,275.49 MB
Available space : 74.49 GB
Available space : .07 TB
Total available space : 79,980,646,400 Bytes
Total size of drive : 107,372,081,152 Bytes
---------------------------------------
Drive : O:\
Drive Type : CDRom
---------------------------------------
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

資料來源：本計畫整理

圖11 檢視磁碟空間容量

顯示資料庫中各資料表占用空間之 SQL 敘述語法如下：

```
SELECT
    t.NAME AS TableName,
    s.Name AS SchemaName,
    p.rows AS RowCounts,
    SUM(a.total_pages) * 8 AS TotalSpaceKB,
SUM(a.total_pages)/1024 * 8 AS TotalSpaceMB,
    SUM(a.used_pages) * 8 AS UsedSpaceKB,
    (SUM(a.total_pages) - SUM(a.used_pages)) * 8 AS UnusedSpaceKB
FROM
    sys.tables t
INNER JOIN
    sys.indexes i ON t.OBJECT_ID = i.object_id
INNER JOIN
    sys.partitions p ON i.object_id = p.OBJECT_ID AND i.index_id = p.index_id
INNER JOIN
    sys.allocation_units a ON p.partition_id = a.container_id
LEFT OUTER JOIN
    sys.schemas s ON t.schema_id = s.schema_id
WHERE
    t.NAME NOT LIKE 'dt%'
    AND t.is_ms_shipped = 0
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
    AND i.OBJECT_ID > 255
GROUP BY
    t.Name, s.Name, p.Rows
ORDER BY
    UsedSpaceKB desc ,t.Name
```

執行畫面詳見圖 12。

結果 訊息

	TableName	SchemaName	RowCounts	TotalSpaceKB	TotalSpaceMB	UsedSpaceKB	UnusedSpaceKB
1	Logs	dbo	57486	29896	24	29528	368
2	[redacted]	dbo	8247	7760	0	7728	32
3		dbo	53066	4424	0	4424	0
4		dbo	27941	4232	0	4208	24
5		dbo	4791	3648	0	3584	64
6		dbo	8072	3528	0	3480	48
7		dbo	3817	3304	0	3264	40
8		dbo	8106	2120	0	2104	16
9		dbo	2064	1776	0	1736	40
10		dbo	8113	1672	0	1616	56
11		dbo	2838	1416	0	1400	16
12		dbo	25	1496	0	1392	104
13		dbo	2634	1160	0	1152	8
14		dbo	465	968	0	920	48
15		dbo	971	712	0	664	48
16		dbo	2041	584	0	560	24

資料來源：本計畫整理

圖12 檢視資料庫資料表磁碟空間用量

參考連結：

- sys.objects (Transact-SQL) | Microsoft Docs
  https://docs.microsoft.com/en-us/sql/relational-databases/system-catalog-views/sys-objects-transact-sql

本文件之智慧財產權屬數位發展部資通安全署擁有。

Java 實作範例：

Java 提供 getTotalSpace(), getFreeSpace()和 getUsableSpace()可以取得磁碟空間相關資訊，範例如下：

```
File file = new File("c:");
long totalSpace = file.getTotalSpace(); //total disk space in bytes.
long usableSpace = file.getUsableSpace(); ///unallocated / free disk space in bytes.
long freeSpace = file.getFreeSpace(); //unallocated / free disk space in bytes.


System.out.println(" === Partition Detail ===");
System.out.println(" === bytes ===");
System.out.println("Total size : " + totalSpace + " bytes");
System.out.println("Space free : " + usableSpace + " bytes");
System.out.println("Space free : " + freeSpace + " bytes");
System.out.println(" === mega bytes ===");
System.out.println("Total size : " + totalSpace /1024 /1024 + " mb");
System.out.println("Space free : " + usableSpace /1024 /1024 + " mb");
System.out.println("Space free : " + freeSpace /1024 /1024 + " mb");
```

參考連結：

- File (Java Platform SE 7)
  https://docs.oracle.com/javase/7/docs/api/java/io/File.html#getFreeSpace()

PHP 實作範例：

PHP 提供 disk_free_space()可以檢視磁碟剩餘空間，範例如下：

```
<?php
// $df contains the number of bytes available on "/"
$df = disk_free_space("/");
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
// On Windows:
$df_c = disk_free_space("C:");
$df_d = disk_free_space("D:");
?>
```

參考連結：

- PHP: disk_free_space - Manual
  http://php.net/manual/en/function.disk-free-space.php
- PHP: disk_total_space - Manual
  http://php.net/manual/en/function.disk-total-space.php

資料來源： 本計畫整理

4.2.4 稽核處理失效之回應(Response to Audit Processing Failures)

稽核處理失效之回應類別之控制措施包含以下 2 項：

- 資訊系統應在稽核處理失效(如儲存容量不足)之情況下，採取適當之行動，如關閉資訊系統、覆寫最舊的稽核紀錄或停止產生稽核紀錄等。
- 當機關規定需要即時通報的稽核失效事件發生時，資訊系統應在機關規定之時效內，對機關特定之人員、角色提出告警。

– 相關實作建議，詳見表 24。

表24 稽核處理失效之回應-實作建議

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	稽核處理失效之回應	(1)資訊系統應在稽核處理失效(如儲存容量不足)之情況下，採取適當之行動，例

本文件之智慧財產權屬數位發展部資通安全署擁有。

				如：關閉資訊系統、覆寫最舊的稽核紀錄或停止產生稽核紀錄等。 (2)當機關規定需要即時通報的稽核失效事件發生時，資訊系統應在機關規定之時效內，對機關特定之人員、角色提出告警(適用於高等級)。
查核方式：☒自動化工具檢測　☒人工審查				
控制措施： (1)資訊系統應在稽核處理失效(如儲存容量不足)之情況下，採取適當之行動，例如：關閉資訊系統、覆寫最舊的稽核紀錄或停止產生稽核紀錄等。 (2)當機關規定需要即時通報的稽核失效事件發生時，資訊系統應在機關規定之時效內，對機關特定之人員、角色提出告警。 **實作指導：** (1)系統定時檢查磁碟空間使用情形，低於警戒值時，發出 Email 通知給相關人員。 (2)根據系統提供功能，當稽核處理失效(如儲存容量不足)時，關閉資訊系統、覆寫最舊的稽核紀錄或停止產生稽核紀錄等。				

資料來源： 本計畫整理

– 相關程式範例，詳見表 25。

表25 稽核處理失效之回應-程式範例

ASP.NET 實作範例：
範例如下： try

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
{
    doSomething();     //做某事
    logger.Info(TextBoxAccount.Text + " This is a log message "); //寫入稽核記錄
}
catch (Exception e)
{
    SmtpClient smtp = new SmtpClient();
    smtp.Send("稽核處理失效"); // Email 通知相關人員
}
```

參考連結：

- AU-05 Response To Audit Processing Failures
  http://www.opensecurityarchitecture.org/cms/library/0802control-catalogue/174-08-02-au-05
- Configure Log File Rollover Options (IIS 7)
  https://technet.microsoft.com/en-us/library/cc754615(v=ws.10).aspx
- Managing IIS Log File Storage
  https://docs.microsoft.com/en-us/iis/manage/provisioning-and-managing-iis/managing-iis-log-file-storage
- Audit process tracking
  https://technet.microsoft.com/en-us/library/cc976411.aspx
- Audit process tracking (Windows 10) | Microsoft Docs
  https://docs.microsoft.com/en-us/windows/device-security/auditing/basic-audit-process-tracking
- Audit Policy
  https://technet.microsoft.com/en-us/library/cc766468(v=ws.10).aspx
- Audit Process Termination (Windows 10) | Microsoft Docs

本文件之智慧財產權屬數位發展部資通安全署擁有。

https://docs.microsoft.com/en-us/windows/device-security/auditing/audit-process-termination

- Audit logon events (Windows 10) | Microsoft Docs

https://docs.microsoft.com/en-us/windows/device-security/auditing/basic-audit-logon-events

Java 實作範例：

```
try {
    doSomething();     //做某事
    Logger logger = Logger.getLogger(Log4jDemo.class);
    logger.info("This is a log message");          // 寫入稽核記錄
}
catch (Exception ex) {
    System.out.println("something wrong");
    String MailTo = Property.getString("admin.mail");
    StringBuilder mail_content = new StringBuilder("<html><body>");
    mail_content.append("稽核處理失效：<br>");
    mail_content.append(Property.getMailSignature());
    mail_content.append("</body></html>");
    Mailer mailer = new Mailer();
    mailer.send(MailTo, "稽核處理失效", mail_content.toString());
}
```

參考連結：

- Apache Tomcat 8 (8.5.20) - Logging in Tomcat

https://tomcat.apache.org/tomcat-8.5-doc/logging.html

- Apache Tomcat 7 (7.0.79) - Logging in Tomcat

本文件之智慧財產權屬數位發展部資通安全署擁有。

http://tomcat.apache.org/tomcat-7.0-doc/logging.html#Using_Log4j

PHP 實作範例：

```
try
{
	doSomething();	//做某事
	include('log4php/Logger.php');
	Logger::configure('config.xml');
	$log = Logger::getLogger('myLogger');
	$log->info("This is a log message ");	// 寫入稽核記錄
}
catch (Exception $e)
{
	echo 'Caught exception: ',	$e->getMessage(), "\n";
	$to="admin@demo.com";
	$subject="log error!";
	$message="Something wrong";
	$headers = "From:  寄件人信箱" . "\r\n" .
	mail($to,$subject,$message,$headers);	// Email 通知相關人員
}
```

參考連結：

- Log Files - Apache HTTP Server Version 2.4
  https://httpd.apache.org/docs/2.4/logs.html
- rotatelogs - Piped logging program to rotate Apache logs
  https://httpd.apache.org/docs/2.4/programs/rotatelogs.html

資料來源： 本計畫整理

本文件之智慧財產權屬數位發展部資通安全署擁有。

4.2.5 時戳及校時(Time Stamps)

時戳及校時類別之控制措施包含以下 2 項：

- 資訊系統應使用系統內部時鐘產生稽核紀錄所需時戳及校時，並可以對映到世界協調時間(UTC)或格林威治標準時間(GMT)。
- 系統內部時鐘應具備定期同步機制。

與時戳及校時控制措施相關的應用程式技術面實作建議，詳見表 26。

表26 時戳及校時-實作建議

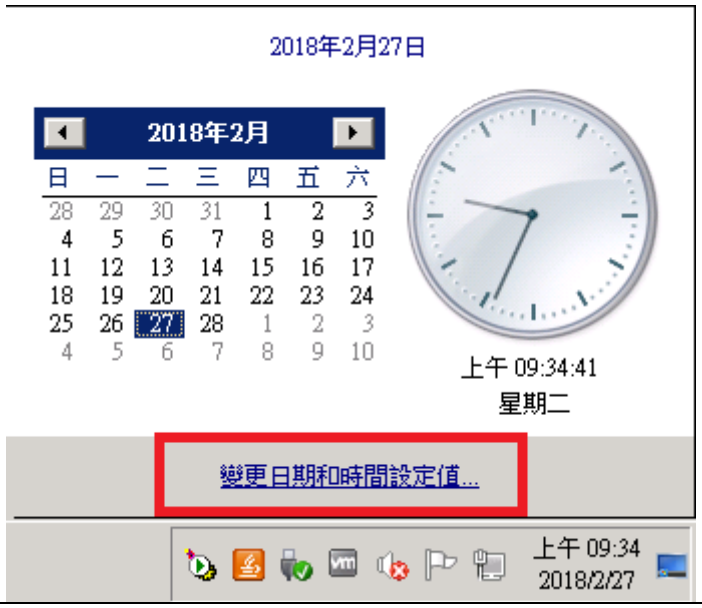
適用分級			類別	實作項目
普	中	高		
◎	◎	◎	時戳及校時	(1)資訊系統應使用系統內部時鐘產生稽核紀錄所需時戳及校時，並可以對映到世界協調時間(UTC)或格林威治標準時間(GMT)。 (2)系統內部時鐘應具備定期同步機制。
查核方式：☒自動化工具檢測　☒人工審查				
控制措施： (1)資訊系統應使用系統內部時鐘產生稽核紀錄所需時戳及校時，並可以對映到世界協調時間(UTC)或格林威治標準時間(GMT)。 (2)系統內部時鐘對基準時間源的時間差大於機關規定之時間週期時應予同步。 **實作指導：** 設定作業系統每日執行定時校時任務。				

本文件之智慧財產權屬數位發展部資通安全署擁有。

資料來源： 本計畫整理

– 相關實作範例，詳見表 27。

表27 時戳及校時-實作範例

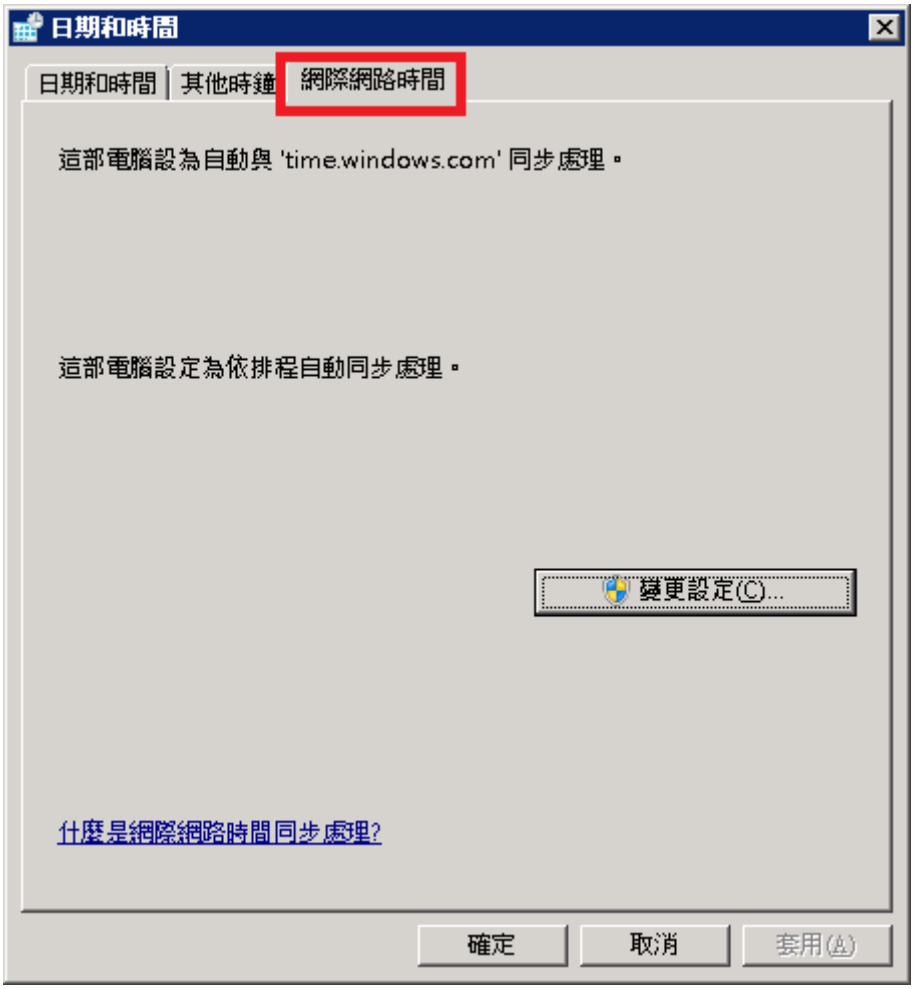
Microsoft Windows 實作範例：
透過 Microsoft Windows Server 內建的校時服務自動校時 在螢幕右下角透過滑鼠雙擊開啟「日期與時間」的內容，畫面詳見圖 13。    資料來源：本計畫整理 圖13 雙擊日期與時間 點擊變更日期和時間設定值，畫面詳見圖 14。 

本文件之智慧財產權屬數位發展部資通安全署擁有。

資料來源：本計畫整理

圖14 變更日期和時間設定值

點擊網際網路時間頁籤，畫面詳見圖 15。

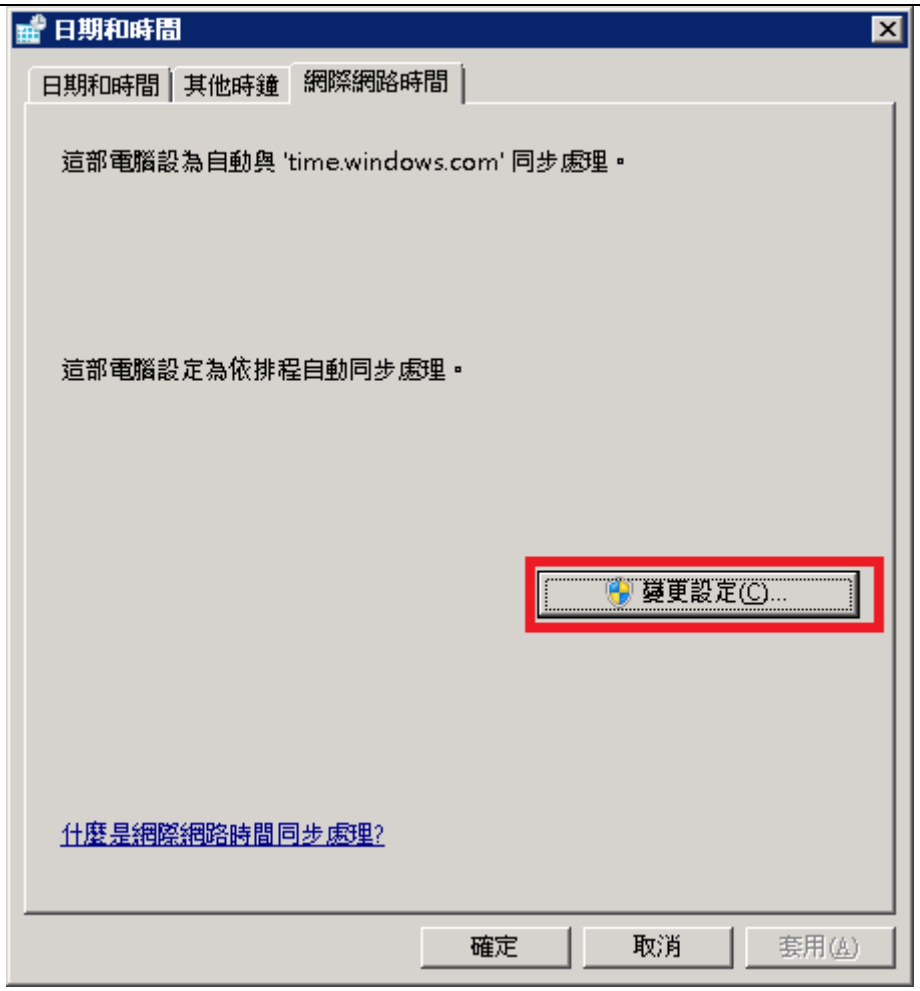


資料來源：本計畫整理

圖15 網際網路時間

點擊變更設定，畫面詳見圖 16。

本文件之智慧財產權屬數位發展部資通安全署擁有。

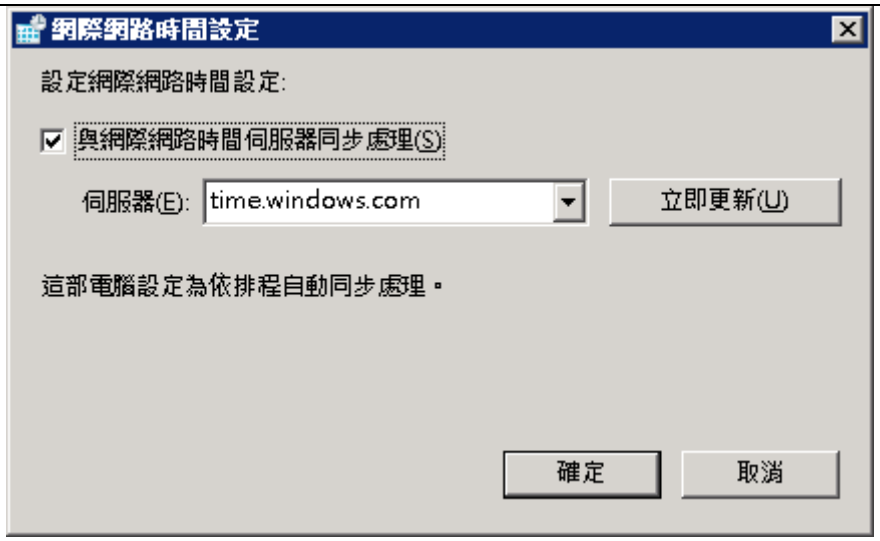


資料來源：本計畫整理

圖16 網際網路時間變更設定

勾選與網際網路時間伺服器同步處理，畫面詳見圖 17。

本文件之智慧財產權屬數位發展部資通安全署擁有。



資料來源：本計畫整理

圖17 與網際網路時間伺服器同步處理

CentOS 實作範例：

執行 vi /etc/crontab 編輯排程設定 (請用 root 權限)

加入一行：

0 23 * * * root /usr/sbin/ntpdate tick.stdtime.gov.tw ; /sbin/hwclock -w

就會設定每天於 23 點 0 分執行 ntpdate 校時，並執行 hwclock 指令更新 BIOS 設定的電腦時間。

參考連結：

- ntpdate - set the date and time via NTP
  http://doc.ntp.org/4.1.1/ntpdate.htm

資料來源： 本計畫整理

4.2.6 稽核資訊之保護(Protection of Audit Information)

稽核資訊之保護類別之控制措施包含以下 3 項：

●對稽核紀錄之存取管理，僅限於有權限之使用者。

本文件之智慧財產權屬數位發展部資通安全署擁有。

●定期備份稽核紀錄到與原稽核系統不同之實體系統 (如 Log 伺服器)。

●運用加密機制，以保護稽核資訊。

與稽核資訊之保護控制措施相關的應用程式技術面項目，整理如下：

4.2.6.1 對稽核紀錄之存取管理，僅限於有權限之使用者

本項目實作項目包含以下 1 項：

●對日誌紀錄進行適當保護及備份，避免未經授權存取。

– 相關實作建議，詳見表 28。

表28 稽核資訊之保護-實作建議 1

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	稽核資訊之保護	對日誌紀錄進行適當保護及備份，避免未經授權存取
查核方式：☒自動化工具檢測　☒人工審查				
控制措施： 系統產生日誌紀錄後，應定時將日誌紀錄進行遠端備份，並將檔案設定存取權限限制，避免未經授權存取。 **實作指導：** 儲存於本地端目錄內的日誌紀錄，可將目錄壓縮後傳送至其他主機進行異地備份。若是日誌紀錄存放於資料庫內，則可以將資料庫進行備份。而若是存放於 syslog server，則應避免 syslog 訊息能從網路網路存取。				

資料來源： 本計畫整理

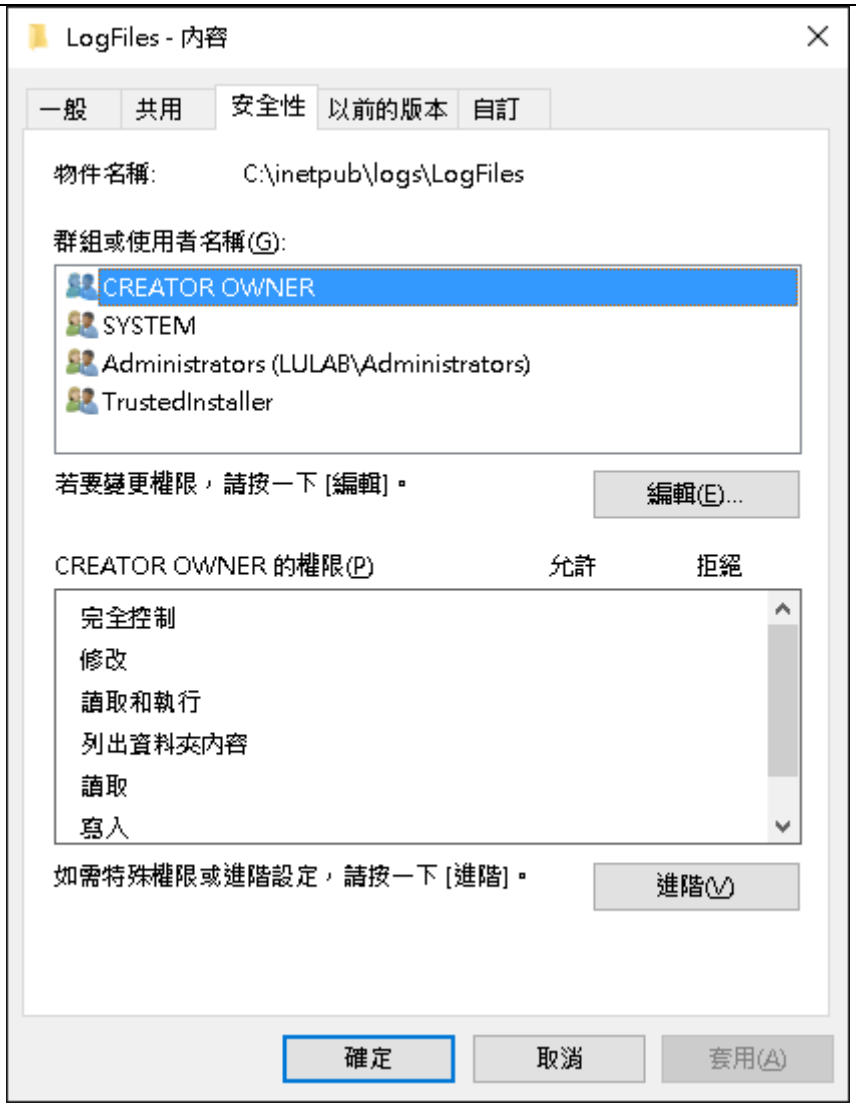
本文件之智慧財產權屬數位發展部資通安全署擁有。

– 相關實作範例，詳見表 29。

表29 稽核資訊之保護-實作範例 1

IIS+SQL Server 實作範例：
Web 應用程式日誌：ASP.NET 網頁應用程式實作之日誌功能，一般會把資料儲存於 SQL Server 資料庫中，所以資料庫備份，就等於把日誌做備份。 參考連結： ▪ 建立完整資料庫備份 (SQL Server) https://docs.microsoft.com/zh-tw/sql/relational-databases/backup-restore/create-a-full-database-backup-sql-server ▪ SQL Server 資料庫的備份與還原 https://docs.microsoft.com/zh-tw/sql/relational-databases/backup-restore/back-up-and-restore-of-sql-server-databases IIS 日誌：在 C:\inetpub\logs\LogFiles 或網站存放 Log 的目錄上按下滑鼠右鍵，選擇「內容」，點選「安全性」頁籤，可以設定 IIS Log 目錄存取權限，避免避免未經授權存取。畫面詳見圖 18。

本文件之智慧財產權屬數位發展部資通安全署擁有。



資料來源：本計畫整理

圖18 設定 IIS Log 目錄存取權限

參考連結：

- Protection of audit information (AU-9) - SecWiki
  http://nist.secwiki.info/index.php?title=Protection_of_audit_information_(AU-9)
- Configure Log File Rollover Options (IIS 7)
  https://technet.microsoft.com/en-us/library/cc754615(v=ws.10).aspx

本文件之智慧財產權屬數位發展部資通安全署擁有。

▪ Managing IIS Log File Storage https://docs.microsoft.com/en-us/iis/manage/provisioning-and-managing-iis/managing-iis-log-file-storage ▪ Windows Server IIS 記錄 https://technet.microsoft.com/zh-TW/library/hh831598.aspx
CentOS 的 Apache Web Server (httpd)實作範例：
在 CentOS7.x，以 yum 安裝的 httpd，access_log 和 error_log 預設存放在/var/log/httpd 目錄中，而網站預設目錄是/var/www/html，故 Web 應用程式預設無法存取到日誌記錄網站，httpd 安裝預設目錄架構對日誌紀錄進行適當保護及備份，避免未經授權存取。 參考連結： ▪ Log Files - Apache HTTP Server Version 2.4 https://httpd.apache.org/docs/2.4/logs.html ▪ mod_log_config - Apache HTTP Server Version 2.4 http://httpd.apache.org/docs/current/mod/mod_log_config.html ▪ Chapter 35. Log Files https://www.centos.org/docs/5/html/Deployment_Guide-en-US/ch-logfiles.html ▪ 21.5. Configuration Directives in httpd.conf https://www.centos.org/docs/5/html/Deployment_Guide-en-US/s1-apache-config.html ▪ Web developers reading /var/log/httpd/error_log - CentOS https://www.centos.org/forums/viewtopic.php?t=15225

資料來源： 本計畫整理

4.2.6.2 定期備份稽核紀錄到與原稽核系統不同之實體系統 (如 Log 伺服器)

本文件之智慧財產權屬數位發展部資通安全署擁有。

相關實作建議，詳見表 30。

表30 稽核資訊之保護-實作建議 2

適用分級			類別	實作項目
普	中	高		
		◎	稽核資訊之保護	定期備份稽核紀錄到與原稽核系統不同之實體系統 (如 Log 伺服器)
查核方式：☐自動化工具檢測　☒人工審查				
控制措施： 系統產生日誌紀錄後，應定時將日誌紀錄進行遠端備份。 **實作指導：** 可建置 syslog server，定期將作業系統或 Web 應用程式的日誌紀錄傳送至 syslog server 進行備份。				

資料來源： 本計畫整理

– 相關程式範例，詳見表 31。

表31 稽核資訊之保護-程式範例 2

C#.NET 實作範例：

▪ 可使用開源函式庫 Rebex Syslog library。程式實作範例如下：
using Rebex.Net;
// create Syslog client object
Syslog client = new Syslog(TransportProtocol.Udp, "localhost", Syslog.DefaultPort);
// initialize Syslog message
SyslogMessage msg = new SyslogMessage();
msg.Facility = FacilityLevel.User;

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
msg.Severity = SeverityLevel.Debug;
msg.Text = "Hello from Syslog client.";
client.Send(msg);    // send message(s)
client.Close();      // close the client
```

參考連結：

- Syslog library for .NET Framework

https://labs.rebex.net/syslog

Java 實作範例：

- 可使用 log4j，設定組態將日誌紀錄傳送至 syslog server。log4j 使用 SyslogAppender 相關函式，讓訊息傳送至遠端的 syslog daemon。Java 程式實作範例如下：

```
log4j.rootLogger=INFO, SYSLOG
log4j.appender.SYSLOG=org.apache.log4j.net.SyslogAppender
log4j.appender.SYSLOG.syslogHost=10.10.10.10
log4j.appender.SYSLOG.layout=org.apache.log4j.PatternLayout
log4j.appender.SYSLOG.layout.conversionPattern=%d{ISO8601} %-5p [%t] %c{2} %x - %m%n
log4j.appender.SYSLOG.Facility=LOCAL1
```

參考連結：

- Class SyslogAppender

https://logging.apache.org/log4j/1.2/apidocs/org/apache/log4j/net/SyslogAppender.html

PHP 實作範例：

- 首先編輯 php.ini，設定使用 syslog

本文件之智慧財產權屬數位發展部資通安全署擁有。

error_log = syslog

▪ 接著設定 syslog-ng.conf

destination php { tcp("10.10.10.10" port(5140)); }; //將紀錄傳送至 10.10.10.10 的 5140 port

log { source(src); filter(f_php); destination(php); };

參考連結：

▪ How To: syslog-ng Server

http://edoceo.com/howto/syslog-ng

資料來源： 本計畫整理

4.2.6.3 運用加密機制，以保護稽核資訊

本項目實作項目包含以下 1 項：

●重要系統資料或紀錄留存雜湊值以確保完整性。

– 相關實作建議，詳見表 32。

表32 稽核資訊之保護-實作建議 3

適用分級			類別	實作項目
普	中	高		
		◎	稽核資訊之保護	重要系統資料或紀錄留存雜湊值以確保完整性
查核方式：☐自動化工具檢測 ☒人工審查				
控制措施： 重要資料或紀錄，以安全雜湊演算法產生並留存其雜湊值，後續可對資料再次產生雜湊值，並與原先結果進行比對，以確保資料未遭到異				

本文件之智慧財產權屬數位發展部資通安全署擁有。

動竄改。

實作指導：

建議開發人員使用開發框架或程式庫原生提供的產生雜湊值的函數或方法，不須開發人員自行依據雜湊演算法撰寫相關程式碼，不僅方便使用且較為安全。

資料來源： 本計畫整理

– 相關程式範例，詳見表 33。

表33 稽核資訊之保護-程式範例 3

ASP.NET 實作範例：

▪ 建立雜湊值範例如下所示：

```
using System;
using System.Security.Cryptography;
using System.Text;


namespace SHA256Sample
{
    class Program
    {
        static void Main(string[] args)
        {
            string source = "Hello World!";
            using (SHA256 sha256Hash = SHA256.Create())
            {
                string hash = Getsha256Hash(sha256Hash, source);
                Console.WriteLine("The SHA256 hash of " + source + " is: " + hash
+ .");
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
            Console.WriteLine("Verifying the hash...");
        if (Verifysha256Hash(sha256Hash, source, hash))
        {
            Console.WriteLine("The hashes are the same.");
        }
        else
        {
            Console.WriteLine("The hashes are not same.");
        }
    }
}
static string Getsha256Hash(SHA256 sha256Hash, string input)
{
    // Convert the input string to a byte array and compute the hash.
    byte[] data = sha256Hash.ComputeHash(Encoding.UTF8.GetBytes(input));
    // Create a new Stringbuilder to collect the bytes
    // and create a string.
    StringBuilder sBuilder = new StringBuilder();
    // Loop through each byte of the hashed data
    // and format each one as a hexadecimal string.
    for (int i = 0; i < data.Length; i++)
    {
        sBuilder.Append(data[i].ToString("x2"));
    }
    // Return the hexadecimal string.
    return sBuilder.ToString();
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
        }.
}
```

參考連結：

- Hash 類別
  https://msdn.microsoft.com/zh-tw/library/system.security.policy.hash(v=vs.110).aspx
- HashAlgorithm.ComputeHash 方法 (Byte[])
  https://msdn.microsoft.com/zh-tw/library/s02tk69a(v=vs.110).aspx

Java 實作範例：

建立檔案雜湊值的實作範例：

```
public byte[] createSha1(File file) throws Exception  {
      MessageDigest digest = MessageDigest.getInstance("SHA-256");
      InputStream fis = new FileInputStream(file);
      int n = 0;
      byte[] buffer = new byte[8192];
      while (n != -1) {
            n = fis.read(buffer);
            if (n > 0) {
                  digest.update(buffer, 0, n);
            }
      }
      return digest.digest();
}
```

參考連結：

- MessageDigest (Java Platform SE 7)
  https://docs.oracle.com/javase/7/docs/api/java/security/MessageDigest.html

本文件之智慧財產權屬數位發展部資通安全署擁有。

PHP 實作範例：

產生 SHA512 雜湊值的實作範例：

```
<?php
echo hash('sha512', 'abc');
?>
```

至於 hash()支援的雜湊演算法種類，可以使用 hash_algos() 來查詢。

參考連結：

- PHP: hash - Manual
  http://php.net/manual/en/function.hash.php
- PHP: Hash - Manual
  http://php.net/manual/en/book.hash.php
- PHP: Hash Functions - Manual
  http://php.net/manual/en/ref.hash.php
- PHP: hash_file - Manual
  http://php.net/manual/en/function.hash-file.php

資料來源： 本計畫整理

4.3 營運持續計畫(Contingency Planning)

營運持續計畫分為「資訊系統備份」以及「資訊系統備援」等 2 項控制措施，說明如下。

4.3.1 資訊系統備份(Information System Backup)

資訊系統備份之控制措施包含以下 5 項：

- 訂定系統可容忍資料損失之時間要求。
- 執行系統源碼與資料備份。

本文件之智慧財產權屬數位發展部資通安全署擁有。

●應定期測試備份資訊來驗證備份媒體之可靠性及資訊之完整性。

●應將備份還原，做為營運持續計畫測試之一部分。

●應在與運作系統不同地點之獨立設施或防火櫃中，儲存重要資訊系統軟體與其他安全相關資訊之備份拷貝。

與資訊系統備份控制措施相關的應用程式技術面項目，整理如下：

4.3.1.1 執行系統源碼與資料備份

本項目實作項目包含以下 1 項：

●重要資料定時同步至備份或備援環境，並加以保護限制存取。

– 相關實作建議，詳見表 34。

表34 資訊系統備份-實作建議

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	資訊系統備份	重要資料定時同步至備份或備援環境，並加以保護限制存取
查核方式：☐自動化工具檢測　☒人工審查				
控制措施： 系統具備重要資料定時備份機制，依組織規範將資料同步至備份或備援環境，以避免系統毀損或資料綁架勒索等對資料可用性之危害。重要資料於備份或備援環境應有保護限制存取措施，以避免增加其他資安風險。 **實作指導：** 可以撰寫一個批次檔(.bat)或執行腳本(.sh)，設定排程定期執行，把資				

本文件之智慧財產權屬數位發展部資通安全署擁有。

料拷貝到備份機或備援機。

資料來源： 本計畫整理

– 相關實作範例，詳見表 35。

表35 資訊系統備份-實作範例

Microsoft Windows 實作範例：
▪ Backup.bat 中，利用 robocopy 把 D:\Data 資料備份到網路磁碟 Z:\Data (另一台備份機或備援機)，內容如下所示： robocopy D:\Data Z:\Data /mir 參考連結： ▪ Robocopy https://technet.microsoft.com/zh-tw/library/cc733145(v=ws.10).aspx ▪ Xcopy https://technet.microsoft.com/zh-tw/library/bb491035.aspx
Linux 實作範例：
Backup.sh 中，利用 tar 指令把 /var/Data/ 資料備份到 /backup/ 目錄 #Backup.sh tar -zcvf /backup/bak_$(date +%Y%m%d).tar.gz /var/Data/ 參考連結： ▪ Linux Man : tar http://linuxcommand.org/lc3_man_pages/tar1.html

資料來源： 本計畫整理

4.3.2 資訊系統備援(Redundancy of Information Systems)

本文件之智慧財產權屬數位發展部資通安全署擁有。

資訊系統備援類別之控制措施包含以下 2 項：

●訂定資訊系統從中斷後至重新恢復服務之可容忍時間要求。

●當原服務中斷，由備援設備取代提供服務。

與資訊系統備援控制措施相關的應用程式技術面項目，整理如下：

4.3.2.1 當原服務中斷，由備援設備取代提供服務

本項目實作項目包含以下 1 項：

●採用「高可用性」(High Availability)架構(分散式或叢集伺服器架構)。

– 相關實作建議，詳見表 36。

表36 資訊系統備援-實作建議

適用分級			類別	實作項目
普	中	高		
		◎	資訊系統備援	採用「高可用性」(High Availability) 架構(分散式或叢集伺服器架構)
查核方式：☐自動化工具檢測 ☒人工審查				
控制措施： 系統之服務水準，經評估後須滿足高可用性需求者，應考量採取分散式或叢集伺服器架構，以使當系統發生錯誤情況或硬體毀損時，服務仍能正常運作。 **實作指導：** 利用作業系統或伺服器本身提供的「高可用性」功能，或是第三方軟體提供的高可用性功能，依需求架設出高可用性的架構。				

本文件之智慧財產權屬數位發展部資通安全署擁有。

資料來源： 本計畫整理

– 相關實作範例，詳見表 37。

表37 資訊系統備援-實作範例

Microsoft Windows Server 實作範例：
Microsoft Windows Server 自 Windows Server 2003 開始提供「網路負載平衡 (Network Load Balancing, NLB)」來增強伺服器應用程式的延展性與可用性。 Windows Server 至少要標準版(Standard)或更高等級才支援 NLB，詳細安裝設定方法，請參考微軟官方連結。 參考連結： ▪ 高可用性 - 維基百科，自由的百科全書 https://zh.wikipedia.org/wiki/%E9%AB%98%E5%8F%AF%E7%94%A8%E6%80%A7 ▪ 網路負載平衡 https://technet.microsoft.com/zh-tw/library/cc770558(v=ws.11).aspx ▪ Network Load Balancing Technical Overview https://msdn.microsoft.com/en-us/library/bb742455.aspx ▪ 網路負載平衡(NLB)：單點傳播(Unicast)與多點傳送(Multicast)的差異 https://technet.microsoft.com/zh-tw/ff359098.aspx

資料來源： 本計畫整理

4.4 識別與鑑別(Identification and Authentication)

識別與鑑別分為「內部使用者之識別與鑑別」、「身分驗證管理」、「鑑別資訊回饋」、「加密模組鑑別」以及「非內部使用者之識別與鑑別」等 5 項控制措施，說明如下。

本文件之智慧財產權屬數位發展部資通安全署擁有。

4.4.1 內部使用者之識別與鑑別(Identification and Authentication for Organizational Users)

內部使用者之識別與鑑別之控制措施包含以下 2 項：

- 資訊系統應具備唯一識別及鑑別機關使用者(或代表機關使用者行為之程序)，不應有共用帳號之行為。
- 對帳號之網路或本機存取採取多重認證技術(如鎖 IP)。

與內部使用者之識別與鑑別控制措施相關的應用程式技術面項目，整理如下：

4.4.1.1 對帳號之網路或本機存取採取多重認證技術(如鎖 IP)

本項目實作項目包含以下 2 項：

- 採用多重因素身分鑑別(兩種以上驗證類型)。
  - 相關實作建議，詳見表 38。

表38 內部使用者之識別與鑑別-實作建議 1

適用分級			類別	實作項目
普	中	高		
		◎	內部使用者之識別與鑑別	採用多重因素身分鑑別(兩種以上驗證類型)
查核方式：☐自動化工具檢測　☒人工審查				
控制措施： 系統身分鑑別或重要交易行為，可採用多重因素身分鑑別以強化安全性。多重因素身分鑑別意指具備兩種以上驗證類型，驗證類型一般區				

本文件之智慧財產權屬數位發展部資通安全署擁有。

分為所知之事(Something you know)、所持之物(Something you have)及所具之形(Something you are)。所知之事類型常採用密碼、特定問題之答案等。所持之物類型常採用令牌(Token)、憑證、簡訊、電子郵件等。所具之形類型常採用生物特徵，如指紋、虹膜辨識等。 **實作指導：** 除了常用的帳號、密碼機制，系統身分鑑別或重要交易行為，可考慮再增加令牌(Token)、憑證、簡訊、電子郵件、生物特徵(指紋、虹膜辨識)等方式。
實作範例：參考實作指導。

資料來源： 本計畫整理

●資訊系統在建立連線前，應識別允許存取之特定來源(如 IP)。

– 相關實作建議，詳見表 39。

表39 內部使用者之識別與鑑別-實作建議 2

適用分級			類別	實作項目
普	中	高		
		◎	內部使用者之識別與鑑別	資訊系統在建立連線前，應識別允許存取之特定來源(如 IP)。
查核方式：☒自動化工具檢測　☒人工審查				
控制措施： 資訊系統在建立連線前，應識別允許存取之特定來源(如 IP)。 **實作指導：** 識別來源 IP，判斷是否允許存取。				

本文件之智慧財產權屬數位發展部資通安全署擁有。

資料來源： 本計畫整理

– 相關程式範例，詳見表 40。

表40 內部使用者之識別與鑑別-程式範例 1

ASP.NET 實作範例：

以下範例可以取得連線本系統之用戶端 IP：
public static string GetClientIP()
{
if (null == HttpContext.Current.Request.ServerVariables["HTTP_VIA"])
{
return HttpContext.Current.Request.ServerVariables["REMOTE_ADDR"];
}
else
{
return HttpContext.Current.Request.ServerVariables["HTTP_X_FORWARDED_FOR"];
}
}
 	
public static string GetClientIPv4()
{
string ipv4 = String.Empty;
foreach (IPAddress ip in Dns.GetHostAddresses(GetClientIP()))
{
if (ip.AddressFamily.ToString() == "InterNetwork")

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
        {
            ipv4 = ip.ToString();
            break;
        }
    }
    if (ipv4 != String.Empty)
    {
        return ipv4;
    }
    //利用 Dns.GetHostEntry 方法，由獲取的 IPv6 位址反查 DNS 紀錄，
    //再逐一判斷何者屬 IPv4 協定，即可轉為 IPv4 位址。
    foreach (IPAddress ip in Dns.GetHostEntry(GetClientIP()).AddressList)
    {
        if (ip.AddressFamily.ToString() == "InterNetwork")
        {
            ipv4 = ip.ToString();
            break;
        }
    }
    return ipv4;
}
```

但是只有 HttpContext.Current.Request.ServerVariables["REMOTE_ADDR"];是比較可靠難以竄改的資訊。

參考連結：

本文件之智慧財產權屬數位發展部資通安全署擁有。

- How to obtain IP address of a client behind proxy via web service
  https://blogs.msdn.microsoft.com/asiatech/2009/08/27/how-to-obtain-ip-address-of-a-client-behind-proxy-via-web-service/
- Dns.GetHostEntry 方法 (IPAddress) (System.Net)
  https://msdn.microsoft.com/zh-tw/library/ms143997(v=vs.110).aspx
- Dns.GetHostEntry 方法 (String) (System.Net)
  https://msdn.microsoft.com/zh-tw/library/ms143998(v=vs.110).aspx

Java 實作範例：

JSP 可用下面方法取得用戶端來源 IP：

```
<%     String ip = request.getHeader("X-Forwarded-For");
            if (ip == null || ip.length() == 0 || "unknown".equalsIgnoreCase(ip)) {
                ip = request.getHeader("Proxy-Client-IP");
            }
            if (ip == null || ip.length() == 0 || "unknown".equalsIgnoreCase(ip)) {
                ip = request.getHeader("WL-Proxy-Client-IP");
            }
            if (ip == null || ip.length() == 0 || "unknown".equalsIgnoreCase(ip)) {
                ip = request.getHeader("HTTP_CLIENT_IP");
            }
            if (ip == null || ip.length() == 0 || "unknown".equalsIgnoreCase(ip)) {
                ip = request.getHeader("HTTP_X_FORWARDED_FOR");
            }
            if (ip == null || ip.length() == 0 || "unknown".equalsIgnoreCase(ip)) {
                ip = request.getRemoteAddr();
            }
%>
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

但是只有 request.getRemoteAddr()是比較可靠難以竄改的資訊。

參考連結：

- HttpServletRequest (Java EE 6)
  http://docs.oracle.com/javaee/6/api/javax/servlet/http/HttpServletRequest.html#getHeaders(java.lang.String)

PHP 實作範例：

PHP 可用以下方法取得使用者 IP：

```
$_SERVER["REMOTE_ADDR"];
```

但使用者若使用代理伺服器上網時，則上面的語法會取得代理伺服器 IP，並非使用者真正的 IP，因此必須先檢查以下兩個變數：

```
$_SERVER["HTTP_CLIENT_IP"];
$_SERVER["HTTP_X_FORWARDED_FOR"];
```

若上述的兩個變數並沒有數值存在，表示使用者並非透過 Proxy Server 上網，可使用『REMOTE_ADDR』直接取得 IP。 完整範例如下：

```
<?php
if (!empty($_SERVER['HTTP_CLIENT_IP']))
{
  $ip=$_SERVER['HTTP_CLIENT_IP'];
}
else if (!empty($_SERVER['HTTP_X_FORWARDED_FOR']))
{
  $ip=$_SERVER['HTTP_X_FORWARDED_FOR'];
}
else
{
  $ip=$_SERVER['REMOTE_ADDR'];
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
}
?>
```

但是只有$_SERVER["REMOTE_ADDR"];是比較可靠難以竄改的資訊。

參考連結：

- PHP: $_SERVER - Manual
  http://php.net/manual/en/reserved.variables.server.php

資料來源： 本計畫整理

4.4.2 身分鑑別管理(Authenticator Management)

身分鑑別管理類別之控制措施包含以下 7 項：

- 使用預設密碼登入系統時，應於登入後要求立即變更。
- 基於密碼之鑑別資訊系統應強制最低密碼複雜度；密碼強制密碼最短及最長之效期限制。
- 使用者更換密碼時，至少不可以與前 3 次使用過之密碼相同。
- 具備帳號鎖定機制，帳號登入進行身分鑑別失敗達 5 次後，至少 15 分鐘內不允許該帳號繼續嘗試登入或使用機關自建之失敗鑑別機制。
- 身分鑑別相關資訊不以明文傳輸。
- 身分鑑別機制應防範自動化程式之登入或密碼更換嘗試，如採用圖形驗證碼(CAPTCHA)機制密碼。
- 密碼重設機制對使用者重新身分確認後，發送一次性及具有時效性令牌(Token)，例如:簡訊驗證碼、EMAIL 驗證連結，檢查傳回令牌有效性後，才允許使用者進行重設密碼動作。

與身分鑑別管理措施相關的應用程式技術面項目，整理如下：

本文件之智慧財產權屬數位發展部資通安全署擁有。

4.4.2.1 基於密碼之鑑別資訊系統應強制最低密碼複雜度；強制密碼最短及最長之效期限制

本項目實作項目包含以下 1 項：

●確實規範使用者密碼強度(密碼長度 12 個字元以上、包含英文大小寫、數字，以及特殊字元)。

– 相關實作建議，詳見表 41。

表41 身分鑑別管理-實作建議 1

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	身分鑑別管理	確實規範使用者密碼強度(密碼長度 12 個字元以上、包含英文大小寫、數字，以及特殊字元)
查核方式：☐自動化工具檢測 ☒人工審查				
控制措施： 若採用密碼作為身分鑑別機制，當使用者設定密碼時，需以正規表示式檢查密碼強度是否符合標準，例如密碼長度 12 個字元以上、包含英文大小寫、數字，以及特殊字元。 **實作指導：** 當系統因功能需求必須取用或儲存使用者所傳入的資料內容時，必須通過統一驗證樣板驗證後才可使用，以避免所傳入的資料對系統造成危害。				

資料來源： 本計畫整理

– 相關程式範例，詳見表 42。

本文件之智慧財產權屬數位發展部資通安全署擁有。

表42 身分鑑別管理-程式範例 1

ASP.NET 實作範例：
ASP.NET Identity 基本上提供了密碼驗證邏輯，在專案的 App_Start 目錄下的 IdentityConfig.cs 檔案中，依據需要修改下列內容： RequiredLength = 12, 密碼長度最少為 12 RequireNonLetterOrDigit = true, 需要有特殊字元 RequireDigit = true, 需要有數字 RequireLowercase = true, 需要有小寫字母 RequireUppercase = true, 需要有大寫字母 參考連結： ▪ Introducing ASP.NET Identity – A membership system for ASP.NET applications http://go.microsoft.com/fwlink/?LinkId=301889
Java 實作範例：
可使用正規表示式驗證密碼複雜度，範例如下： ^.*(?=.{12})(?=.*[a-z])(?=.*[A-Z])(?=.*[0-9]).*$ 細部說明如下： ^ 為開頭定位符號，而$為結尾定位符號 (?=.{12}) 表示長度大於 12 字元 (?=.*[a-z]) 表示英文小寫字元 (?=.*[A-Z]) 表示英文大寫字元 (?=.*[0-9]) 表示數字字元 參考連結： ▪ Lesson: Regular Expressions (The Java Tutorials > Essential Classes) https://docs.oracle.com/javase/tutorial/essential/regex/

本文件之智慧財產權屬數位發展部資通安全署擁有。

▪ Regular Expressions https://docs.oracle.com/cd/E20593_01/doc.560/e23610/app_regexp.htm
PHP 實作範例：

對 PHP 而言，密碼長度 12 個字元以上、包含英文大小寫、數字，以及特殊字元的正規運算式如下：
(?=^.{12,}$)(?=.*\d)(?=.*\W+)(?![.\n])(?=.*[A-Z])(?=.*[a-z]).*$
程式範例：
if (!preg_match('/^(?=^.{12,}$)(?=.*\d)(?=.*\W+)(?![.\n])(?=.*[A-Z])(?=.*[a-z]).*$
/',($_POST['password']))) {
// login failed
}
else
{
// login success
}
參考連結：
▪ PHP: preg_match - Manual
http://php.net/manual/en/function.preg-match.php

資料來源： 本計畫整理

4.4.2.2 使用者更換密碼時，至少不可以與前 3 次使用過之密碼相同

本項目實作項目包含以下 1 項：

●使用者必須定期更換密碼，且至少不可以與前 3 次使用過之密碼相同。

– 相關實作建議，詳見表 43。

本文件之智慧財產權屬數位發展部資通安全署擁有。

表43 身分鑑別管理-實作建議 2

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	身分鑑別管理	使用者必須定期更換密碼，且至少不可以與前 3 次使用過之密碼相同
查核方式：☐自動化工具檢測　☒人工審查				
控制措施： 使用者初次設定或異動密碼時，系統應留存設定密碼之時間，往後每次使用者成功登入後，必須檢查該組密碼是否已使用超過組織政策所規定的最長期限(例如，45 天)，若已超過時限則強制使用者更換密碼，使用者的前 3 次舊密碼應被保留(以雜湊值的形式)，新密碼應比對且不允許與前 3 次使用密碼相同。 **實作指導：** 使用者必須定期更換密碼，且至少不可以與前 3 次使用過之密碼相同。				

資料來源： 本計畫整理

– 相關程式範例，詳見表 44。

表44 身分鑑別管理-程式範例 2

ASP.NET 實作範例：

▪程式範例片段如下：
protected void ButtonSubmit_Click(object sender, EventArgs e)
{
if (IsNotOldPassword(password, times)){
LabelShow.Text = "驗證通過";

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
            //可以再對資料做處理。
        }
    else{
        LabelShow.Text = "密碼不可和前 3 次相同!;
    }
```

參考連結：

- Hash 類別
  https://msdn.microsoft.com/zh-tw/library/system.security.policy.hash(v=vs.110).aspx
- HashAlgorithm.ComputeHash 方法 (Byte[])
  https://msdn.microsoft.com/zh-tw/library/s02tk69a(v=vs.110).aspx

Java 實作範例：

程式範例片段如下：

```
//檢查帳號密碼是否正確
if (checkPW(list, password) ){
if (checkExpiration(list,"45")){
HttpSession s = request.getSession();
s.setAttribute("id", id);
s.setAttribute("list", list);
requestDispatcher = getServletContext().getRequestDispatcher("/Expire.jsp");
requestDispatcher.forward(request,response);
return;
}

private boolean checkExpiration(ArrayList list, String Days){
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
boolean    expire = false;
Iterator i = list.iterator();
if (i.hasNext()){
ArrayList row = (ArrayList)list.get(0);
//取得使用者上次密碼修改時間並與現在系統時間相減，確認是否超過過期時間
Timestamp t1 = new Timestamp(System.currentTimeMillis());
Timestamp t2 = (Timestamp) row.get(3);
if (t2!=null && (t1.getTime() - t2.getTime()) > Integer.parseInt(days) * 24 * 60 * 60 *
1000 ){
expire = true;
}
}
return expire;
}
}
```

參考連結：

- Date (Java Platform SE 7)
  https://docs.oracle.com/javase/7/docs/api/java/util/Date.html#getTime()
- Timestamp (Java Platform SE 7)
  https://docs.oracle.com/javase/7/docs/api/java/sql/Timestamp.html#getTime(
)

PHP 實作範例：

範例如下：

```
if    (isLastFivePassword(password)) {
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
    echo “密碼不可和前面 3 次相同”;
}
else
{
    changePassword(password);
}
```

參考連結：

- PHP: elseif/else if - Manual
  http://php.net/manual/fr/control-structures.elseif.php

資料來源： 本計畫整理

4.4.2.3 具備帳號鎖定機制，帳號登入進行身分鑑別失敗達 5 次後，至少 15 分鐘內不允許該帳號繼續嘗試登入

本項目實作項目包含以下 1 項：

- 具備帳號鎖定機制，帳號登入進行身分鑑別失敗達 5 次後，至少 15 分鐘內不允許該帳號及來源 IP 繼續嘗試登入。

– 相關實作建議，詳見表 45。

表45 身分鑑別管理-實作建議 3

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	身分鑑別管理	具備帳號鎖定機制，帳號登入進行身分鑑別失敗達 5 次後，至少 15 分鐘內不允許該帳號及來源 IP 繼續嘗試登入

本文件之智慧財產權屬數位發展部資通安全署擁有。

查核方式：☐自動化工具檢測　☒人工審查

控制措施：

系統須具備帳號鎖定機制，記錄使用者身分鑑別錯誤次數，若錯誤次數達到組織資安規範之次數(例如，5 次)，則針對該帳號及來源 IP 進行鎖定一段時間(例如，15 分鐘)。

實作指導：

在認證時，需加入錯誤的嘗試次數紀錄與判斷，可減少帳號密碼猜測攻擊成功機會，以提高系統安全性。達鎖定時間後，若使用者再次進行身分鑑別登入嘗試時，應將錯誤次數歸零。除帳號外亦鎖定來源 IP 的用意為防範攻擊多個帳號，使同一來源無法在某個帳號鎖定後，又再行嘗試其他帳號。

資料來源： 本計畫整理

– 相關程式範例，詳見表 46。

表46 身分鑑別管理-程式範例 3

ASP.NET 實作範例：

ASP.NET Identity 提供了密碼驗證邏輯，在專案的 App_Start 目錄下 的 IdentityConfig.cs 檔案中，依據需要修改下面內容：

```
//失敗 5 次，鎖定 15 分鐘
manager.UserLockoutEnabledByDefault =
true;manager.DefaultAccountLockoutTimeSpan =
TimeSpan.FromMinutes(15);manager.MaxFailedAccessAttemptsBeforeLockout = 5;
```

在 Account 目錄下 Login.aspx.cs 檔案中找到下面這行，把 false 改為 true

```
var result = signinManager.PasswordSignIn(Email.Text, Password.Text,
RememberMe.Checked, shouldLockout: false);
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

參考連結：

- Introducing ASP.NET Identity – A membership system for ASP.NET applications

  http://go.microsoft.com/fwlink/?LinkId=301889

Java 實作範例：

```
//取得錯誤次數上限及鎖定時間
ResourceBundle rb = ResourceBundle.getBundle("parameter");
String limit = rb.getString("login.failLimit");
String ip = request.getRemoteAddr();

//取出帳號密碼和 IP
String id = request.getParameter("id");
String password = request.getParameter("password");
String ip = request.getRemoteAddr();

RequestDispatcher requestDispatcher =
getServletContext().getRequestDispatcher("/Login.jsp");

try{
ArrayList list = dbQuery(id);
//使用者是否存在
if (!checkUser(list)){
request.setAttribute("msg","ID 或密碼錯誤");
requestDispatcher.forward(request, response);
return;
}
//使用者是否被鎖定
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
if ( checkLockout(list,id,ip,period)){
request.setAttribute("使用者帳號已鎖定");
requestDispatcher.forward(request, response);
return;
}

//檢查帳號密碼
if (checkPW(list, password)){
if (checkExpiration(list,"1")){
HttpSession s = request.getSession();
s.setAttribute("id",id);
s.setAttribute("list",list);
requestDispatcher = getServletContext().getRequestDispatcher("Expire.jsp");
requestDispatcher.forward(request,response);
return;
}
request.setAttribute("msg","登入成功");
requestDispatcher = getServletContext().getRequestDispatcher("/Main.jsp");
requestDispatcher.forward(request,response);
return;
} else{
request.setAttribute("msg","ID 或密碼錯誤");
updateFailCount(list,id,ip,limit);
requestDispatcher.forward(request,response);
return;
}
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
} catch (Exception e){
e.printStackTrace();
}

private boolean checkLockout(ArrayList list,String id,String ip,String period){
boolean lockout = true;
Iterator i = list.iterator();
if (i.hasNext()){
ArrayList row = (ArrayList)list.get(0);
//取得帳號是否鎖定以及上次登入錯誤時間
Timestamp t1 = new Timestamp(System.currentTimeMillis());
Timestamp t2 = (Timestamp) row.get(9);
int lockStatus = (int) row.get(10);
if (lockStatus != 1){
lockout = false;
}
//若帳號鎖定但已超過鎖定時間則解鎖，並將錯誤次數歸零
else if (t2 != null && (t1.getTime() - t2.getTime() ) > Integer.parseInt(period)*60*1000){
try{
update(id,ip,0,0);
lockout = false;
} catch (Exception e){
e.printStackTrace();
}
}
}
return lockout;
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
}


private void updateFailCount(ArrayList list, String id, String ip, String limit){
Iterator i = list.iterator();
if (i.hasNext()){
//取得已錯誤次數
ArrayList row = (ArrayList)list.get(0);
int failed_count = (int) row.get(8);
try{
//若錯誤次數加 1 達到上限則鎖定，否則次數增加 1
if (failed_count +1 >= Integer.parseInt(limit)){
update(id,ip,failed_count+1,1);
} else{
update(id,ip,failed_count+1,0);
}
} catch (Exception e){
e.printStackTrace();
}
}
}
```

參考連結：

- ResourceBundle (Java Platform SE 7)
  https://docs.oracle.com/javase/7/docs/api/java/util/ResourceBundle.html

PHP 實作範例：

可以自行撰寫一個 config.inc.php 檔案，設定 Session 的啟用：

```
$duration = (5 * 60);
if(isset($_SESSION['started'])){
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
    $time = ($duration - (time() - $_SESSION['started']));
    if($time <= 0){
        session_unset();
        session_destroy();
    }
}
else{
  $_SESSION['started'] = time();
}
```

在其他檔案，把 config.inc.php 含入，例如 login.php：

```
<?php include "config.inc.php"; ?>
    <?php
    if(!empty($_SESSION['LoggedIn']) && !empty($_SESSION['Username']))
        {
            echo "<p>Thanks for logging in <b>".$_SESSION['FName']."
".$_SESSION['SName']."</b>.</p>";
            echo "<a href='Logout.php'><input name='logoutBtn' type='submit'
value='Logout'/></a>";
            #set failed_login_attempts = 0
            $set_failed_login_attempts=mysql_query("UPDATE login SET
failed_login_attempts=0 WHERE LoginID=".$_SESSION['LoginID']);
        }
        elseif(!empty($_POST['username']) && !empty($_POST['password']))
        {
            $userID = mysql_real_escape_string($_POST['username']);
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
            $password = md5(mysql_real_escape_string($_POST['password']));
            $checkloginEmp = mysql_query("SELECT * FROM UserDetails WHERE
UserID = '".$userID."' AND Password = '".$password."'") or die(mysql_error());
if(mysql_num_rows($checkloginEmp) == 1)
        {
            // Check if they're locked out
            $checkLockout = mysql_query("SELECT * FROM login
                                                WHERE LoginID = $userID
                                                AND failed_login_attempts >= 3
                                                AND last_failed_login >
DATE_SUB(NOW(), INTERVAL 10 MINUTE)" or die (mysql_error());
            if (mysql_num_rows($checkLockout) > 0) {
                echo "Locked out!";
            } else {
                $row = mysql_fetch_array($checkloginEmp);
                $_SESSION['Username'] = $userID;
                $_SESSION['FName'] = $row['FName'];
                $_SESSION['SName'] = $row['SName'];
                $_SESSION['LoggedIn'] = 1;
            }
            echo "<meta http-equiv='refresh' content='1;Login2.php'/>";
        }
            else
            {
                if (isset($_SESSION['LoggedAttempts'])){
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
                $_SESSION['LoggedAttempts']++;
            }
            else{
                $_SESSION['LoggedAttempts'] = 0;
            }

            $login = mysql_query("SELECT failed_login_attempts, last_failed_login
FROM login WHERE LoginID ='".$_SESSION['LoginID']."')or die(mysql_error());

            if(mysql_num_rows($login) == 0){
                #create failed_login_attempts = failed_login_attempts + 1 AND
last_failed_login = NOW()
                $failed_login_attempts=mysql_query("INSERT INTO login
VALUES ('".$_SESSION['LoggedAttempts']."',NOW())");
            }

            else{
                $row = mysql_fetch_array($login);
                $_SESSION['LoginID'] = $row['LoginID'];
                $update_failed_login_attempts=mysql_query("UPDATE login SET
failed_login_attempts='".$_SESSION['LoggedAttempts']."',
                last_failed_login = NOW() WHERE LoginID
='".$_SESSION['LoginID']."') or die(mysql_error());
            }
        }
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
                $login_attempts_remaining=2 - $_SESSION['LoggedAttempts'];


                if ($login_attempts_remaining<=0){
                    echo 'Locked out!';
                    //going to add code here after to check if they were locked out for more than 10 minutes then to set failed login attempts back to zero
                }
                else{

                echo "Login Details Incorrect<p></p><p></p>";
                echo "<p>Please contact with WebSite Administrator</p>
                    <p>You have ". $login_attempts_remaining ." login attempts remaining. </p>
                    <p> <form action='Login2.php' method='POST'>
                        <input type='submit' name='login' id='login' value='Try again'/>
                    </form>
                    </p>";
                }
            }
            //}

        else{
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
        ?>
        <div id="mainText" style="width:400px;text-align:center;float:left" class="post">
            <form method="post" action="Login2.php" name="loginform"
id="loginform">
                <fieldset>
                    <label for="username">Username:</label>
                        <input type="text" name="username"
id="username"/><br/><br/>
                    <label for="password">Password:</label>
                        <input type="password" name="password"
id="password"/><br/><br/>
                    <input type="submit" name="login" id="login" value="Login"/>
                </fieldset>
            </form>
        </div>
        <?php
        }
        ?>
```

參考連結：

- PHP lockout user after 3 failed log ins for 10 minutes
  https://stackoverflow.com/questions/16509643/php-lockout-user-after-3-failed-log-ins-for-10-minutes
- PHP Login Failed Attempt Lockout
  http://board.phpbuilder.com/showthread.php?10368340-PHP-Login-Failed-Attempt-Lockout

本文件之智慧財產權屬數位發展部資通安全署擁有。

資料來源： 本計畫整理

4.4.2.4 身分鑑別相關資訊不以明文傳輸

本項目實作項目包含以下 1 項：

●身分鑑別相關資訊不以明文傳輸。

– 相關實作建議，詳見表 47。

表47 身分鑑別管理-實作建議 4

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	身分鑑別管理	身分鑑別相關資訊不以明文傳輸
查核方式：☐自動化工具檢測 ☒人工審查				
控制措施： 系統傳遞身分鑑別相關資訊(例如帳號密碼)時，採用加密傳輸，以避免該資訊被攔截或監聽竊取。 **實作指導：** 網站可採用 HTTPS 方式傳輸帳號密碼資訊。				
IIS+HTTPS 實作範例：				
IIS 設定支援 HTTPS 後，使用 HTTPS 連線，身分鑑別相關資訊將不以明文傳輸，安裝設定步驟詳見 4.6.1 節。				
Java 實作範例：				
詳見 4.6.1 節。				

本文件之智慧財產權屬數位發展部資通安全署擁有。

PHP 實作範例：
詳見 4.6.1 節。

資料來源： 本計畫整理

4.4.2.5 身分鑑別機制應防範自動化程式之登入或密碼更換嘗試，如採用圖形驗證碼(CAPTCHA)機制密碼

本項目實作項目包含以下 1 項：

- 採用圖形驗證碼(CAPTCHA)機制於身分鑑別及重要交易行為，以防範自動化程式之嘗試。

  – 相關實作建議，詳見表 48。

表48 身分鑑別管理-實作建議 5

適用分級			類別	實作項目
普	中	高		
	◎	◎	身分鑑別管理	採用圖形驗證碼(CAPTCHA)機制於身分鑑別及重要交易行為，以防範自動化程式之嘗試
查核方式：☐自動化工具檢測 ☒人工審查				
控制措施： 系統若採用帳號密碼進行身分鑑別，可能遭受到自動化程式以暴力破解方式嘗試登入。另外，系統重要行為若被獲知相關執行參數，亦可能被自動化程式嘗試偽冒合法使用者觸發。因此，採用圖形方式顯示一驗證碼於頁面上，並要求使用者辨別該圖形中文字之方式，或以其他足以辨識人為動作之方式(例如勾選特定選項)，將可以防堵自動化程				

本文件之智慧財產權屬數位發展部資通安全署擁有。

式之嘗試行為。

實作指導：

如適用，建議使用開發工具或程式庫本身提供的元件或函示庫，或是採用已廣被大眾使用之第三方元件，不僅使用上較為方便且安全性也較高，例如：Google reCAPTCHA。若有必要自行開發圖形驗證碼(CAPTCHA)，必須注意是否過於簡單，避免被某些具備 OCR(光學辨識)功能之駭客工具破解。

資料來源： 本計畫整理

– 相關程式範例，詳見表 49。

表49 身分鑑別管理-程式範例 5

ASP.NET 實作範例：
▪ Google 有推出 reCAPTCHA，可以免費使用，詳細用法請參考官方說明。 首先必須先註冊並取得 reCAPTCHA，並且設定可以使用的網址或 IP。 註冊網址為：https://www.google.com/recaptcha/intro/index.html ▪ 至下列網址下載 GoogleReCaptcha_Binary.zip 檔案，把 GoogleReCaptcha.dll 放到 Web 專案的 bin 目錄內。 Google ReCaptcha 2.0 - ASP.net Control http://www.codeproject.com/Tips/884193/Google-ReCaptcha-ASP-net-Control ▪ 前端.aspx 檔案增加 <%@ Register TagPrefix=“Recaptcha” Namespace=“GoogleReCaptcha” Assembly="GoogleReCaptcha" %> 和 <recaptcha:googlerecaptcha ID=“ctrlGoogleReCaptcha” runat=“server” PublicKey=“Your_Site_Key” PrivateKey=“Secret_key” />

本文件之智慧財產權屬數位發展部資通安全署擁有。

▪ 後端.aspx.cs 檔案增加

```
if (!ctrlGoogleReCaptcha.Validate())
{
    FailureText.Text = "reCAPTCHA「我不是機器人」驗證失敗，請再次勾選進行驗證!!";
    ErrorMessage.Visible = true;
    return;
}
```

注意，使用 Google ReCAPTCHA 的網站必須可以連線至 Google ReCAPTCHA 相關網站才可使用。

參考連結：

- 驗證碼 - 維基百科，自由的百科全書
  https://zh.wikipedia.org/wiki/%E9%AA%8C%E8%AF%81%E7%A0%81
- Google reCAPTCHA
  https://www.google.com/recaptcha/intro/index.html
- Google reCAPTCHA Auto Render
  https://developers.google.com/recaptcha/docs/display#auto_render
- Google reCAPTCHA API Request
  https://developers.google.com/recaptcha/docs/verify#api-request
- Google ReCaptcha 2.0 - ASP.net Control
  https://www.codeproject.com/Tips/884193/Google-ReCaptcha-ASP-net-Control
- How to Validate Recaptcha V2 Server side
  https://www.codeproject.com/Tips/851004/How-to-Validate-Recaptcha-V-Server-side

Java 實作範例：

本文件之智慧財產權屬數位發展部資通安全署擁有。

reCAPTCHA.jsp 程式範例如下：

```
<html xmlns="http://www.w3.org/1999/xhtml">
<head>
<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
<title>example</title>
<link rel="stylesheet" type="text/css" href="./css/main.css" media="screen" />
<link rel="stylesheet" type="text/css" href="./css/print.css" media="print" />
<script src="https://www.google.com/recaptcha/api.js" async defer></script>
</head>
<body>
<form action="TestCaptcha" method="post">
<input type="text" name="id" value="test@example.com" size="20" /><br><br>
<input type="password" name="password" value="changeit" size="20" /><br><br>
<input type="submit" name="submit" value="submit"><br><br>
<div class="g-recaptcha data-sitekey="[Your Site Key]"></div>
</form>
</body>
</html>
```

reCAPTCHA.java 程式範例如下：

```
protected void doPost(HttpServletRequest request,HttpServletResponse response) throws
ServletException, IOException {
String id = request.getParameter("id");
String password = request.getParameter("password");
//取出 reCAPTCHA 傳送過來的參數
String gr = request.getParameter("g-recaptcha-response");
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
//設定驗證網址,編碼
String url = "https://www.google.com/recaptcha/api/siteverify";
String charset = "UTF-8";
//申請時取得的 KEY
String secret ="[YOUR SECRET KEY]";
String out = "secret="+secret+"&"+"response="+gr;
URLConnection con = new URL(url).openConnection();
con.setDoOutput(true);
con.setRequestProperty("Accept-Charset",charset);
con.setRequestProperty("Content-Type","application/x-www-form-urlencoded;charset=" +
charset);
//連線 google 驗證網址進行驗證
try(OutputStream output = con.getOutputStream();){
output.write(out.getBytes(charset));
}catch(Exception e){
e.printStackTrace();
}
//接收回應訊息，判別驗證結果
try (InputStream is = con.getInputStream(); JsonReader rdr = Json.createReader(is)) {
  JsonObject o = rdr.readObject();
  System.out.println(""+o.getBoolean("success"));
  System.out.println(""+o.getJsonArray("error-codes"));


}catch (Exception e){
e.printStackTrace();
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
}
}
```

參考連結：

- ServletRequest (Java EE 6)
  http://docs.oracle.com/javaee/6/api/javax/servlet/ServletRequest.html#getParameter(java.lang.String)
- ServletRequest (Servlet API Documentation)
  https://docs.oracle.com/cd/E17802_01/products/products/servlet/2.5/docs/servlet-2_5-mr2/javax/servlet/ServletRequest.html#getParameter(java.lang.String)

PHP 實作範例：

顯示 CAPTCHA 的網頁內容，範例如下：

```
<?php
$pageToGo = "http://example.com/" #the page to go to if captcha correct
if ($_POST["captchaused"] == "true")
{
if ($_POST["numcaptcha"] == $_POST["captcha"])
{
header('Location: ' . $pageToGo);
}
else
{
echo '<form action="' . $_SERVER['php_self'] . '" method="post">';
$text = mt_rand();
echo '<input type="hidden" name="captchaused" value="true" />';
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
echo '<input type="hidden" name="numcaptcha" value="' . $text . '" />';
echo 'Enter the numbers you see: <br><input type="text" name="captcha" />';
require_once('numcaptcha.php');
echo '<input type="submit" value="enter site" /></form>';
}
?>
```

numcaptcha.php 內容

```
<?php
header('Content-type: image/png');
$im = imagecreatetruecolor(400, 30);
$white = imagecolorallocate($im, 255, 255, 255);
$grey = imagecolorallocate($im, 128, 128, 128);
$black = imagecolorallocate($im, 0, 0, 0);
imagefilledrectangle($im, 0, 0, 399, 29, $white);
imagettftext($im, 20, 0, 11, 21, $grey, $font, $text);
imagettftext($im, 20, 0, 10, 20, $black, $font, $text);
imagepng($im);
imagedestroy($im);
?>
```

參考連結：

- PHP: imagettftext - Manual
  http://php.net/manual/en/function.imagettftext.php

資料來源： 本計畫整理

本文件之智慧財產權屬數位發展部資通安全署擁有。

4.4.2.6 密碼重設機制對使用者重新身分確認後，發送一次性及具有時效性令牌(Token)，例如:簡訊驗證碼、EMAIL 驗證連結，檢查傳回令牌有效性後，才允許使用者進行重設密碼動作

本項目實作項目包含以下 1 項：

●密碼重設機制對使用者重新身分確認後，發送一次性及具有時效性令牌(Token)，檢查傳回令牌有效性後，才允許使用者進行重設密碼動作。

– 相關實作建議，詳見表 50。

表50 身分鑑別管理-實作建議 6

適用分級			類別	實作項目
普	中	高		
	◎	◎	身分鑑別管理	密碼重設機制對使用者重新身分確認後，發送一次性及具有時效性令牌(Token)，檢查傳回令牌有效性後，才允許使用者進行重設密碼動作
查核方式：☐自動化工具檢測 ☒人工審查				
控制措施： 密碼重設機制設計不良可能造成安全問題。常見錯誤是系統主動將密碼重新設定後寄送給使用者。使用者忘記密碼並啟動密碼重設機制時，應以使用者其他留存於系統的聯絡資訊，例如電子郵件或手機號碼，先要求使用者輸入該資訊，比對正確無誤後，發送一次性及具有時效性令牌(Token)，一般是亂數產生的英數字，使用者接收後須於時效內進行輸入回傳動作，系統檢查回傳令牌有效性後，允許使用者重設密碼。 **實作指導：**				

本文件之智慧財產權屬數位發展部資通安全署擁有。

當使用者忘記密碼時，系統需要求使用者輸入相關資訊，以便確認身分，發送一次性及具有時效性令牌(Token) ，使用者接收後須於時效內進行輸入回傳動作，系統檢查回傳令牌有效性後，允許使用者重設密碼。

資料來源： 本計畫整理

– 相關程式範例，詳見表 51。

表51 身分鑑別管理-程式範例 6

ASP.NET 實作範例：

微軟官方提供的 ASP.NET Identify 身分鑑別機制，本身有忘記密碼功能，可以寄發 Email 通知信給忘記密碼的使用者，程式範例如下：
protected void Forgot(object sender, EventArgs e)
{
if (IsValid)
{
// 驗證使用者的電子郵件地址
var manager = Context.GetOwinContext().GetUserManager<ApplicationUserManager>();
ApplicationUser user = manager.FindByName(Email.Text);
if (user == null || !manager.IsEmailConfirmed(user.Id))
{
FailureText.Text = "使用者不存在或未確認。";
ErrorMessage.Visible = true;
return;
}
// 如需如何進行帳號確認及密碼重設的詳細資訊

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
            //，請前往 https://go.microsoft.com/fwlink/?LinkID=320771
            // 傳送包含驗證碼的電子郵件並重新導向至重設密碼頁面
            string code = manager.GeneratePasswordResetToken(user.Id);
            string callbackUrl = IdentityHelper.GetResetPasswordRedirectUrl(code,
Request);
            manager.SendEmail(user.Id, "重設密碼", "請按 <a href=\"" + callbackUrl + "\">
這裏</a> 重設密碼.");
            loginForm.Visible = false;
            DisplayEmail.Visible = true;
        }
}
```

參考連結：

- Account Confirmation and Password Recovery with ASP.NET Identity (C#)
  https://docs.microsoft.com/en-us/aspnet/identity/overview/features-api/account-confirmation-and-password-recovery-with-aspnet-identity

Java 實作範例：

驗證使用者並產生 Token 程式碼：

```
public class GenToken extends HttpServlet{
protected void doGet(HttpServletRequest request,HttpServletResponse response) throws
ServletException,IOException {
   doPost(request,response);
}

protected void doPost(HttpServletRequest request,HttpServletResponse response) throws
ServletException,IOException {
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
    String account = request.getParameter("account");
    String email = request.getParameter("email");
    try{
        //產生亂數 Token 以及生成的時間戳記
        String token = UUID.randomUUID().toString();
        Timestamp t = new Timestamp(System.currentTimeMillis());
        //確認帳號存在且輸入的 Email 相符後才寄送密碼重設信
        if (userIsExist(account,email)){
            setToken(account,email,token,t);
            PrintWriter out = response.getWriter();
            out.println("<a href='CheckToken?token=" + token + "'>reset link</a>");
        }
    } catch (Exception e) {
        e.printStackTrace();
    }
}
}
```

檢查使用者回傳的 Token 是否合法。

```
protected void doGet(HttpServletRequest request, HttpServletResponse response) throws
ServletException,IOException{
    doPost(request,response);
}

protected void doPost(HttpServletRequest request,HttpServletResponse response) throws
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
ServletException,IOException{
   String token = request.getParameter("token");
   RequestDispatcher requestDispatcher =
getServletContext().getRequestDispatcher("/Error.jsp");
   try{
   //查詢 token 是否存在於資料庫內
   ArrayList list = doQuery(token);
   Iterator i = list.iterator();
   if (i.hasNext()){
      //抓取當前系統時間以及 Token 的產生時間
      ArrayList row = (ArrayList) list.get(0);
      Timestamp t1 = new Timestamp(System.currentTimeMillis());
      Timestamp t2 = (Timestamp) row.get(12);
   }
   //若 token 時間已超過 3 小時則失效
   if (t2 != null && (t1.getTime() - t2.getTime()) < 3*60*60*1000){
      HttpSession s = request.getSession();
      s.setAttribute("id", row.get(0));
      s.setAttribute("token", token);
      requestDispatcher = getServletContext().getRequestDispatcher("/Reset.jsp");
      requestDispatcher.forward(request,response);
   } else {
      requestDispatcher.forward(request,response);
   }
} catch (Exception e){
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
e.printStackTrace();
}
}
```

參考連結：

- UUID (Java Platform SE 7)
  https://docs.oracle.com/javase/7/docs/api/java/util/UUID.html#randomUUID()
- Uses of Class java.util.UUID (Java Platform SE 7)
  https://docs.oracle.com/javase/7/docs/api/java/util/class-use/UUID.html

PHP 實作範例：

範例如下：

```
<?php
function forgot()
{
    if (IsValid)
    {
        //驗證使用者的電子郵件地址
        var manager = new ApplicationUserManager();
        ApplicationUser user = manager->FindByName(email);
        if (user == null || !manager->IsEmailConfirmed(user->Id))
        {
            echo "使用者不存在或未確認。";
            return;
        }
        var code = manager->GeneratePasswordResetToken(user->Id);
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
            var callbackUrl = IdentityHelper->GetResetPasswordRedirectUrl(code, Request);
            manager->SendEmail(user->Id, "重設密碼", "請按 <a href=\"" + callbackUrl +
"\">這裏</a> 重設密碼.");
        }
}
?>
```

參考連結：

- Forgot Password Recovery in Login System with PHP and MySQL
  https://www.codexworld.com/login-system-forgot-password-recovery-email-php-mysql/
- Send Forgotten Password By Mail Using PHP And MySql
  http://codingcyber.com/send-forgotten-password-by-mail-using-php-and-mysql-35/
- PHP Forgot Password Recover Code
  http://phppot.com/php/php-forgot-password-recover-code/
- How to create forget password recovery procedure in PHP
  http://www.phpgang.com/how-to-create-forget-password-form-in-php_381.html
- Reset Password System
  http://www.dreamincode.net/forums/topic/370692-reset-password-system/

資料來源： 本計畫整理

4.4.3 鑑別資訊回饋(Authenticator Feedback)

鑑別資訊回饋類別之控制措施包含：

- 資訊系統應遮蔽在鑑別過程中之資訊(如密碼)，以防止未授權之使用者可能之窺探/使用。

本文件之智慧財產權屬數位發展部資通安全署擁有。

與鑑別資訊回饋控制措施相關的應用程式技術面項目，整理如下：

4.4.3.1 資訊系統應遮蔽在鑑別過程中之資訊(如密碼)，以防止未授權之使用者可能之窺探/使用

本項目實作項目包含以下 1 項：

- 資訊系統應遮蔽在鑑別過程中之資訊(如密碼)，以防止未授權之使用者可能之窺探/使用。

– 相關實作建議，詳見表 52。

表52 鑑別資訊回饋-實作建議

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	鑑別資訊回饋	資訊系統應遮蔽在鑑別過程中之資訊(如密碼)，以防止未授權之使用者可能之窺探/使用
查核方式：☐自動化工具檢測　☒人工審查				
控制措施： 資訊系統應遮蔽在鑑別過程中之資訊(如密碼)，以防止未授權之使用者可能之窺探/使用。 **實作指導：** 設定使用者在輸入密碼欄位輸入密碼時，不顯示內容。				

資料來源： 本計畫整理

– 相關程式範例，詳見表 52。

本文件之智慧財產權屬數位發展部資通安全署擁有。

表53 鑑別資訊回饋-程式範例

ASP.NET 實作範例：
於密碼的輸入欄位，增加屬性 TextMode="Password"即可，例如： <asp:TextBox ID="TextBox1" TextMode="Password" runat="server"></asp:TextBox> 參考連結： ▪ TextBox 類別 https://msdn.microsoft.com/zh-tw/library/system.web.ui.webcontrols.textbox(v=vs.110).aspx
Java 實作範例：
Java 提供 JPasswordField 可以建立輸入密碼的欄位，範例如下： passwordField = new JPasswordField(10); 參考連結： ▪ How to Use Password Fields https://docs.oracle.com/javase/tutorial/uiswing/components/passwordfield.html
PHP 實作範例：
根據 HTML 語法，在 input 元件中設定 type=password，就會以星號顯示輸入內容，不會顯示實際資料。 <input type="password" name="psw"> 參考連結： ▪ HTML Input Types https://www.w3schools.com/html/html_form_input_types.asp

資料來源： 本計畫整理

4.4.4 加密模組鑑別(Cryptographic Module Authentication)

本文件之智慧財產權屬數位發展部資通安全署擁有。

加密模組鑑別類別之控制措施包含：

●資訊系統若以密碼進行鑑別時，該密碼應加密或經雜湊處理後儲存。

加密模組鑑別控制措施相關的應用程式技術面項目，整理如下：

4.4.4.1 資訊系統若以密碼進行鑑別時，該密碼應加密或經雜湊處理後儲存

本項目實作項目包含以下 1 項：

●密碼添加亂數(Salt)進行雜湊函式(HASH Function)處理後，分別儲存亂數及雜湊後密碼。

– 相關實作建議，詳見表 54。

表54 加密模組鑑別-實作建議

適用分級			類別	實作項目
普	中	高		
	◎	◎	加密模組鑑別	密碼添加亂數(Salt)進行雜湊函式(HASH Function)處理後，分別儲存亂數及雜湊後密碼
查核方式：☐自動化工具檢測　☒人工審查				
控制措施： 系統儲存使用者密碼時，不宜儲存明文密碼，以避免遭到有心人士竊取。使用者設定密碼時，應針對該使用者產生一個亂數值，將使用者密碼結合亂數值，再以雜湊函式(HASH Function)處理產生雜湊值後，分別於不同欄位儲存使用者亂數值及雜湊值。後續使用者輸入密碼時，以輸入值添加當初設定密碼時產生的亂數，再次以雜湊函式處理，若產出結果同當初設定密碼時的雜湊值，則表示輸入密碼正確。 **實作指導：**				

本文件之智慧財產權屬數位發展部資通安全署擁有。

假設密碼為 123，經過 SHA1 雜湊處理後的結果為 40bd001563085fc35165329ea1ff5c5ecbdbbeef，事實上駭客可透過暴力嘗試的方式將所有可能的密碼以 SHA1 演算法都計算過一遍，進而猜出原本的密碼為 123，如此一來就失去將密碼進行雜湊運算的保護目的。 Salt 字面上的意思是加點鹽巴，也就是將原本的密碼，加上一個 Salt 值，讓密碼與這個 Salt 一起進行雜湊運算，如此一來，駭客想透過暴力破解的方式猜出雜湊過的字串原本的密碼為何，將會變得非常困難。 SHA1 雜湊演算法安全性已不足夠，應使用強度更高的 SHA-256 以上之演算法對資料進行雜湊運算，在各程式語言中也都有相對應的類別可提供類似的運算。

資料來源： 本計畫整理

– 相關程式範例，詳見表 55。

表55 加密模組鑑別-程式範例

ASP.NET 實作範例：

using System;
using System.IO;
using System.Text;
using System.Security.Cryptography;
 	
public class rfc2898test
{
// Generate a key k1 with password pwd1 and salt salt1.
// Generate a key k2 with password pwd1 and salt salt1.
// Encrypt data1 with key k1 using symmetric encryption, creating edata1.
// Decrypt edata1 with key k2 using symmetric decryption, creating data2.
// data2 should equal data1.

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
    private const string usageText = "Usage: RFC2898 <password>\nYou must
specify the password for encryption.\n";
    public static void Main(string[] passwordargs)
    {
        //If no file name is specified, write usage text.
        if (passwordargs.Length == 0)
        {
            Console.WriteLine(usageText);
        }
        else
        {
            string pwd1 = passwordargs[0];
            // Create a byte array to hold the random value.
            byte[] salt1 = new byte[8];
            using (RNGCryptoServiceProvider rngCsp = new
RNGCryptoServiceProvider())
            {
                // Fill the array with a random value.
                rngCsp.GetBytes(salt1);
            }

            //data1 can be a string or contents of a file.
            string data1 = "Some test data";
            //The default iteration count is 1000 so the two methods use the
same iteration count.
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
            int myIterations = 1000;
            try
            {
                Rfc2898DeriveBytes k1 = new Rfc2898DeriveBytes(pwd1, salt1,
myIterations);
                Rfc2898DeriveBytes k2 = new Rfc2898DeriveBytes(pwd1, salt1);
                // Encrypt the data.
                TripleDES encAlg = TripleDES.Create();
                encAlg.Key = k1.GetBytes(16);
                MemoryStream encryptionStream = new MemoryStream();
                CryptoStream encrypt = new CryptoStream(encryptionStream,
encAlg.CreateEncryptor(), CryptoStreamMode.Write);
                byte[] utfD1 = new System.Text.UTF8Encoding(false).GetBytes(
data1);

                encrypt.Write(utfD1, 0, utfD1.Length);
                encrypt.FlushFinalBlock();
                encrypt.Close();
                byte[] edata1 = encryptionStream.ToArray();
                k1.Reset();

                // Try to decrypt, thus showing it can be round-tripped.
                TripleDES decAlg = TripleDES.Create();
                decAlg.Key = k2.GetBytes(16);
                decAlg.IV = encAlg.IV;
                MemoryStream decryptionStreamBacking = new MemoryStream();
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
                    CryptoStream decrypt = new CryptoStream(
decryptionStreamBacking, decAlg.CreateDecryptor(), CryptoStreamMode.Write);
                    decrypt.Write(edata1, 0, edata1.Length);
                    decrypt.Flush();
                    decrypt.Close();
                    k2.Reset();
                    string data2 = new UTF8Encoding(false).GetString(
decryptionStreamBacking.ToArray());

                    if (!data1.Equals(data2))
                    {
                        Console.WriteLine("Error: The two values are not equal.");
                    }
                    else
                    {
                        Console.WriteLine("The two values are equal.");
                        Console.WriteLine("k1 iterations: {0}", k1.IterationCount);
                        Console.WriteLine("k2 iterations: {0}", k2.IterationCount);
                    }
                }
                catch (Exception e)
                {
                    Console.WriteLine("Error: ", e);
                }
            }
        }
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

}

參考連結：

- Rfc2898DeriveBytes 類別
  https://msdn.microsoft.com/zh-tw/library/system.security.cryptography.rfc2898derivebytes(v=vs.110).aspx
- MembershipEntity.PasswordSalt Property
  https://msdn.microsoft.com/en-us/library/system.web.providers.entities.membershipentity.passwordsalt(v=vs.108).aspx
- Password Hashing
  https://docs.microsoft.com/en-us/aspnet/core/security/data-protection/consumer-apis/password-hashing
- PasswordHasher.HashPassword Method (String)
  https://msdn.microsoft.com/en-us/library/microsoft.aspnet.identity.passwordhasher.hashpassword(v=vs.108).aspx
- ASP.NET Identity | The ASP.NET Site
  https://www.asp.net/identity
- Introducing ASP.NET Identity – A membership system for ASP.NET applications
  https://blogs.msdn.microsoft.com/webdev/2013/06/27/introducing-asp-net-identity-a-membership-system-for-asp-net-applications/
- Microsoft.AspNet.Identity 命名空間
- https://msdn.microsoft.com/zh-tw/library/microsoft.aspnet.identity(v=vs.111).aspx

Java 實作範例：

```
public class RegisterAction extends HttpServlet {
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
    protected void doPost(HttpServletRequest request, HttpServletResponse response) throws
ServletException,IOException {
        //request
        String id = request.getParameter("id");
        String name = request.getParameter("name");
        String password = request.getParameter("password");
        RequestDispatcher requestDispatcher =
getServletContext().getRequestDispatcher("/Register.jsp");
        try{
            //使用 Java UUID 產生唯一且亂數的 salt，將密碼及 salt 合併後進行 hash 運算
            String salt = UUID.randomUUID().toString();
            String hashValue = hash(password, salt);
            //將 hash 值及 salt 值存入資料庫
            addNewUser(id,name,hashValue,salt);
            requestDispatcher = getServletContext().getRequestDispatcher("/Login.jsp");
            requestDispatcher.forward(request,response);
            return;
        } catch (Exception e){
            e.printStackTrace();
        }
        requestDispatcher.forward(request,response);
    }

    private String hash(String password,String salt){
        try{
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
        Encoder encoder = java.util.Base64.getEncoder();
        // 設定採用 sha-512 進行雜湊運算
        MessageDigest md = MessageDigest.getInstance("SHA-512");
        String salted = password + salt;
        // hash
        md.update(salted.getBytes("UTF-8"));
        byte[] digest = md.digest();
        return encoder.encoderToString(digest);
      } catch (Exception e){
        e.printStackTrace();
      }
      return null;
   }
}
```

參考連結：

- PBEKeySpec (Java Platform SE 7)
  https://docs.oracle.com/javase/7/docs/api/javax/crypto/spec/PBEKeySpec.html
- How can I hash a password in Java?
  https://stackoverflow.com/questions/2860943/how-can-i-hash-a-password-in-java
- How do I generate a SALT in Java for Salted-Hash?
  https://stackoverflow.com/questions/18142745/how-do-i-generate-a-salt-in-java-for-salted-hash
- Salted Password Hashing - Doing it Right

本文件之智慧財產權屬數位發展部資通安全署擁有。

https://crackstation.net/hashing-security.htm

PHP 實作範例：

PHP 提供 password_hash()函數，可以產生有 salt 的密碼，範例如下：

```
<?php
/**
 * Note that the salt here is randomly generated.
 * Never use a static salt or one that is not randomly generated.
 *
 * For the VAST majority of use-cases, let password_hash generate the salt randomly for you
 */
$options = [
    'cost' => 11,
    'salt' => mcrypt_create_iv(22, MCRYPT_DEV_URANDOM),
];
echo password_hash("rasmuslerdorf", PASSWORD_BCRYPT, $options)."\n";
?>
```

參考連結：

- PHP: password_hash - Manual
  http://php.net/manual/en/function.password-hash.php
- PHP: Password Hashing - Manual - PHP.net
  http://php.net/manual/en/faq.passwords.php
- Creates a password hash - PHP.net
  http://php.net/manual/en/function.password-hash.php
- PHP: crypt - Manual

本文件之智慧財產權屬數位發展部資通安全署擁有。

http://php.net/manual/en/function.crypt.php

資料來源： 本計畫整理

4.4.5 非內部使用者之識別與鑑別(Identification and Authentication for Non-Organizational Users)

非內部使用者之識別與鑑別類別之控制措施包含：

●資訊系統應識別及鑑別非機關使用者(或代表機關使用者行為的程序)。

非內部使用者之識別與鑑別控制措施並無相關的應用程式技術面項目，因此不在此份文件描述。

4.5 系統與服務獲得(System and Services Acquisition)

系統與服務獲得分為「系統發展生命週期需求階段」、「系統發展生命週期設計階段」、「系統發展生命週期開發階段」、「系統發展生命週期測試階段」、「系統發展生命週期部署與維運階段」、「系統發展生命週期委外階段」、「獲得程序」及「資訊系統文件」等 8 項控制措施，說明如下。

4.5.1 安全系統發展生命週期需求階段(Secure System Development Life Cycle-Requirement)

安全系統發展生命週期需求階段類別之控制措施包含：

●針對系統安全需求，以檢核表方式進行確認。

與安全系統發展生命週期需求階段控制措施相關的應用程式技術面項目，整理如下：

4.5.1.1 安全系統發展生命週期需求階段

本文件之智慧財產權屬數位發展部資通安全署擁有。

本項目實作項目包含以下 1 項：

●針對系統安全需求，以檢核表方式進行確認。

– 相關實作建議與範例，詳見表 56。

表56 安全系統發展生命週期需求階段-實作建議與範例

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	安全系統發展生命週期需求階段	針對系統安全需求，以檢核表方式進行確認
查核方式：☐自動化工具檢測　☒人工審查				
控制措施： 針對系統安全需求，以檢核表方式進行確認。 **實作指導：** 建議可參照技服中心所發布的「資訊系統委外開發 RFP 資安需求範本」，進行安全需求確認。				
實作範例：以檢核表方式進行確認。				

資料來源： 本計畫整理

4.5.2 安全系統發展生命週期設計階段(Secure System Development Life Cycle-Design)

安全系統發展生命週期設計階段類別之控制措施包含以下 2 項：

●應根據系統功能與要求，識別可能影響系統之威脅，進行風險分析與評估。

本文件之智慧財產權屬數位發展部資通安全署擁有。

●將風險評估結果回饋需求階段的檢核項目，並提出安全需求修正。

與安全系統發展生命週期設計階段控制措施相關的應用程式技術面實作建議，詳見表 57。

表57 安全系統發展生命週期設計階段-實作建議

適用分級			類別	實作項目
普	中	高		
	◎	◎	安全系統發展生命週期設計階段	(1)應根據系統功能與要求，識別可能影響系統之威脅，進行風險分析與評估。 (2)將風險評估結果回饋需求階段的檢核項目，並提出安全需求修正。
查核方式：☐自動化工具檢測　☒人工審查				
控制措施： (1)應根據系統功能與要求，識別可能影響系統之威脅，進行風險分析與評估。 (2)將風險評估結果回饋需求階段的檢核項目，並提出安全需求修正。 **實作指導：** 建議可參照行政院資通安全會報技術服務中心於 103 年發行之「安全軟體設計參考指引」，於第 3 章說明安全軟體設計階段實務活動，包含介紹「安全設計原則」，說明應該進行系統設計時，應該參考使用的設計原則。「執行攻擊面分析」，說明進行攻擊面的定義、識別與對應方式，包含如何進行攻擊面的衡量與評估，並進行管理等。「執行風險分析」說明軟體設計過程中，如何透過使用威脅建模與架構風險分析，進行系統架構與威脅的分析，並介紹通用性的安全設計原則與控制措施，提供軟體安全風險分析與控制。「安全設計審查」說明在進行一連安全軟體設計的實務活動之後，應確保安全設計符合需求				

本文件之智慧財產權屬數位發展部資通安全署擁有。

階段提出的相關安全需求及安全設計，能滿足軟體安全的基準線。

資料來源： 本計畫整理

– 相關程式範例，詳見表 58。

表58 安全系統發展生命週期設計階段-程式範例

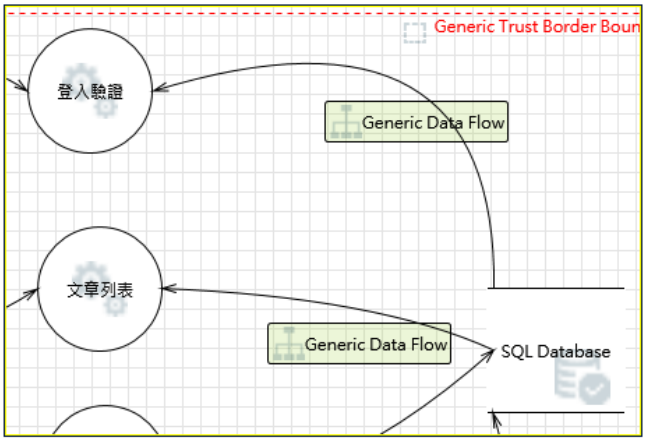
Microsoft Threat Modeling Tool 2016 實作範例：
微軟提供了 Microsoft Threat Modeling Tool 2016 免費軟體，可以對威脅建立模型和分析，畫面詳見圖 19。 Interaction: Generic Data Flow    1. Spoofing of Source Data Store SQL Database [State: Not Started] [Priority: High] Category: Spoofing Description: SQL Database may be spoofed by an attacker and this may lead to incorrect data delivered to 登入驗證. Consi Justification: <no mitigation provided> 2. Weak Access Control for a Resource [State: Not Started] [Priority: High] Category: Information Disclosure Description: Improper data protection of SQL Database can allow an attacker to read information not intended for disclosure Justification: <no mitigation provided> 資料來源：本計畫整理

圖19 Microsoft Threat Modeling Tool 2016 執行畫面

本文件之智慧財產權屬數位發展部資通安全署擁有。

參考連結：

- Microsoft Threat Modeling Tool 2016 軟體下載
  https://www.microsoft.com/en-us/download/details.aspx?id=49168
- Threat Modeling
  https://msdn.microsoft.com/en-us/library/ff648644.aspx
- Application Threat Modeling - OWASP
  https://www.owasp.org/index.php/Application_Threat_Modeling
- 威脅模型分析 - 維基百科，自由的百科全書
  https://zh.wikipedia.org/wiki/%E5%A8%81%E8%84%85%E6%A8%A1%E5%9E%8B%E5%88%86%E6%9E%90
- Threat model - Wikipedia
  https://en.wikipedia.org/wiki/Threat_model

資料來源： 本計畫整理

4.5.3 安全系統發展生命週期開發階段(Secure System Development Life Cycle-Develop)

安全系統發展生命週期開發階段類別之控制措施包含以下 5 項：

- 應針對安全需求實作必要控制措施。
- 應注意避免軟體常見漏洞(如 OWASP TOP 10)及實作必要控制措施。
- 應針對資訊系統之錯誤與例外進行適當處理。
- 執行「源碼掃描」安全檢測。
- 具備系統嚴重錯誤之通知機制(例如電子郵件或簡訊)。

與安全系統發展生命週期開發階段控制措施相關的應用程式技術面項目，整理如下：

本文件之智慧財產權屬數位發展部資通安全署擁有。

4.5.3.1 應注意避免軟體常見漏洞(如 OWASP TOP 10) 及實作必要控制措施

本項目實作項目包含以下 3 項：

●具有防範 SQL 命令注入攻擊(SQL Injection)之措施。

– 相關實作建議，詳見表 59。

表59 安全系統發展生命週期開發階段-實作建議 1

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	安全系統發展生命週期開發階段	具有防範 SQL 命令注入攻擊(SQL Injection)之措施
查核方式：☒自動化工具檢測　☒人工審查				
控制措施： 系統於伺服器端具有防範 SQL 命令注入攻擊措施。例如 Prepared statements、Stored procedures、輸入驗證(Input Validation)等。 **實作指導：** 當系統存取資料庫時，應採用明確宣告傳入變數的方式進行與資料庫的溝通，以避免組合 SQL 語法的處理方式發生無法預期的系統錯誤與系統安全的問題。				

資料來源： 本計畫整理

– 相關程式範例，詳見表 60。

本文件之智慧財產權屬數位發展部資通安全署擁有。

表60 安全系統發展生命週期開發階段-程式範例 1

ASP.NET 實作範例：
ASP.NET 較底層的資料庫存取方式為：建立連線後，再將 SQL 語法傳給 SqlCommand，進一步與資料庫做溝通，但在傳入變數時應使用 SqlCommand 的 Parameter 宣告變數，避免在組合 SQL 語法時讓不安全的 SQL 語法在資料庫中執行。以下針對 SqlCommand 傳入變數實作程式碼示範： ▪ 設置一個傳入字串，假設該字串為使用者輸入，或由第三方傳來的資料內容，需將字串內容傳入 SQL 語法做為變數，用來查詢其他資料，進一步顯示在頁面上時，就必須將變數以 Parameter 方式宣告處理。 ▪ 直接組合 SQL 語法對資料庫查詢，可能導致無法預期的行為，需避免危險的 SQL 組合字串的使用方式，例如： SqlCommand command = new SqlCommand("SELECT * FROM salary where name= '" + user + "'", connection); ▪ 正確安全的 SQL 語法使用方式，使用 Parameter 正確的將字串宣告為變數，可避免其他無法預期的 SQL 行為。 SqlCommand command = new SqlCommand("SELECT * FROM salary where name= @user",connection); command.Parameters.AddWithValue("@user", user); 參考連結： ▪ SQL 資料隱碼 https://technet.microsoft.com/zh-tw/library/ms161953(v=sql.105).aspx ▪ SqlCommand.Prepare 方法 () https://msdn.microsoft.com/zh-tw/library/system.data.sqlclient.sqlcommand.prepare(v=vs.110).aspx ▪ SQL Injection https://docs.microsoft.com/en-us/sql/relational-databases/security/sql-injection

本文件之智慧財產權屬數位發展部資通安全署擁有。

- Sqlparameter Class

  http://msdn.microsoft.com/en-us/library/system.data.sqlclient.sqlparameter.aspx
- How To: Protect From SQL Injection in ASP.NET

  http://msdn.microsoft.com/en-us/library/ff648339.aspx

Java 實作範例：

Java 已有現成的 PreparedStatement 元件：

- 設置一個傳入字串，假設該字串為使用者輸入，或由第三方傳來的資料內容，需將字串內容傳入 SQL 語法做為變數，用來查詢其他資料，進一步顯示在頁面上時，就必須將變數以 Parameter 方式宣告處理。
- 直接組合 SQL 語法對資料庫查詢最危險，可能導致無法預期的行為，需避免危險的 SQL 組合字串的使用方式，例如：

```
String unsafeData = '';SELECT * FROM Administrator;//';
String sqlString = "SELECT * FROM Member WHERE Name LIKE '" + unsafeData + "'";
try {
  Statement statement = connection.createStatement( … );
  ResultSet results = statement.executeQuery(sqlString);
  };
//實際進資料庫所查詢的語法：
”SELECT * FROM Member WHERE Name LIKE ';SELECT * FROM Administrator;//”
//上行結果，會把原本是要查詢 Member 這個 Table 的 SQL 語法組合為查詢 Administrator 這個 Table 的語法，甚至可以組合為把 Table 刪除的 SQL 語法，故需避免此種用法。
```

- 正確安全的 SQL 語法使用方式，使用 Parameter 正確的將字串宣告為變數，可避免其他無法預期的 SQL 行為。

```
String unsafeData = '';SELECT * FROM Administrator;//';
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
String sqlString = "SELECT * FROM Member WHERE Name LIKE ?";
PreparedStatement pstmt = connection.prepareStatement( sqlString );
 pstmt.setString( 1, unsafeData);
 ResultSet results = pstmt.executeQuery( )
```

參考連結：

- SQL Injection Prevention Cheat Sheet
  https://www.owasp.org/index.php/SQL_Injection_Prevention_Cheat_Sheet
- Hibernate
  http://www.hibernate.org/

PHP 實作範例：

PHP 有 mysql_real_escape_string()函數可以進行字串過濾，範例如下：

```
$user = mysql_real_escape_string($user);
$pwd = mysql_real_escape_string($pwd);
```

但是在 PHP 5.5.0 版時被放棄，在 PHP 7.0.0 時被移除，改用 MySQLi 或 PDO_MySQL 代替。

PHP 可透過 PDO 實作不同的資料庫操作介面：

- 設置一個傳入字串，假設該字串為使用者輸入，或由第三方傳來的資料內容，需將字串內容傳入 SQL 語法做為變數，用來查詢其他資料，進一步顯示在頁面上時，就必須將變數以 Parameter 方式宣告處理。
- 直接組合 SQL 語法對資料庫查詢最危險，可能導致無法預期的行為，應避免危險的 SQL 組合字串的使用方式，例如：

```
$dbh = new PDO('mysql:host=localhost;dbname=test', $user, $pass);
$unsafe_data = '';SELECT * FROM Administrator;//';
$sql_string = "SELECT * FROM Member WHERE Name LIKE '" . $unsafe_data . "'";
$dbh->query($sql_string);
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
//實際進資料庫所查詢的語法：
”SELECT * FROM Member WHERE Name LIKE '';SELECT * FROM Administrator;//”
//上行結果，會把原本是要查詢 Member 這個 Table 的 SQL 語法組合為查詢 Administrator 這個 Table 的語法，甚至可以組合為把 Table 刪除的 SQL 語法，故需避免此種用法。
```

- 正確安全的 SQL 語法使用方式，使用 Parameter 正確的將字串宣告為變數，可避免其他無法預期的 SQL 行為。

```
$dbh = new PDO('mysql:host=localhost;dbname=test', $user, $pass);
$unsafe_data = '';SELECT * FROM Administrator;//';
$sql_string = "SELECT * FROM Member WHERE Name LIKE :name";
$sth = $dbh->prepare($sql, array(PDO::ATTR_CURSOR =>
                        PDO::CURSOR_FWDONLY));
$sth->execute(array(':name' => 'yourname'));
//實際進資料庫所查詢的語法：
DECLARE @name varchar(30) = “';SELECT * FROM Administrator;//”;
SELECT * FROM Member WHERE Name LIKE @name
//上行執行仍會如預期方式查詢 Member 這張 Table
```

參考連結：

- PDO

  PDO 是 PHP 內建的套件

  http://www.php.net/manual/en/pdo.prepare.php
- PHP: mysql_real_escape_string - Manual

  http://php.net/manual/en/function.mysql-real-escape-string.php

資料來源： 本計畫整理

●具有防範跨站腳本攻擊(XSS, Cross-Site Scripting)之措施。

本文件之智慧財產權屬數位發展部資通安全署擁有。

– 相關實作建議，詳見表 61。

表61 安全系統發展生命週期開發階段-實作建議 2

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	系統發展生命週期開發階段	具有防範跨站腳本攻擊(XSS, Cross-Site Scripting)之措施
查核方式：☒自動化工具檢測　☒人工審查				
控制措施： 系統於伺服器端具有防範跨站腳本攻擊(Cross-Site Scripting)措施。例如以黑名單過濾跳脫特殊字元、白名單正規表示式驗證、輸出編碼等。此安全需求項目僅適用於 Web 網站系統。 **實作指導：** 當系統因功能需求必須取用或儲存使用者所傳入的資料內容時，必須使用統一驗證樣板驗證判斷處理後才可使用，以避免所傳入的資料對系統造成危害。				

資料來源： 本計畫整理

– 相關程式範例，詳見表 62。

表62 安全系統發展生命週期開發階段-程式範例 2

ASP.NET 實作範例：
ASP.NET 本身內建防範跨站腳本攻擊(Cross-Site Scripting)，預設使用黑名單技術，另外提供使用白名單技術的 Microsoft Anti-XSS Library V4.3 (Microsoft Anti-Cross Site Scripting Library V4.3)，使用者可以用 NuGet 或

本文件之智慧財產權屬數位發展部資通安全署擁有。

獨立下載安裝使用，而到了.NET 4.5 版，Anti-XSS 更直接整合放入.NET 4.5 之中。許多方法，例如 HtmlEncode, HtmlFormUrlEncode, XmlEncode, UrlEncode, UrlPathEncode, CssEncode 等皆直接內建 XSS 防護功能。

對於.NET 4.5 用戶，只要在 Web.Config 加入一行設定即可。

```
<httpRuntime encoderType="System.Web.Security.AntiXss.AntiXssEncoder,
                          System.Web,
                          Version=4.0.0.0,
                          Culture=neutral,
                          PublicKeyToken=b03f5f7f11d50a3a" />
```

然後把string result = HttpUtility.HtmlEncoder(orgionMessage);

改成string result = AntiXssEncoder.HtmlEncoder(orgionMessage, true);

依此類推。

參考連結：

- System.Web.Security.AntiXss 命名空間
  https://msdn.microsoft.com/zh-tw/library/system.web.security.antixss.aspx
- AntiXssEncoder 類別
  https://msdn.microsoft.com/zh-tw/library/system.web.security.antixss.antixssencoder(v=vs.110).aspx
- Microsoft Anti-XSS Library V4.3 (Microsoft Anti-Cross Site Scripting Library V4.3)
  https://www.microsoft.com/en-us/download/details.aspx?id=43126
- NuGet - AntiXss
  https://www.nuget.org/packages/AntiXss/
- ASP.NET Output Encoding
  https://www.owasp.org/index.php/ASP.NET_Output_Encoding#AntiXssEncoder

本文件之智慧財產權屬數位發展部資通安全署擁有。

▪ HttpEncoder 類別

https://msdn.microsoft.com/zh-tw/library/system.web.util.httpencoder(v=vs.100).aspx

Java 實作範例：

▪ 使用 filter 跳脫特殊字元(escape html special characters)在所有文字字串「輸入」以及「輸出」，範例如下。

```
// Remove any lonesome    <script ... > tag
scriptPattern = Pattern.compile("<script(.*?)>",Pattern.CASE_INSENSITIVE |
Pattern.MULTILINE | Pattern.DOTALL);
value = scriptPattern.matcher(value).replaceALL("");

// Avoid eval(....) expressions
scriptPattern = Pattern.compile("eval\\((.*?)\\)",Pattern.CASE_INSENSITIVE |
Pattern.MULTILINE | Pattern.DOTALL);
value = scriptPattern.matcher(value).replaceALL("");

// Avoid expression(...) expressions
scriptPattern = Pattern.compile("<expression\\(.*?)\\)",Pattern.CASE_INSENSITIVE |
Pattern.MULTILINE | Pattern.DOTALL);
value = scriptPattern.matcher(value).replaceALL("");
```

▪ 在允許作 HTML 語法輸入的地方使用 HTMLInputFilter，參考 http://josephoconnell.com/java/xss-html-filter/

▪ 使用 OWASP ESAPI

OWASP Enterprise Security API (ESAPI)是免費、開放原始碼的網頁安全控制函式庫，目的使程式設計師較容易地寫出低風險的應用程式。它具有 Java、.NET、PHP、C、C++、Objective C、JavaScript、Python、Perl 等多種版本。

▪ 利用 ESAPI 避免 XSS 問題

Input Validation API 使用範例：

```
String safe = ESAPI.encoder().encodeForJavaScript(request.getParameter(“input”));
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

Output Encoding API 使用範例：

String safeOutput =”/admin/findUser.do?name=” +

ESAPI.encoder().encodeForURL(cleanUserName);

▪ Input Validation

僅允許輸入特定字元(白名單)，使用 Regular Expression (正規表示式)，範例如下：

中文:[\u4e00-\u9fa5]

英文字母:[a-zA-Z]

數字:[0-9]

中文、英文、數字，及底線: ^[\u4e00-\u9fa5_a-zA-Z0-9]+$

另外需要注意的是，過濾特殊字元(黑名單) (Not Recommend)僅在 Server 端有效，使用 JavaScript 無效。

必須防範同義字(Canonicalization)問題，包括 URL 編碼(URL Encoding)、HTML 編碼 (HTML Encoding)，以及 Unicode 編碼(Unicode Encoding)等，過濾惡意輸入時，必須注意輸入採用的是何種形式的編碼，否則過濾方式容易被攻擊者以特定編碼略過。

▪ 使用 OWASP ESAPI 防護 XSS：

value = ESAPI.encoder().canonicalize(value.trim());

▪ Output Encoding

在資料被使用者端呈現前，將不合法的字元從代表「命令」修改為代表「資料」的編碼，網頁有五種格式輸出需要作輸出編碼

HTML Body Context，例如：<Body>...</Body>

HTML Attribute Context，例如：

URL Context，例如：<a href=”/hello?name=……”>

本文件之智慧財產權屬數位發展部資通安全署擁有。

Javascript Context

CSS Context，例如：<span style=property:" …";>text</style>

使用範例如下：

String encodeForHTML(String Input)

String encodeForHTMLAttribute(String Input)

String encodeForURL(String Input)

String encodeForJavaScript(String Input)

String encodeForCSS(String Input)

參考連結：

- HTML filtering utility for Java

  http://josephoconnell.com/java/xss-html-filter/
- Pattern (Java Platform SE 7)

  https://docs.oracle.com/javase/7/docs/api/java/util/regex/Pattern.html
- Methods of the Pattern Class (The Java™ Tutorials > Essential Classes > Regular Expressions)

  https://docs.oracle.com/javase/tutorial/essential/regex/pattern.html

PHP 實作範例：

PHP 提供 htmlspecialchars()可以避免 XSS 攻擊，範例如下：

```
<?php
$new = htmlspecialchars("<a href='test'>Test</a>", ENT_QUOTES);
echo $new; // &lt;a href=&#039;test&#039;&gt;Test&lt;/a&gt;
?>
```

參考連結：

- PHP Attacks and Defense

  http://talks.php.net/show/xss-csrf-apachecon2003/1
- PHP: htmlspecialchars - Manual

本文件之智慧財產權屬數位發展部資通安全署擁有。

http://php.net/manual/en/function.htmlspecialchars.php

- PHP: htmlentities - Manual

  http://php.net/manual/en/function.htmlentities.php

資料來源： 本計畫整理

●具有防範「跨站請求偽造」(Cross-Site Request Forgery, CSRF)攻擊之措施。

– 相關實作建議，詳見表 63。

表63 安全系統發展生命週期開發階段-實作建議 3

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	安全系統發展生命週期開發階段	具有防範「跨站請求偽造」(Cross-Site Request Forgery, CSRF)攻擊之措施
查核方式：☒自動化工具檢測　☒人工審查				
控制措施： 「跨站請求偽造」攻擊發生情況為，攻擊者知道網站特定行為的執行參數，在使用者已通過網站身分鑑別登入後，以欺騙使用者點選連結或其他方式，偽造使用者之請求進行該特定行為並帶入相關參數，以遂行惡意之目的。 **實作指導：** 防範 CSRF 的措施主要有：1.重要行為前先動態產生獨立而唯一的 request token，並於執行行為前檢查。2.要求使用者重新身分鑑別或證明該動作是人為進行(使用 CAPTCHA)。此安全需求項目僅適用於 Web 網				

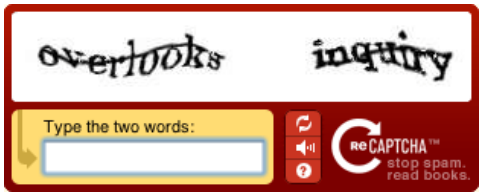
本文件之智慧財產權屬數位發展部資通安全署擁有。

站系統。

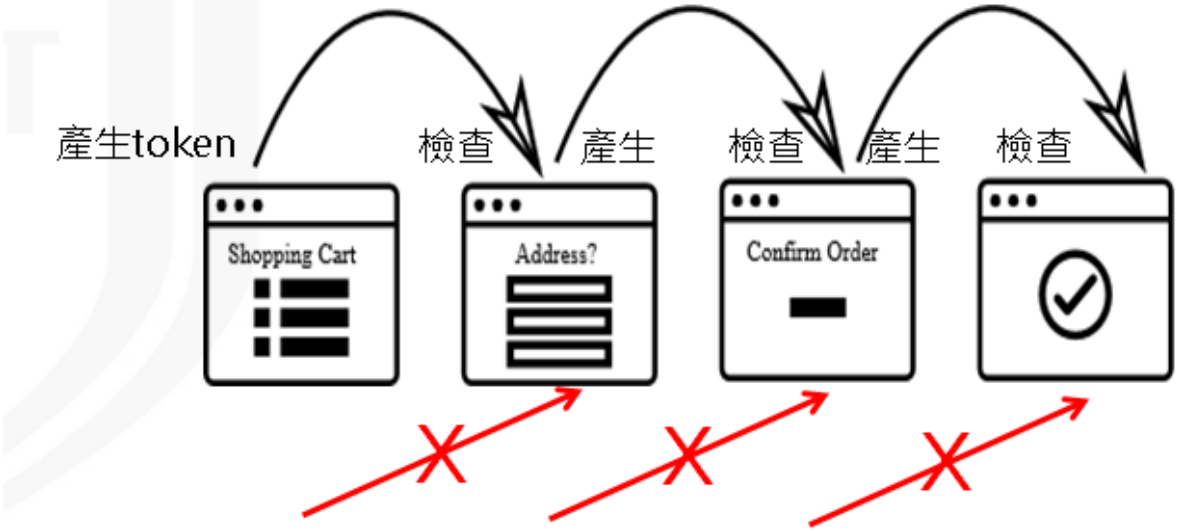
資料來源： 本計畫整理

– 相關程式範例，詳見表 64。

表64 安全系統發展生命週期開發階段-程式範例 3

ASP.NET 實作範例：
ASP.NET 可考慮用下面 2 種方法進行防禦： ▪ CAPTCHA：重要的行為要求使用者重新認證或證明該動作是人為進行畫面詳見圖 20。    資料來源：本計畫整理 圖20 CAPTCHA ▪ Anti-CSRF Token：重要的行為動態產生獨立而唯一的 request token (Synchronizer Token Pattern)，原理如下： 1. Token 隨機產生 2. Token 必須由伺服器驗證 3. 攻擊者無法猜測到 Token 畫面詳見圖 21。

本文件之智慧財產權屬數位發展部資通安全署擁有。



資料來源：本計畫整理

圖21 Anti-CSRF Token

Microsoft .NET 對於 CSRF 防禦機制如下：

- ASP.NET WebForm：Visual Studio 2012 預設的 Web app 即啟用保護，將驗證資訊儲存於 ViewState，畫面詳見圖 22。

```
<input name="__RequestVerificationToken" type="hidden" value="MRRR4ga6eu8EiCeHKdJAiZgF1EO4OC52U3L6UUe
_nqIfe7I7jONPmsJ2Vc_chDi7gA7drUYy4hyehi_UDkso2wrbmLgaKXGypM0rAfHec7g1" />
```

資料來源：本計畫整理

圖22 ViewState

Site.Master.cs 範例如下：

```
using System;
using System.Collections.Generic;
using System.Security.Claims;
using System.Security.Principal;
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
using System.Web;
using System.Web.Security;
using System.Web.UI;
using System.Web.UI.WebControls;
using Microsoft.AspNet.Identity;

namespace SSDLCSample
{
    public partial class SiteMaster : MasterPage
    {
        private const string AntiXsrfTokenKey = "__AntiXsrfToken";
        private const string AntiXsrfUserNameKey = "__AntiXsrfUserName";
        private string _antiXsrfTokenValue;

        protected void Page_Init(object sender, EventArgs e)
        {
            //下面的程式碼有助於防禦 XSRF 攻擊
            var requestCookie = Request.Cookies[AntiXsrfTokenKey];
            Guid requestCookieGuidValue;
            if (requestCookie != null && Guid.TryParse(requestCookie.Value, out
 requestCookieGuidValue))
            {
                //使用 Cookie 中的 Anti-XSRFToken
                _antiXsrfTokenValue = requestCookie.Value;
                Page.ViewStateUserKey = _antiXsrfTokenValue;
            }
            else
            {
                //產生新的 Anti-XSRF Token 並儲存到 cookie
                _antiXsrfTokenValue = Guid.NewGuid().ToString("N");
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
                Page.ViewStateUserKey = _antiXsrfTokenValue;

                var responseCookie = new HttpCookie(AntiXsrfTokenKey)
                {
                    HttpOnly = true,
                    Value = _antiXsrfTokenValue
                };
                if (FormsAuthentication.RequireSSL && Request.IsSecureConnection)
                {
                    responseCookie.Secure = true;
                }
                Response.Cookies.Set(responseCookie);
            }

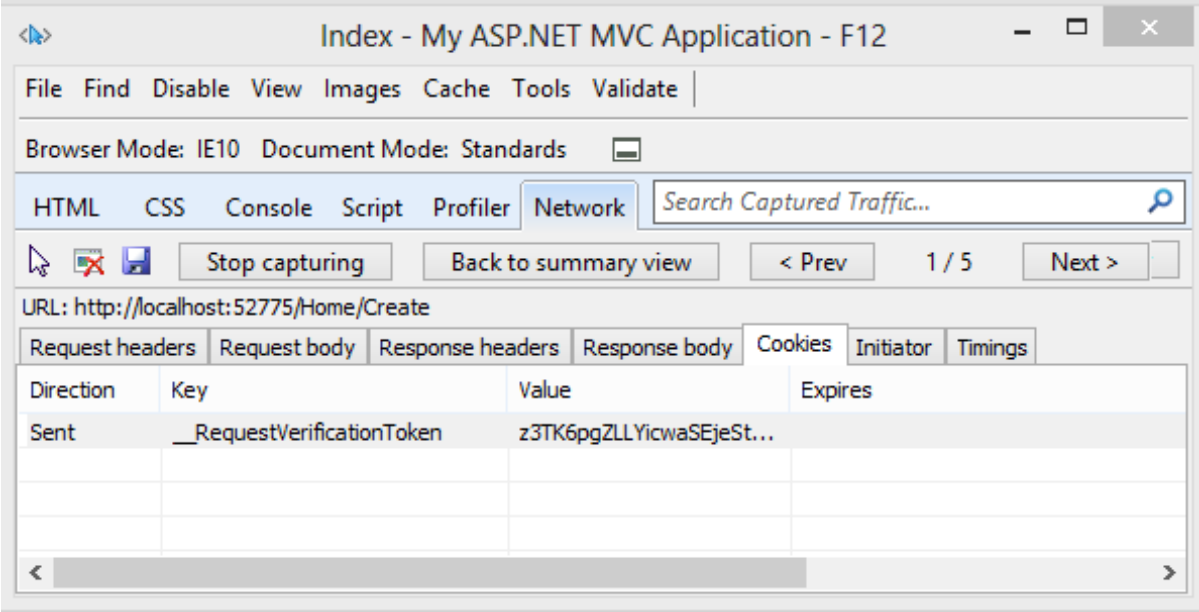
            Page.PreLoad += master_Page_PreLoad;
        }

        protected void master_Page_PreLoad(object sender, EventArgs e)
        {
            if (!IsPostBack)
            {
                //設定 Anti-XSRF Token
                ViewState[AntiXsrfTokenKey] = Page.ViewStateUserKey;
                ViewState[AntiXsrfUserNameKey] = Context.User.Identity.Name ??
String.Empty;
            }
            else
            {
                //驗證 Anti-XSRF Token
                if ((string)ViewState[AntiXsrfTokenKey] != _antiXsrfTokenValue
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
                    || (string)ViewState[AntiXsrfUserNameKey] !=
(Context.User.Identity.Name ?? String.Empty))
                {
                    throw new InvalidOperationException("Anti-XSRF Token 驗證失
敗。");
                }
            }
        }
    }
}
```

- ASP.NET MVC/Web API：使用 AntiForgery tokens，呼叫 GetHtml 方法，此方法會建立加密 Token，並將它新增至表單，以做為隱藏欄位。它會將相同的 Token 新增至 HTTP Cookie，畫面詳見圖 23。



資料來源：本計畫整理

圖23 AntiForgery Token

本文件之智慧財產權屬數位發展部資通安全署擁有。

AntiForgery in ASP.NET MVC 程式範例：

```
@{
    string name = string.Empty;
    if(IsPost) {
        AntiForgery.Validate();
        name = Request.Form["name"];
    }
}
<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="utf-8" />
    <title>Antiforgery helper</title>
</head>
<body>
    @if (IsPost)
    {<span>You typed in @name</span> }
    <form method="post" action="">
        <label><strong>Name : </strong></label>
        <input type="text" name="name" value="@name" />
        @AntiForgery.GetHtml()
        <input type="submit" value="Go" />
    </form>
</body>
</html>
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

參考連結：

- AntiForgery 類別 (System.Web.Helpers)
  https://msdn.microsoft.com/zh-tw/library/system.web.helpers.antiforgery(v=vs.111).aspx

Anti-CSRF and AJAX 程式(html 部分)：

```
<script>
    @functions{
        public string TokenHeaderValue()
        {
            string cookieToken, formToken;
            AntiForgery.GetTokens(null, out cookieToken, out formToken);
            return cookieToken + ":" + formToken;
        }
    }

    $.ajax("api/values", {
        type: "post",
        contentType: "application/json",
        data: {  }, // JSON data goes here
        dataType: "json",
        headers: {
            'RequestVerificationToken': '@TokenHeaderValue()'
        }
    });
</script>
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

Anti-CSRF and AJAX 程式(C#部分)：

```
void ValidateRequestHeader(HttpRequestMessage request)
{
    string cookieToken = "";
    string formToken = "";

    IEnumerable<string> tokenHeaders;
    if (request.Headers.TryGetValues("RequestVerificationToken", out tokenHeaders))
    {
        string[] tokens = tokenHeaders.First().Split(':');
        if (tokens.Length == 2)
        {
            cookieToken = tokens[0].Trim();
            formToken = tokens[1].Trim();
        }
    }
    AntiForgery.Validate(cookieToken, formToken);
}
```

參考連結：

- Preventing Cross-Site Request Forgery (CSRF) Attacks in ASP.NET Web API
  https://docs.microsoft.com/en-us/aspnet/web-api/overview/security/preventing-cross-site-request-forgery-csrf-attacks
- How To Fix Cross-Site Request Forgery (CSRF) using Microsoft .Net ViewStateUserKey and Double Submit Cookie
  https://software-security.sans.org/developer-how-to/developer-guide-csrf

Java 實作範例：

本文件之智慧財產權屬數位發展部資通安全署擁有。

可使用 Anti-CSRF Token 來抵抗 CSRF 攻擊，存取重要行為時動態產生獨立且唯一的 request token (Synchronizer Token Pattern)，經由伺服器驗證其合法性後始能進行後續動作。以下為 OWASP CSRF Guard 使用範例：

設定 Web.xml：

```
<context-param>
   <param-name>Owasp.CsrfGuard.Config</param-name>
   <param-value>WEB-INF/Owasp.CsrfGuard.properties</param-value>
</context-param>
<context-param>
   <param-name>Owasp.CsrfGuard.Config.Print</param-name>
   <param-value>true</param-value>
</context-param>
<listener>
   <listener-class>org.owasp.csrfguard.CsrfGuardServletContextListener</listener-class>
</listener>
<listener>
   <listener-class>org.owasp.csrfguard.CsrfGuardHttpSessionListener</listener-class>
</listener>
<filter>
   <filter-name>CSRFGuard</filter-name>
   <filter-class>org.owasp.csrfguard.CsrfGuardFilter</filter-class>
</filter>
<filter-mapping>
   <filter-name>CSRFGuard</filter-name>
   <url-pattern>/TestCsrfGuard</url-pattern>
</filter-mapping>
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

Test.jsp 程式範例：

```
<%@ page language="java" contentType="text/html; charset=UTF-8" pageEncoding="UTF-8"%>
<%@ taglib uri="http://www.owasp.org/index.php/Category:OWASP_CSRFGuard_Project/Owasp.CsrfGuard.tld" prefix="csrf"%>
<html>
<body>
<a href="TestCsrfGuard?<csrf:token uri="TestCsrfGuard"/>">正確</a>
<br>
<form name="test" method="post" action="TestCsrfGuard">
<input type="text" name="text" value="text">
<input type="hidden" name="<csrf:tokenname/>" value="<csrf:tokenvalue uri="TestCsrfGuard"/>" />
<input type="submit" name="submit" value="submit"/>
</form>
<body>
</html>
```

參考連結：

- Category:OWASP CSRFGuard Project
  https://www.owasp.org/index.php/Category:OWASP_CSRFGuard_Project

PHP 實作範例：

以下為 PHP 官方提供之 CSRF 攻擊防範範例：

```
<?
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
$secret = uniqid(time());
$fp = fopen('./secrets.txt', 'a');
fwrite($fp, "$secret\n");
fclose($fp);
?>
<form action="<? echo $PHP_SELF; ?>">
<input type="text" name="message">
<input type="hidden" name="secret" value="<? echo $secret; ?>">
<input type="submit">
</form>
<?
if (!empty($_GET['message']))
{
	$secrets = file('./secrets.txt');
	$user_secret = "{$_GET['secret']}\n";
	if (in_array($user_secret, $secrets))
	{
		$fp = fopen('./safer.txt', 'a');
		$msg = $_GET['message'];
		$msg = htmlentities($msg);
		fwrite($fp, "$msg<br>");
		fclose($fp);
	}
}
readfile('./safer.txt');
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
?>
```

參考連結：

- PHP Message Board Revisited - Preventing CSRF Attacks
  http://talks.php.net/show/php-under-attack/15
- PHP: htmlentities - Manual
  http://php.net/manual/en/function.htmlentities.php
- PHP htmlentities() 函數
  http://www.w3school.com.cn/php/func_string_htmlentities.asp

以下為 OWASP 官方提供之 CSRF 攻擊防範範例：

```
<form method='post'>
<input type='text' name='test' value='<?php echo "testing"?>' />
<input type='submit' />
</form>

<form class='nocsrf'>
</form>
<?php
session_start(); //if you are copying this code, this line makes it work.
function store_in_session($key,$value)
{
if (isset($_SESSION))
{
$_SESSION[$key]=$value;
}
}
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
function unset_session($key)
{
$_SESSION[$key]=' ';
unset($_SESSION[$key]);
}
function get_from_session($key)
{
if (isset($_SESSION[$key]))
{
return $_SESSION[$key];
}
else {    return false; }
}
function csrfguard_generate_token($unique_form_name)
{
$token = random_bytes(64); // PHP 7, or via paragonie/random_compat
store_in_session($unique_form_name,$token);
return $token;
}
function csrfguard_validate_token($unique_form_name,$token_value)
{
$token = get_from_session($unique_form_name);
if (!is_string($token_value)) {
return false;
}
$result = hash_equals($token, $token_value);
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
unset_session($unique_form_name);
return $result;
}
function csrfguard_replace_forms($form_data_html)
{
$count=preg_match_all("/<form(.*?)>(.*?)<\\/form>/is",$form_data_html,$matches,PREG_SET_ORDER);
if (is_array($matches))
{
foreach ($matches as $m)
{
if (strpos($m[1],"nocsrf")!==false) { continue; }
$name="CSRFGuard_".mt_rand(0,mt_getrandmax());
$token=csrfguard_generate_token($name);
$form_data_html=str_replace($m[0],
"<form{$m[1]}>
<input type='hidden' name='CSRFName' value='{$name}' />
<input type='hidden' name='CSRFToken' value='{$token}'
/>{$m[2]}</form>",$form_data_html);
}
}
return $form_data_html;
}
function csrfguard_inject()
{
$data=ob_get_clean();
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
$data=csrfguard_replace_forms($data);
echo $data;
}
function csrfguard_start()
{
if (count($_POST))
{
if ( !isset($_POST['CSRFName']) or !isset($_POST['CSRFToken']) )
{
trigger_error("No CSRFName found, probable invalid request.",E_USER_ERROR);
}
$name =$_POST['CSRFName'];
$token=$_POST['CSRFToken'];
if (!csrfguard_validate_token($name, $token))
{
throw new Exception("Invalid CSRF token.");
}
}
ob_start();
/* adding double quotes for "csrfguard_inject" to prevent:
        Notice: Use of undefined constant csrfguard_inject - assumed 'csrfguard_inject' */
register_shutdown_function("csrfguard_inject");
}
csrfguard_start();
?>
```

參考連結：

本文件之智慧財產權屬數位發展部資通安全署擁有。

- PHP CSRF Guard - OWASP
  https://www.owasp.org/index.php/PHP_CSRF_Guard
- CSRFProtector Project - OWASP
  https://www.owasp.org/index.php/CSRFProtector_Project
- CSRF Protector php library - OWASP
  https://www.owasp.org/index.php/CSRF_Protector_php_library
- Cross-Site Request Forgery (CSRF) - OWASP
  https://www.owasp.org/index.php/Cross-Site_Request_Forgery_(CSRF)
- Cross-Site Request Forgery (CSRF) Prevention Cheat Sheet - OWASP
  https://www.owasp.org/index.php/Cross-Site_Request_Forgery_(CSRF)_Prevention_Cheat_Sheet
- PHP: rfc:automatic_csrf_protection
  https://wiki.php.net/rfc/automatic_csrf_protection
- PHP: Session Management Basics - Manual
  http://php.net/manual/en/features.session.security.management.php
- PHP Attacks and Defense
  http://talks.php.net/show/xss-csrf-apachecon2003

資料來源： 本計畫整理

4.5.3.2 應針對資訊系統之錯誤與例外進行適當處理

本項目實作項目包含以下 2 項：

- 發生錯誤時，使用者頁面僅顯示簡短錯誤訊息及代碼，不包含詳細的錯誤訊息。

  – 相關實作建議，詳見表 65。

本文件之智慧財產權屬數位發展部資通安全署擁有。

表65 安全系統發展生命週期開發階段-實作建議 4

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	安全系統發展生命週期開發階段	發生錯誤時，使用者頁面僅顯示簡短錯誤訊息及代碼，不包含詳細的錯誤訊息
查核方式：☐自動化工具檢測　☒人工審查				
控制措施： 系統應設計錯誤處理機制，當系統發生錯誤時，儘可能採取錯誤代碼或簡短訊息呈現，避免將詳細或除錯用訊息直接顯示於使用者頁面，以防被攻擊者用來刺探系統內部資訊，或根據錯誤訊息推測出系統可能之弱點。 **實作指導：** 發生錯誤時，使用者頁面僅顯示簡短錯誤訊息及代碼，不包含詳細的錯誤訊息。				

資料來源： 本計畫整理

– 相關程式範例，詳見表 66。

表66 安全系統發展生命週期開發階段-程式範例 4

ASP.NET 實作範例：
Microsoft Windows IIS 預設情況下，對遠端主機只會顯示簡短錯誤訊息，不會顯示詳細錯誤訊息，對本機電腦才會顯示詳細錯誤訊息。 在 ASP.NET 網站中，利用 web.config 中的設定，可以指定客製化的錯誤網頁。以下範例中，當網站發生錯誤時，使用者只能看到 CustomErrorPage.aspx 網頁內容：

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
<configuration>
  <appSettings/>
  <connectionStrings/>
  <system.web>
    <!-- Turn on Custom Errors -->
    <customErrors mode="RemoteOnly" defaultRedirect="CustomErrorPage.aspx">
    </customErrors >
  </system.web>
</configuration>
```

參考連結：

- 錯誤處理常式的完整範例
  https://msdn.microsoft.com/zh-tw/library/bb397417(v=vs.100).aspx
- customErrors 項目 (ASP.NET 設定結構描述)
  https://msdn.microsoft.com/zh-tw/library/office/h0hfz6fc(v=vs.100).aspx/html
- 如何使用 Visual C# .NET 在 ASP.NET 中建立自訂的錯誤報告頁面
  https://support.microsoft.com/zh-tw/help/306355/how-to-create-custom-error-reporting-pages-in-asp.net-by-using-visual

Java 實作範例：

在 Java 網站中，可以利用 web.xml 中的設定，指定客製化的錯誤網頁。以下範例中，當網站發生 404 錯誤、500 錯誤或是程式例外時，使用者只能看到 error.html 網頁內容，無法看見詳細錯誤資訊：

```
<web-app>
…
<error-page>
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
        < error-code>404</error-code>
        <location>/error.html</location>
  </error-page>
  <error-page>
        <error-code>500</error-code>
        <location>/error.html</location>
  </error-page>
  <error-page>
        <exception-type>java.lang.Exception</exception-type>
        <location>/error.html</location>
  </error-page>
  …
  </web-app>
```

參考連結：

- Creating and Configuring Servlets
  https://docs.oracle.com/cd/E13222_01/wls/docs92/webapp/configureservlet.html

PHP 實作範例：

PHP 的設定檔 PHP.ini 中 error_reporting 可設定顯示的錯誤訊息等級。

```
error_reporting= E_ALL        //記錄全部等級之錯誤
error_reporting= E_ERROR   //只記錄會造成程式當掉的嚴重錯誤
error_reporting= E_WARNING     //記錄警告
error_reporting= E_PARSE     //記錄編譯錯誤
error_reporting= E_NOTICE     //提醒工程師，可能會出錯的訊息
error_reporting = E_ERROR & E_WARNING   //只記錄嚴重錯誤及警告兩種等級
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

error_reporting = E_ALL & ~E_NOTICE　//除了 Notice 以外的錯誤皆記錄下來

display_errors = On　//在網頁顯示錯誤訊息

在 PHP 5.3 或之後的版本，預設值為：

error_reporting=E_ALL & ~E_NOTICE & ~E_STRICT & ~E_DEPRECATED

但 php.ini 中說明開發時建議值：

error_reporting=E_ALL

正式環境建議值為：

error_reporting=E_ALL ~E_STRICT & ~E_DEPRECATED

除了可以在 php.ini 中設定，也可以在程式中指定，範例如下：

```
<?php

// Désactiver le rapport d'erreurs
error_reporting(0);

// Rapporte les erreurs d'exécution de script
error_reporting(E_ERROR | E_WARNING | E_PARSE);

// Rapporter les E_NOTICE peut vous aider à améliorer vos scripts
// (variables non initialisées, variables mal orthographiées..)
error_reporting(E_ERROR | E_WARNING | E_PARSE | E_NOTICE);

// Rapporte toutes les erreurs à part les E_NOTICE
// C'est la configuration par défaut de php.ini
error_reporting(E_ALL & ~E_NOTICE);
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
// Reporte toutes les erreurs PHP (Voir l'historique des modifications)
error_reporting(E_ALL);

// Reporte toutes les erreurs PHP
error_reporting(-1);

// Même chose que error_reporting(E_ALL);
ini_set('error_reporting', E_ALL);
?>
```

參考連結：

- PHP: Runtime Configuration - Manual
  http://php.net/manual/en/errorfunc.configuration.php
- PHP: error_reporting - Manual
  http://php.net/manual/fr/function.error-reporting.php

資料來源： 本計畫整理

●所有功能皆進行錯誤及例外處理，並確保將資源正確釋放。

– 相關實作建議，詳見表 67。

表67 安全系統發展生命週期開發階段-實作建議 5

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	安全系統發展生命週期開發階段	所有功能皆進行錯誤及例外處理，並確保將資源正確釋放
查核方式：☐自動化工具檢測 ☒人工審查				

本文件之智慧財產權屬數位發展部資通安全署擁有。

控制措施：

確保系統所有功能的程式碼，在程式的進入點之後，盡可能採用程式語言的 try-catch 陳述，捕捉可能發生的錯誤與例外狀況。另外，採用程式語言的 finally 陳述，確保將該段功能程式碼所使用的資源正確釋放。

實作指導：

程式的進入點之後，盡可能採用程式語言的 try-catch -finally 陳述，捕捉可能發生的錯誤與例外狀況。

資料來源： 本計畫整理

– 相關程式範例，詳見表 68。

表68 安全系統發展生命週期開發階段-程式範例 5

ASP.NET 實作範例：

一般在實作資料庫存取，例如 ExecuteNonQuery()、ExecuteScalar()或 ExecuteReader()指令時，會利用 try-catch 處理例外，把確保要釋放的資源放在 finally 區段，以下為微軟的程式碼範例：
try
{
conn.Open();
cmdNewCustomer.ExecuteNonQuery();
this.holdCustomerID =
int)cmdNewCustomer.Parameters["@CustomerID"].Value;
this.displayCustomerID = Convert.ToString(holdCustomerID);
txtCustomerID.Text = displayCustomerID;
}
catch (SqlException ex)
{

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
        MessageBox.Show(ex.Message);
    }
    finally
    {
        conn.Close();
    }
```

或使用 using 指令方式進行資料庫連線存取，結束後會自動釋放相關資源，程式碼如下：

```
private static void CreateCommand(string queryString, string connectionString)
{
    using (SqlConnection connection = new SqlConnection(connectionString))
    {
        SqlCommand command = new SqlCommand(queryString, connection);
        command.Connection.Open();
        command.ExecuteNonQuery();
    }
}
```

參考連結：

- try-catch (C# 參考)
  https://docs.microsoft.com/zh-tw/dotnet/csharp/language-reference/keywords/try-catch
- 例外狀況和例外處理 (C# 程式設計手冊)
  https://docs.microsoft.com/zh-tw/dotnet/csharp/programming-guide/exceptions/
- try-catch-finally (C# 參考)
  https://docs.microsoft.com/zh-tw/dotnet/csharp/language-reference/keywords/try-catch-finally

本文件之智慧財產權屬數位發展部資通安全署擁有。

- 逐步解說：使用 ADO.NET 建立簡單資料應用程式
  https://msdn.microsoft.com/zh-tw/library/jj969619(v=vs.110).aspx
- SqlCommand.ExecuteNonQuery 方法()
  https://msdn.microsoft.com/zh-tw/library/system.data.sqlclient.sqlcommand.executenonquery(v=vs.110).aspx

Java 實作範例：

在 try-finally 語法中，在 finally 中釋放資源，範例如下：

```
try {
        conn = getConnection();// Any methodology to get connection.
        ps = conn.prepareStatement(sql);
        ps.setString(1, "This is parameter");
        rs = ps.executeQuery();
        while (rs.next()) {
            rs.getString(1);
        }
    } finally {
        try {
            rs.close();
            ps.close();
            conn.close();
        } catch (Exception e) {
            throw e;
        }
    }
```

參考連結：

- The try-with-resources Statement (The Java Tutorials > Essential Classes >

本文件之智慧財產權屬數位發展部資通安全署擁有。

Exceptions)

https://docs.oracle.com/javase/tutorial/essential/exceptions/tryResourceClose.html

PHP 實作範例：

PHP 有 try-catch 可以處理例外(Exceptions)，範例如下：

```
<?php
try {
   // do somethings
} catch (Exception $e) {
      echo 'Exception: ',    $e->getMessage(), "\n";
}
// Continue execution
echo 'Hello World';
?>
```

參考連結：

- PHP: CATCH - Manual

  http://php.net/manual/en/internals2.opcodes.catch.php
- PHP: Exceptions - Manual

  http://php.net/manual/en/language.exceptions.php
- PHP: rfc:finally

  https://wiki.php.net/rfc/finally

資料來源： 本計畫整理

4.5.3.3 具備系統嚴重錯誤之通知機制(例如電子郵件或簡訊)

本項目實作項目包含以下 1 項：

本文件之智慧財產權屬數位發展部資通安全署擁有。

●具備系統嚴重錯誤之通知機制(例如電子郵件或簡訊)。

– 相關實作建議，詳見表 71。

表69 安全系統發展生命週期開發階段-實作建議 6

適用分級			類別	實作項目
普	中	高		
		◎	安全系統發展生命週期開發階段	具備系統嚴重錯誤之通知機制(例如電子郵件或簡訊)
查核方式：☐自動化工具檢測　☒人工審查				
控制措施： 系統增加電子郵件或簡訊之通知機制，並就系統錯誤或例外狀況進行等級區分，當嚴重等級錯誤發生時，採用通知機制，使系統管理員或相關人員得以即時得知錯誤發生，進行後續處理。 **實作指導：** 當嚴重等級錯誤發生時，採用通知機制，使系統管理員或相關人員得以即時得知錯誤發生。				

資料來源： 本計畫整理

– 相關程式範例，詳見表 72。

表70 安全系統發展生命週期開發階段-程式範例 6

ASP.NET 實作範例：
▪若要設定 ASP.NET 應用程式傳送電子郵件 開啟應用程式的 Web.config 檔，並設定<system.net>區段內的<mailSettings>項目。<smtp>項目的 deliveryMethod 屬性(Attribute)中指定

本文件之智慧財產權屬數位發展部資通安全署擁有。

傳遞方法，並在<network>項目的 host 屬性中指定 SMTP 伺服器的名稱。此外，建議將 defaultCredentials 屬性設為 true (其他屬性可以使用，也會在項目相關的主題中進行說明)。組態設定範例如下：

```
<configuration xmlns="http://schemas.microsoft.com/.NetConfiguration/v2.0">
  <system.net>
    <mailSettings>
      <smtp deliveryMethod="Network">
      <network defaultCredentials="true"    host="smtpservername" /> </smtp>
</mailSettings>
  </system.net>
  <!-- Other configuration settings. -->
</configuration>
```

▪ 若要設定 SimpleMailWebEventProvider Web 事件提供者

於 Web.config 檔案內<system.web>區段的<healthMonitoring>項目內，加入新的<providers>項目。這個提供者包含在 ASP.NET 健康監視系統中，但未在根 Web.config 檔案中事先設定。組態設定範例如下：

```
<configuration>
  <system.web>
    <healthMonitoring enabled="true" heartbeatInterval="0">
      <providers>
        <add     name="exampleMailWebEventProvider"
type="System.Web.Management.SimpleMailWebEventProvider"
to="someone@xxxx.com"    from="someone@xxxx.com"    buffer="false"
subjectPrefix="WebEvent has fired" />
      </providers>
    </healthMonitoring>
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
  </system.web>
  <!-- Other configuration settings. -->
</configuration>
```

為了這個程序的目的，請藉由將 buffer 屬性設為 false 停用事件緩衝。name 屬性是任意的，它用於在下一步中識別提供者。將 to 和 from 屬性變更為自己的電子郵件地址，以完成在此程序中稍後的測試步驟。

在<healthMonitoring>項目內加入新的<rules>項目。這個新的 rules 項目會設定電子郵件提供者接聽所有 Web 事件。組態設定範例如下：

```
<configuration>
  <system.web>
    <healthMonitoring enabled="true" heartbeatInterval="0">
      <!-- <providers> element from the previous step -->
      <rules>
        <add name="Testing Mail Event Providers" eventName="All Events"
provider="exampleMailWebEventProvider" profile="Default" minInstances="1"
maxLimit="Infinite" minInterval="00:01:00" custom="" />
      </rules>
    </healthMonitoring>
  </system.web>
  <!-- Other configuration settings. -->
</configuration>
```

參考連結：

- HOW TO：傳送健康監視通知的電子郵件
  https://msdn.microsoft.com/zh-tw/library/ms227553(v=vs.100).aspx
- System.Net.Mail 命名空間
  https://msdn.microsoft.com/zh-tw/library/system.net.mail(v=vs.110).aspx

本文件之智慧財產權屬數位發展部資通安全署擁有。

▪ SMTP 電子郵件

https://technet.microsoft.com/zh-tw/library/hh831469(v=ws.11).aspx

Java 實作範例：

Java 可以使用 log4j 進行通知，設定範例如下。

```
<Configuration status="WARN">
<APPenders>
<SMTP name="SMTPMeiler" subject="Error log" bufferSize="1"
to="admin@example.org.tw" from="system@example.org.tw"
smtpHost="smtp.example.org.tw"
smtpPort="465" smtpProtocol="smtps" smtpUsername="system@example.org.tw"
smtpPassword="ChangeIt">
<PatternLayout>
<pattern> %d{yyyy-MM-dd HH:mm:ss.SSS} [%t] %-5p %c %L - %m%n </pattern>
</PatternLayout>
</SMTP>
</APPenders>
<Loggers>
<Root level="error">
<AppenderRef ref="SMTPMailer"/>
</Root>
</Loggers>
</Configuration>
```

參考連結：

▪ org.apache.log4j.net - Class SMTPAppender

https://logging.apache.org/log4j/1.2/apidocs/org/apache/log4j/net/SMTPApp

本文件之智慧財產權屬數位發展部資通安全署擁有。

ender.html

PHP 實作範例：

PHP 本身有 mail 函式可以使用，範例如下：

```
<?php
$to = 'nobody@example.com';
$subject = 'the subject';
$message = 'hello';
$headers = 'From: webmaster@example.com' . "\r\n" .
    'Reply-To: webmaster@example.com' . "\r\n" .
    'X-Mailer: PHP/' . phpversion();
mail($to, $subject, $message, $headers);
?>
```

也可以使用 PHPMailer 寄送通知信，範例如下：

```
<?php
 include("PHPMailer/class.phpmailer.php"); //匯入 PHPMailer 類別

    $mail= new PHPMailer();          //建立新物件
    $mail->IsSMTP();                 //設定使用 SMTP 方式寄信
    $mail->SMTPAuth = true;          //設定 SMTP 需要驗證
    $mail->SMTPSecure = "tls";       // Gmail 的 SMTP 主機需要使用 TLS 連線
    $mail->Host = "smtp.gmail.com"; //Gamil 的 SMTP 主機
    $mail->Port = 465;                 //Gamil 的 SMTP 主機的 SMTP 埠位為 465 埠。
    $mail->CharSet = "big5";           //設定郵件編碼
    $mail->Username = "**********";   //Gmail 帳號
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
    $mail->Password = "*********";   //Gmail 密碼
    $mail->From = "xxxx@gmail.com"; //設定寄件者信箱
    $mail->FromName = "XXXX ";       //設定寄件者姓名
    $mail->Subject = "測試信件";        //設定郵件標題
    $mail->Body = "這是一封測試信件! ";  //設定郵件內容
    $mail->IsHTML(true);                  //設定郵件內容為 HTML
    $mail->AddAddress("xxxx@gmail.com", "xxxx"); //設定收件者郵件及名稱
    if(!$mail->Send()) {
        echo "Mailer Error: " . $mail->ErrorInfo;
    }
    else {
        echo "Message sent!";
    }
?>
```

參考連結：

- mail
  http://php.net/manual/en/function.mail.php
- PHPMailer
  https://sourceforge.net/projects/phpmailer/
- PHPMailer
  https://github.com/PHPMailer/PHPMailer

資料來源： 本計畫整理

本文件之智慧財產權屬數位發展部資通安全署擁有。

4.5.3.4 HTTP 安全標頭防護與設定

本項目實作項目包含以下 1 項：

- 於網站伺服器回應 HTTP 請求時附加 HTTP 安全標頭(HTTP Security Headers)控制項，協助瀏覽器實施一系列安全政策，減少常見攻擊風險。
  - HTTP 安全標頭(HTTP Security Headers)詳細介紹與說明可參考附件 3. HTTP 安全標頭防護設定
  - 相關實作建議，詳見表 71。

表71 安全系統發展生命週期開發階段-實作建議 7

適用分級			類別	實作項目
普	中	高		
	◎	◎	安全系統發展生命週期開發階段	於網站伺服器於回應 HTTP 請求時附加安全性控制項
查核方式：☒自動化工具檢測　☒人工審查				
控制措施： 於網站伺服器回應 HTTP 請求時附加 HTTP 安全標頭(HTTP Security Headers)控制項，協助瀏覽器實施一系列安全政策，減少常見攻擊風險。 **實作指導：** 依系統網站實際之架構與設計考量，添加設定並調整 6 個關鍵的 HTTP Security Headers 及值，以大幅提高網站抵禦常見攻擊（如 XSS、Clickjacking、MIME 混淆、流量竊聽等）的能力，包含以下六個安全性優先級較高的 Response Header（Content-Security-Policy、HTTP Strict-Transport-Security、X-Content-Type-Options、X-Frame-				

本文件之智慧財產權屬數位發展部資通安全署擁有。

Options、Referrer-Policy、Permissions-Policy）。

補充建議：

若 HTTP 回應標頭中的 Content-Security-Policy (CSP) 設定不完整或僅部分實作，安全掃描工具進行自動化分析時，可能會基於保守假設而判定潛在風險，進一步產生過度的風險評估結果。這類情況常見於僅設定部分資源限制（例如 default-src 未明確定義或缺少對特定來源的控管），導致工具誤以為應用程式允許來自任意來源的內容載入。

因此，CSP 應依實際應用架構與需求進行完整且明確的設定，以平衡安全防護需求、系統正常運行與誤報風險。在實務上，若系統運作環境或資安稽核結果顯示 CSP 不完整僅屬設計考量而非漏洞，則可視具體情況調整或補充設定，以避免系統無法正常運行或安全掃描工具產生不必要的高風險判定。詳細介紹與說明可參考附件 3. HTTP 安全標頭防護設定。

資料來源： 本計畫整理

– 相關程式範例，詳見表 72。

表72 安全系統發展生命週期開發階段-程式範例 6

ASP.NET 實作範例：
▪若要設定 ASP.NET 應用程式 6 個關鍵的 HTTP Security Headers 及值開啟應用程式的 Web.config 檔，並設定< system.webServer >區段內的 < httpProtocol >下< customHeaders > 項目。透過<add name=" " value=" " />添加 6 個關鍵的 HTTP Security Headers 及值，並視專案實際情況強化安全屬性及值。組態設定範例如下： <configuration> <system.webServer> <httpProtocol> <customHeaders>

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
            <add name="X-Frame-Options" value="DENY" />
            <add name="Strict-Transport-Security" value="max-age=31536000;
includeSubDomains" />
            <add name="Content-Security-Policy" value="script-src 'self' 'unsafe-inline'
'unsafe-eval'" />
            <add name="X-Content-Type-Options" value="nosniff" />
            <add name="Referrer-Policy" value="strict-origin-when-cross-origin" />
            <add name="Permissions-Policy" value="camera=(), microphone=(),
geolocation=(self), fullscreen=(self)" />
        </customHeaders>
    </httpProtocol>
  </system.webServer>
</configuration>
```

Java 實作範例：

在遵循 Java Servlet 規範的應用伺服器（如 Tomcat、Jetty、WebSphere、WebLogic）上，最簡潔、可重用的做法是使用 Servlet Filter 並註冊啟用於服務器中(web.xml)，於回應階段統一加入安全標頭，設定範例如下。

```
public class CommonHeader implements Filter {

  @Override
  public void doFilter(ServletRequest request, ServletResponse response, FilterChain
chain)
throws IOException, ServletException {

    HttpServletRequest req = (HttpServletRequest) request;
    HttpServletResponse res = (HttpServletResponse) response;

    res.setHeader("X-Frame-Options", "DENY");
    res.setHeader("Strict-Transport-Security", "max-age=31536000;
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
includeSubDomains");
        res.setHeader("Content-Security-Policy", "script-src 'self' 'unsafe-inline' 'unsafe-
eval'");
        res.setHeader("X-Content-Type-Options", "nosniff");
        res.setHeader("Referrer-Policy", "strict-origin-when-cross-origin");
        res.setHeader("Permissions-Policy", "camera=(), microphone=(), geolocation=(self),
fullscreen=(self)");

        chain.doFilter(request, response);

    }

}
```

PHP 實作範例：

使用共用的 PHP「前置載入檔」 (bootstrap / common include)添加安全標頭，範例如下：

```
<?php
function set_common_headers() {
        header("X-Frame-Options: DENY");
        header("Strict-Transport-Security: max-age=31536000; includeSubDomains");
        header("Content-Security-Policy: script-src 'self' 'unsafe-inline' 'unsafe-eval'");
        header("X-Content-Type-Options: nosniff");
        header("Referrer-Policy: strict-origin-when-cross-origin");
        header("Permissions-Policy: camera=(), microphone=(), geolocation=(self),
fullscreen=(self)");
}
set_common_headers();
```

資料來源： 本計畫整理

本文件之智慧財產權屬數位發展部資通安全署擁有。

4.5.4 安全系統發展生命週期測試階段(Secure System Development Life Cycle-Test)

安全系統發展生命週期測試階段類別之控制措施包含以下 2 項：

●執行「弱點掃描」安全檢測。

●執行「滲透測試」安全檢測。

與系統發展生命週期測試階段控制措施相關的應用程式技術面實作建議與範例，詳見表 73。

表73 安全系統發展生命週期測試階段-實作建議與範例

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	安全系統發展生命週期測試階段	(1)執行「弱點掃描」安全檢測。 (2)執行「滲透測試」安全檢測。(適用於高等級)
查核方式：☒自動化工具檢測　☒人工審查				
控制措施： (1)執行「弱點掃描」安全檢測。 (2)執行「滲透測試」安全檢測。 **實作指導：** 弱點掃描是使用自動化工具針對目標進行安全性弱點檢測，以找出網路與主機可能存在的安全弱點。滲透測試則是委由專業的資安人員模擬駭客手法對受測目標進行入侵攻擊，故除了會進行弱點掃描外，還可進一步針對發現之弱點進行利用，故攻擊手法更為多元。				
實作範例：				

本文件之智慧財產權屬數位發展部資通安全署擁有。

可使用著名的弱點掃描或滲透測試工具進行檢測，例如：Acunetix Web Vulnerability Scanner, HP WebInspect, Nessus, OpenVAS 等。

參考連結：

- Acunetix Web Vulnerability Scanner (AWVS)
  https://www.acunetix.com/vulnerability-scanner/
- HP WebInspect
  https://saas.hpe.com/en-us/software/webinspect
- Nessus Vulnerability Scanner
  https://www.tenable.com/products/nessus-vulnerability-scanner
- OpenVAS - Open Vulnerability Assessment System
  http://www.openvas.org/

資料來源： 本計畫整理

4.5.5 安全系統發展生命週期部署與維運階段(Secure System Development Life Cycle-Deployment and Maintenance)

安全系統發展生命週期部署與維運階段類別之控制措施包含以下 3 項：

- 在部署環境中應針對相關資安威脅，進行更新與修補，並關閉不必要服務及埠口(Port)。
- 資訊系統相關軟體，不使用預設或空的密碼。
- 在系統發展生命週期之維運階段需要注重版本控制與變更管理。

與系統發展生命週期部署與維運階段控制措施相關的應用程式技術面項目，整理如下：

4.5.5.1 在部署環境中應針對相關資安威脅，進行更新與修補，並關閉不必要服務及埠口(Port)

本項目實作項目包含以下 2 項：

本文件之智慧財產權屬數位發展部資通安全署擁有。

●作業平台定期更新並關閉不必要服務及埠口(Port)。

– 相關實作建議，詳見表 74。

表74 安全系統發展生命週期部署與維運階段-實作建議 1

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	安全系統發展生命週期部署與維運階段	作業平台定期更新並關閉不必要服務及埠口(Port)
查核方式：☐自動化工具檢測　☒人工審查				
控制措施： 就作業系統或平台之安全更新，定期評估、測試與更新。系統上線前，就作業系統或平台預設開啟的服務與埠口進行檢視與評估，盡可能關閉不必要之項目，並正面表列需要開啟該服務及埠口之理由。 **實作指導：** 讓作業系統自動檢查和更新。 對於 Web 應用程式伺服器(例如 Apache)，亦應移除不需要使用之元件，例如 Apache 啟動後預設啟動若干 DSO (Dynamic Shared Object)模組，建議可移除非必要之 DSO 模組。				

資料來源： 本計畫整理

– 相關實作範例，詳見表 75。

表75 安全系統發展生命週期部署與維運階段-實作範例 1

Microsoft Windows 實作範例：

本文件之智慧財產權屬數位發展部資通安全署擁有。

開啟 Microsoft Windows Update 功能，讓作業系統自動檢查和更新。 對於系統使用之軟體或套件，定期評估、測試與更新。 可使用 netstat 指令查詢埠口開放情況，並設定防火牆規則以阻擋非必要開放的埠口。
CentOS 7 實作範例：
在系統排程檔案/etc/crontab 中，設定每天定時執行 yum -y update 更新所有安裝使用中的套件。 使用 firewalld 指令，關閉或開啟 port。 參考連結： ▪ 35.1.1. Configuring Cron Tasks - CentOS Project https://www.centos.org/docs/5/html/5.2/Deployment_Guide/s2-autotasks-cron-configuring.html ▪ Firewalld - FedoraProject https://fedoraproject.org/wiki/Firewalld?rd=FirewallD

資料來源： 本計畫整理

●針對系統依賴的外部元件或軟體，注意其安全漏洞通告，定期評估更新。

– 相關實作建議與範例，詳見表 76。

表76 安全系統發展生命週期部署與維運階段-實作建議與範例 2

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	安全系統發	針對系統依賴的外部元件或軟體，注意其

本文件之智慧財產權屬數位發展部資通安全署擁有。

			展生命週期部署與維運階段	安全漏洞通告，定期評估更新

查核方式：☐自動化工具檢測　☒人工審查

控制措施：

對系統所使用的外部元件與軟體進行表列，包含其版本資訊。注意相關之安全漏洞通告(透過 CVE Details 網站、廠商安全通告等)，於系統驗收前確認採用之軟體與元件，已使用最新之穩定版本或該版本已排除所有已知安全漏洞。系統上線後，持續定期關注安全漏洞通告，若有相關之安全漏洞發生，評估該系統元件更新之必要性，於系統測試環境進行更新測試驗證後，才於正式環境進行更新。

實作指導：

持續定期關注安全漏洞通告，若有相關之安全漏洞發生，評估該系統元件更新之必要性，於系統測試環境進行更新測試驗證後，才於正式環境進行更新。

實作範例：

注意 Microsoft Security Alert 網站，定期檢視評估元件更新之必要性，重要服務應於測試環境評估完畢後再行更新。

相關資訊：

- Microsoft Security Alert
  http://technet.microsoft.com/zh-tw/security/dn530791
- CVE
  http://cve.mitre.org/cve/
- Bugtraq
  http://www.us-cert.gov/ncas/alerts/

資料來源： 本計畫整理

本文件之智慧財產權屬數位發展部資通安全署擁有。

4.5.5.2 資訊系統相關軟體，不使用預設或空的密碼

本項目實作項目包含以下 1 項：

●系統依賴的外部元件或軟體，不使用預設或空的密碼。

– 相關實作建議，詳見表 77。

表77 安全系統發展生命週期部署與維運階段-實作建議 3

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	安全系統發展生命週期部署與維運階段	系統依賴的外部元件或軟體，不使用預設或空的密碼
查核方式：☐自動化工具檢測　☒人工審查				
控制措施： 表列系統所使用的外部元件與軟體，包含其版本資訊，並檢核確認未有使用預設密碼之情況。 **實作指導：** 表列系統所使用的外部元件與軟體，包含其版本資訊，並檢核確認未有使用預設或空的密碼之情況。				

資料來源： 本計畫整理

– 相關程式範例，詳見表 78。

表78 安全系統發展生命週期部署與維運階段-程式範例 3

MySQL 實作範例：

本文件之智慧財產權屬數位發展部資通安全署擁有。

MySQL 安裝後，預設帳號為 sa，預設密碼為空，變更方法如下：

MySQL 5.7.6 和之後版本

```
shell> mysql
mysql> ALTER USER 'root'@'localhost' IDENTIFIED BY 'MyNewPass';
mysql> FLUSH PRIVILEGES;
```

MySQL 5.7.5 和早期版本

```
shell> mysql
mysql> SET PASSWORD FOR 'root'@'localhost' = PASSWORD('MyNewPass');
mysql> FLUSH PRIVILEGES;
```

參考連結：

- MySQL :: MySQL 5.7 Reference Manual :: B.5.3.2 How to Reset the Root Password
  https://dev.mysql.com/doc/refman/5.7/en/resetting-permissions.html

資料來源： 本計畫整理

4.5.6 安全系統發展生命週期委外階段(Secure System Development Life Cycle-Outsourcing)

安全系統發展生命週期委外階段之控制措施包含：

- 資訊系統開發若委外服務應將系統發展生命週期各階段依安全等級將安全需求納入委外合約。

與系統發展生命週期委外階段控制措施相關的應用程式技術面實作建議，詳見表 79。

表79 安全系統發展生命週期委外階段-實作建議

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	安全系統發	資訊系統開發若委外服務應將系統發展生

本文件之智慧財產權屬數位發展部資通安全署擁有。

			展生命週期委外階段	命週期各階段依安全等級將安全需求納入委外合約。
查核方式：☐自動化工具檢測　☒人工審查				
控制措施： 資訊系統開發若委外服務應將系統發展生命週期各階段依安全等級將安全需求(含機密性、可用性、完整性)納入委外合約。 **實作指導：** 建議可參照技服中心所發布的「資訊系統委外開發 RFP 資安需求範本」，擷取及發展資訊系統適用之安全需求，並納入於委外合約內。				
實作範例：無，請參考實作指導。				

資料來源： 本計畫整理

4.5.7 獲得程序(Acquisition Process)

獲得程序之控制措施包含：

●開發、測試以及正式作業環境應作區隔。

與獲得程序控制措施相關的應用程式技術面實作建議，詳見表 80。

表80 獲得程序-實作建議

適用分級			類別	實作項目
普	中	高		
	◎	◎	獲得程序	開發、測試以及正式作業環境應作區隔。
查核方式：☐自動化工具檢測　☒人工審查				

本文件之智慧財產權屬數位發展部資通安全署擁有。

控制措施： (1)開發、測試以及正式作業環境應作區隔。 **實作指導：** 開發環境、測試環境與正式作業環境可區隔成不同的網段，限制所能存取的應用程式及資料庫，以保護正式作業環境系統及資料。
實作範例：環境隔離
開發人員以本機電腦為開發環境，並連結使用本機端之資料庫進行 Web 應用程式開發。待開發完畢則將 Web 應用程式部署至測試主機，並連結至測試用資料庫，供測試人員進行測試使用。待測試完畢，再將 Web 應用程式部署至正式環境，並連結至正式資料庫提供上線服務。

資料來源： 本計畫整理

4.5.8 資訊系統文件(Information System Documentation)

資訊系統文件之控制措施包含：

●應儲存與管理系統發展生命週期之相關文件。

與獲得程序控制措施相關的應用程式技術面實作建議，詳見表 81。

表81 資訊系統文件-實作建議與範例

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	資訊系統文件	應儲存與管理系統發展生命週期之相關文件。
查核方式：☐自動化工具檢測 ☒人工審查				
控制措施：				

本文件之智慧財產權屬數位發展部資通安全署擁有。

應儲存與管理系統發展生命週期之相關文件。 **實作指導：** 以書面或電子化形式進行文件保存，例如可建立系統專案用軟體發展目錄，儲存應被納入建構管理的系統發展生命週期之相關文件及建構項目。
實作範例：相關文件包含軟體需求規格書、系統規格書、軟體發展計畫、軟體測試計畫、軟體測試報告、使用手冊、維護手冊等。

資料來源： 本計畫整理

4.6 系統與通訊保護(System and Communications Protection)

系統與通訊保護分為「傳輸之機密性與完整性」以及「資料儲存之安全」等 2 項控制措施，說明如下。

4.6.1 傳輸之機密性與完整性(Transmission Confidentiality and Integrity)

傳輸之機密性與完整性類別之控制措施包含以下 2 項：

- 傳輸過程中除非有其他替代之實體保護措施，否則資訊系統應採用加密機制以防止未授權之資訊揭露或偵測資訊之變更。
- 避免使用已遭破解之加密演算法。

傳輸之機密性與完整性控制措施相關的應用程式技術面項目，整理如下：

4.6.1.1 傳輸過程中除非有其他替代之實體保護措施，否則資訊系統應採用加密機制以防止未授權之資訊揭露或偵測資訊之變更

本項目實作項目包含以下 1 項：

- 機敏資料傳輸時，採用加密機制。

  – 相關實作建議，詳見表 82。

本文件之智慧財產權屬數位發展部資通安全署擁有。

表82 傳輸之機密性與完整性-實作建議 1

適用分級			類別	實作項目
普	中	高		
	◎	◎	遠端存取	機敏資料傳輸時，採用加密機制
查核方式：☐自動化工具檢測 ☒人工審查				
控制措施： 網站傳輸機敏資料時，採用 HTTPS(透過 TLS 加密協定)協定以確保機敏資料以密文方式傳輸。 **實作指導：** 於網站安裝支援 HTTPS 之模組或套件。				

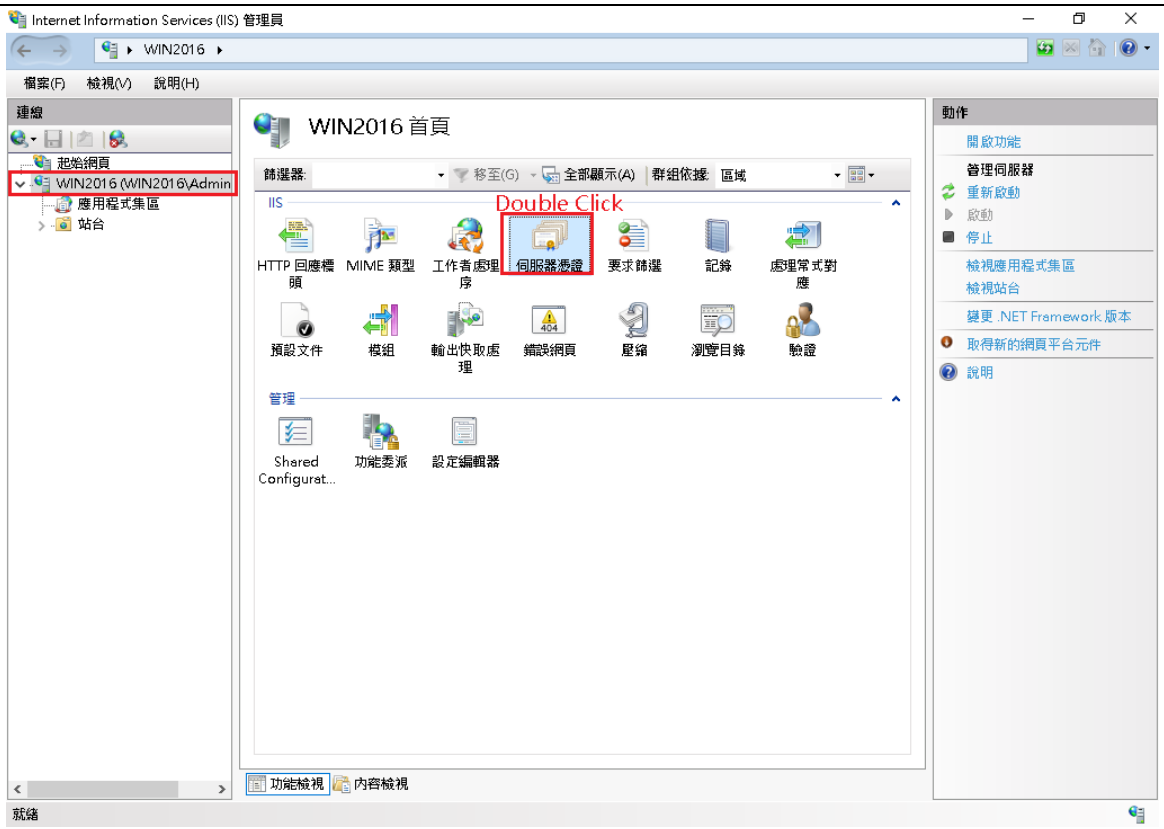
資料來源： 本計畫整理

– 相關實作範例，詳見表 83。

表83 傳輸之機密性與完整性-實作範例 1

IIS 實作範例：
Microsoft Windows 目前都內建 IIS (網頁伺服器，Internet Information Services)，而且支援 HTTPS 。讓 IIS 支援 HTTPS，首先要申請建立伺服器憑證，如果是偏向自己單位內部使用的，可以考慮自簽憑證，步驟詳見圖 24 至圖 30 。 在 IIS 管理員點選左邊主機名稱，在右邊畫面「伺服器憑證」上快按兩下，畫面詳見圖 24。

本文件之智慧財產權屬數位發展部資通安全署擁有。

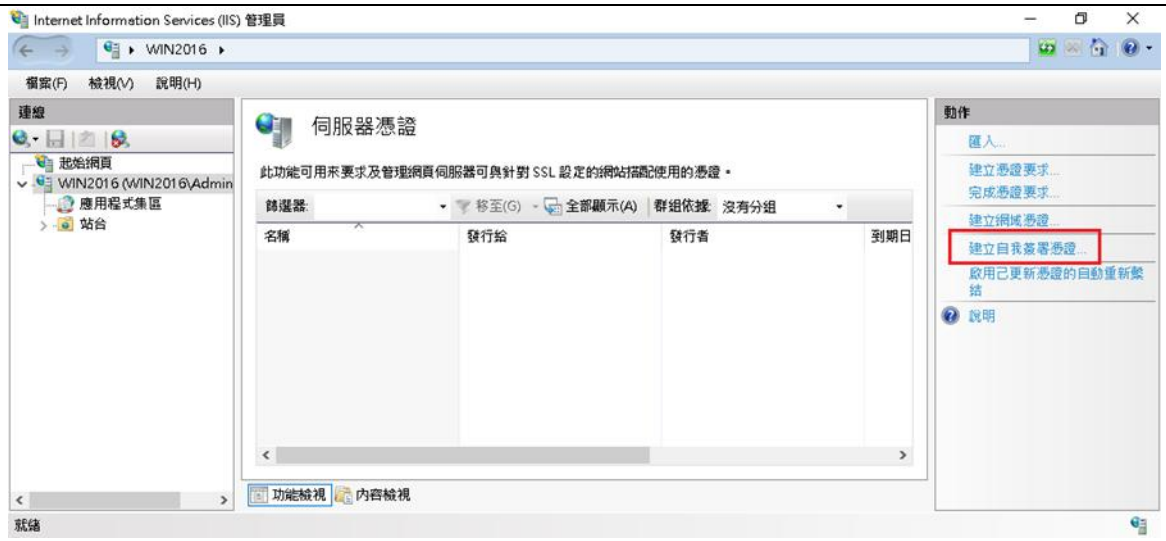


資料來源：本計畫整理

圖24 Windows Server 2016 IIS 安裝 HTTPS 支援圖 1

點選畫面右邊「自我簽署憑證」，畫面詳見圖 25。

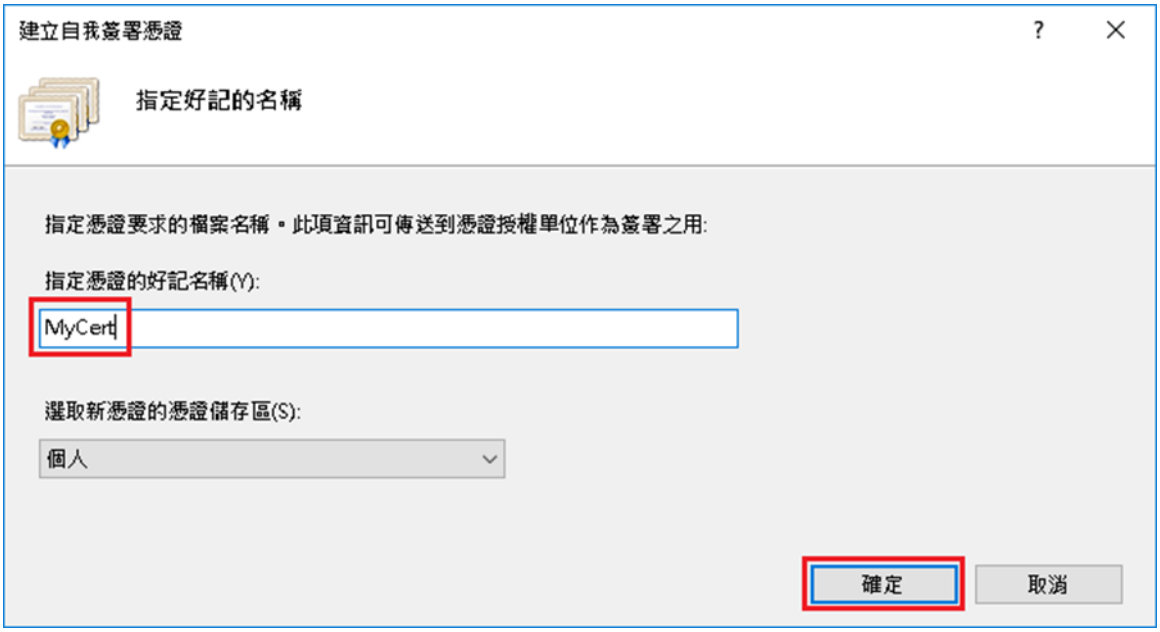
本文件之智慧財產權屬數位發展部資通安全署擁有。



資料來源：本計畫整理

圖25 Windows Server 2016 IIS 安裝 HTTPS 支援圖 2

設定憑證名稱，畫面詳見圖 26。



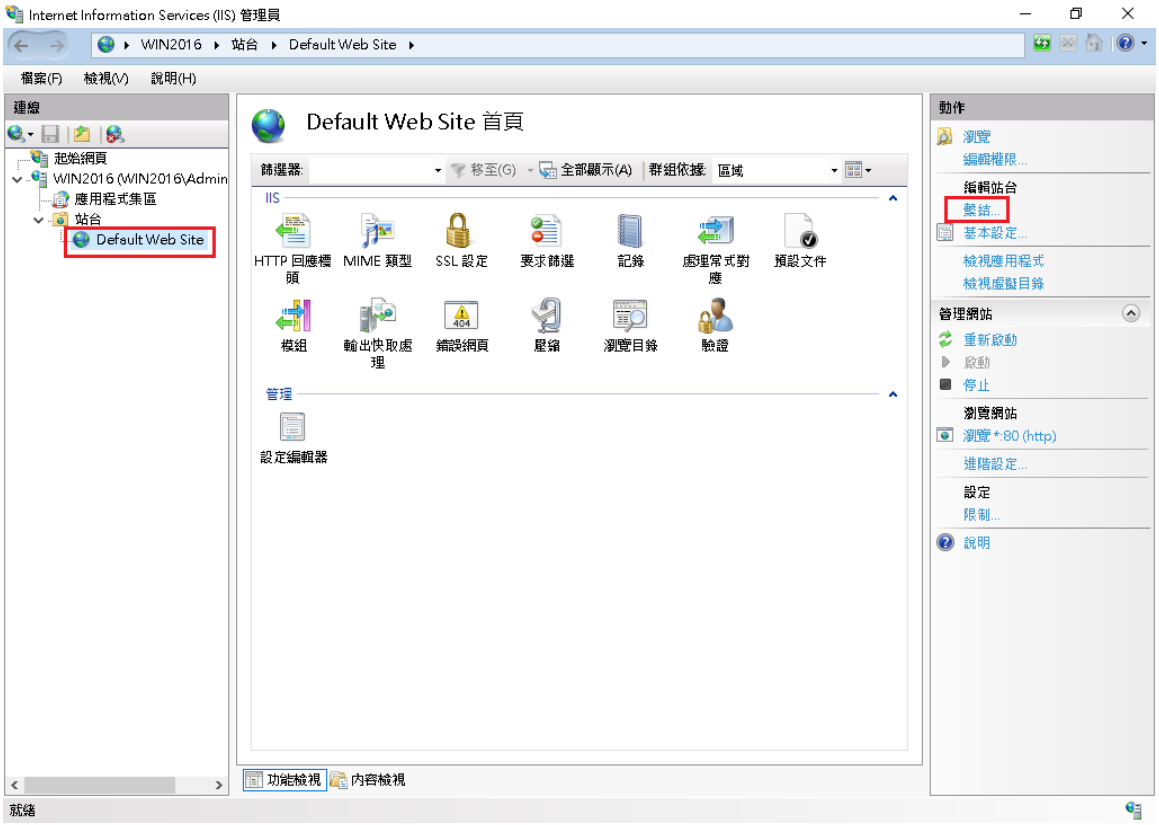
資料來源：本計畫整理

圖26 Windows Server 2016 IIS 安裝 HTTPS 支援圖 3

點選畫面左邊要支援 HTTPS 的站台，點選畫面右邊「繫結」，畫面詳見

本文件之智慧財產權屬數位發展部資通安全署擁有。

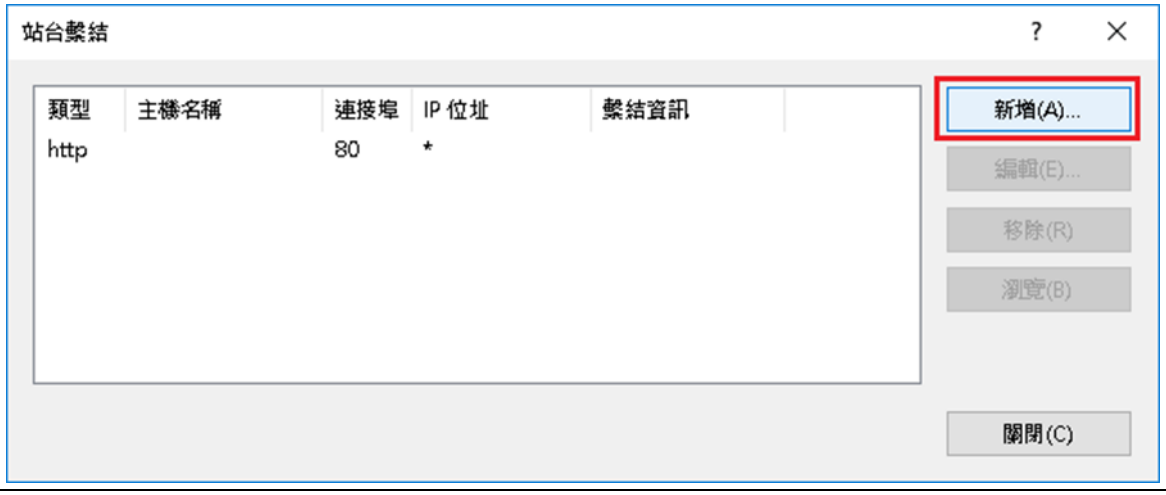
圖 27。



資料來源：本計畫整理

圖27 Windows Server 2016 IIS 安裝 HTTPS 支援圖 4

按下「新增」按鈕，畫面詳見圖 28。

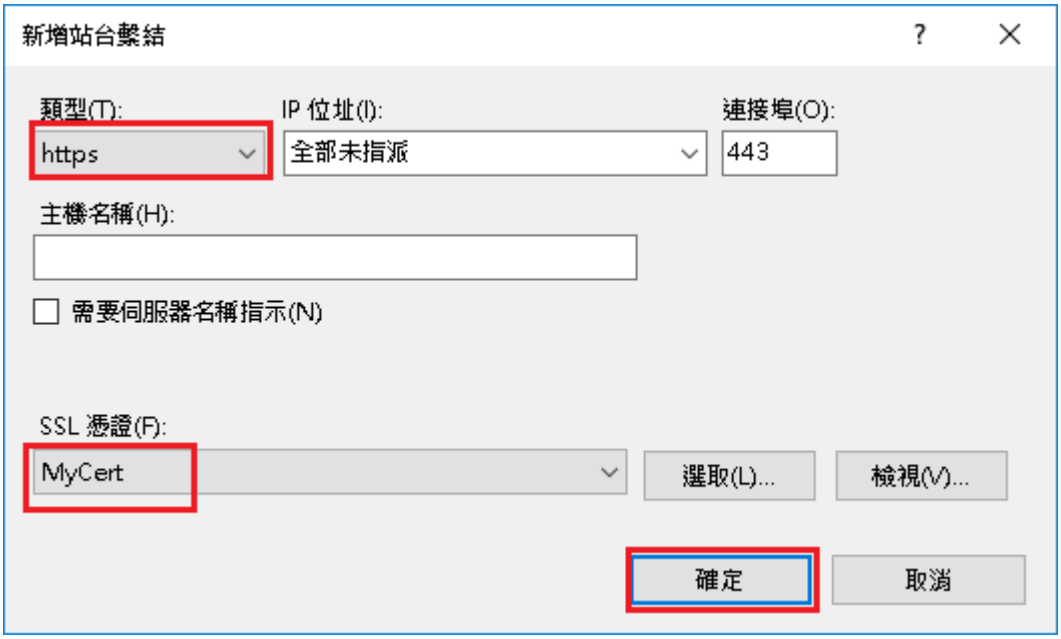


本文件之智慧財產權屬數位發展部資通安全署擁有。

資料來源：本計畫整理

圖28 Windows Server 2016 IIS 安裝 HTTPS 支援圖 5

「類型」選擇 https，「SSL 憑證」選擇剛剛建立的憑證，按下「確定」按鈕，畫面詳見圖 29。



資料來源：本計畫整理

圖29 Windows Server 2016 IIS 安裝 HTTPS 支援圖 6

按下「關閉」按鈕，畫面詳見圖 30。

本文件之智慧財產權屬數位發展部資通安全署擁有。



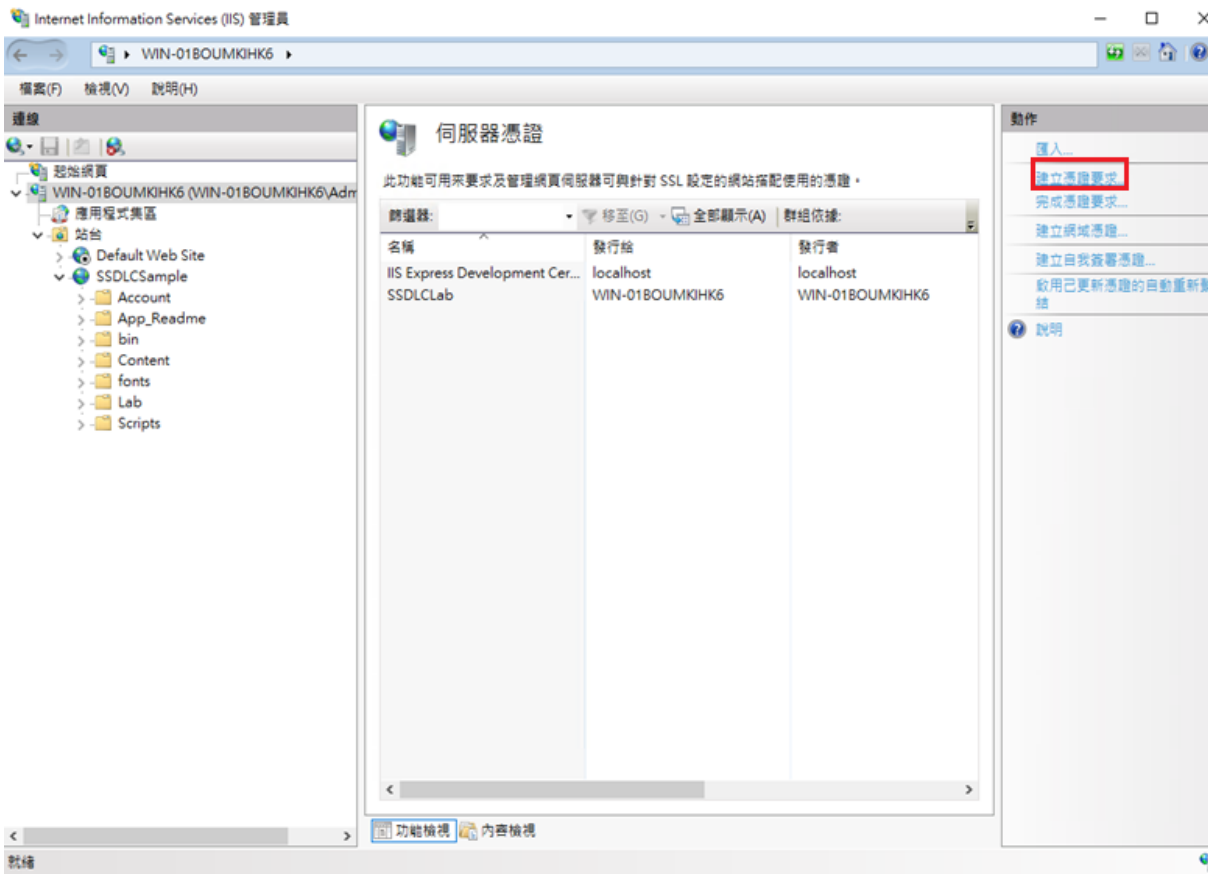
資料來源：本計畫整理

圖30 Windows Server 2016 IIS 安裝 HTTPS 支援圖 7

公開使用的網站可考慮使用「建立憑證要求」申請憑證使用，畫面詳見圖 31 至圖 36。

在 IIS 管理員，點選畫面右邊「建立憑證要求」，畫面詳見圖 31。

本文件之智慧財產權屬數位發展部資通安全署擁有。

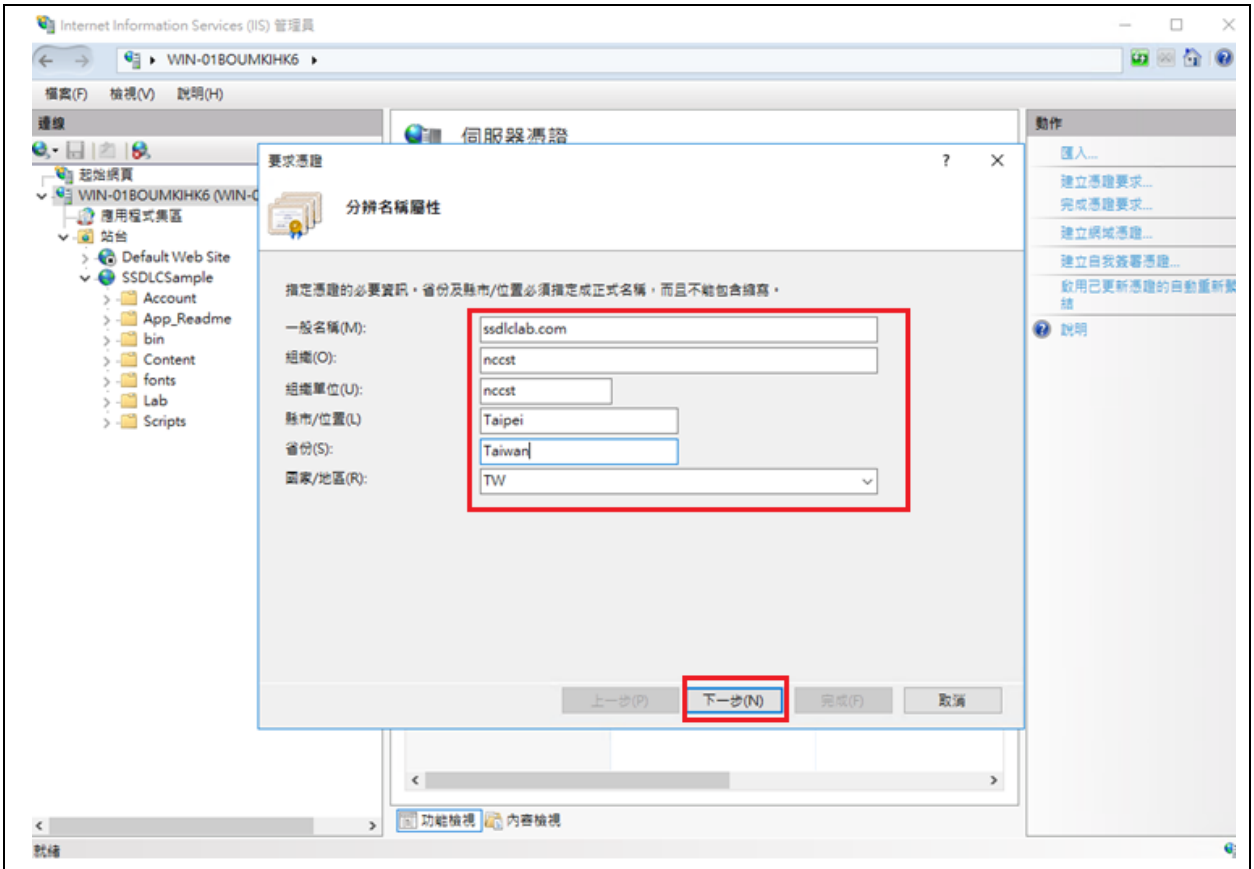


資料來源：本計畫整理

圖31 Windows Server 2016 IIS 建立憑證要求圖 1

輸入憑證相關資訊，按下「下一步」按鈕，畫面詳見圖 32。

本文件之智慧財產權屬數位發展部資通安全署擁有。

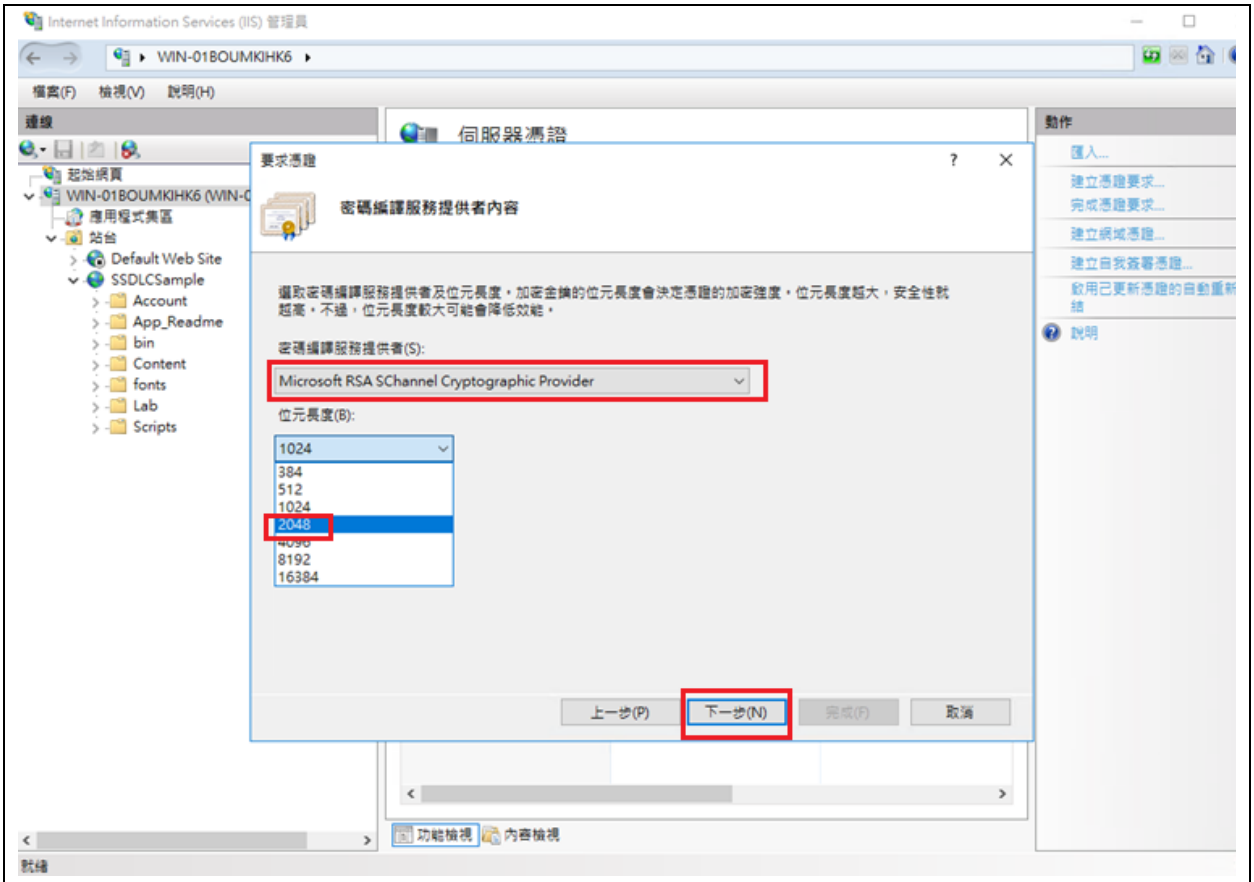


資料來源：本計畫整理

圖32 Windows Server 2016 IIS 建立憑證要求圖 2

設定提供者和位元長度，畫面詳見圖 33。

本文件之智慧財產權屬數位發展部資通安全署擁有。

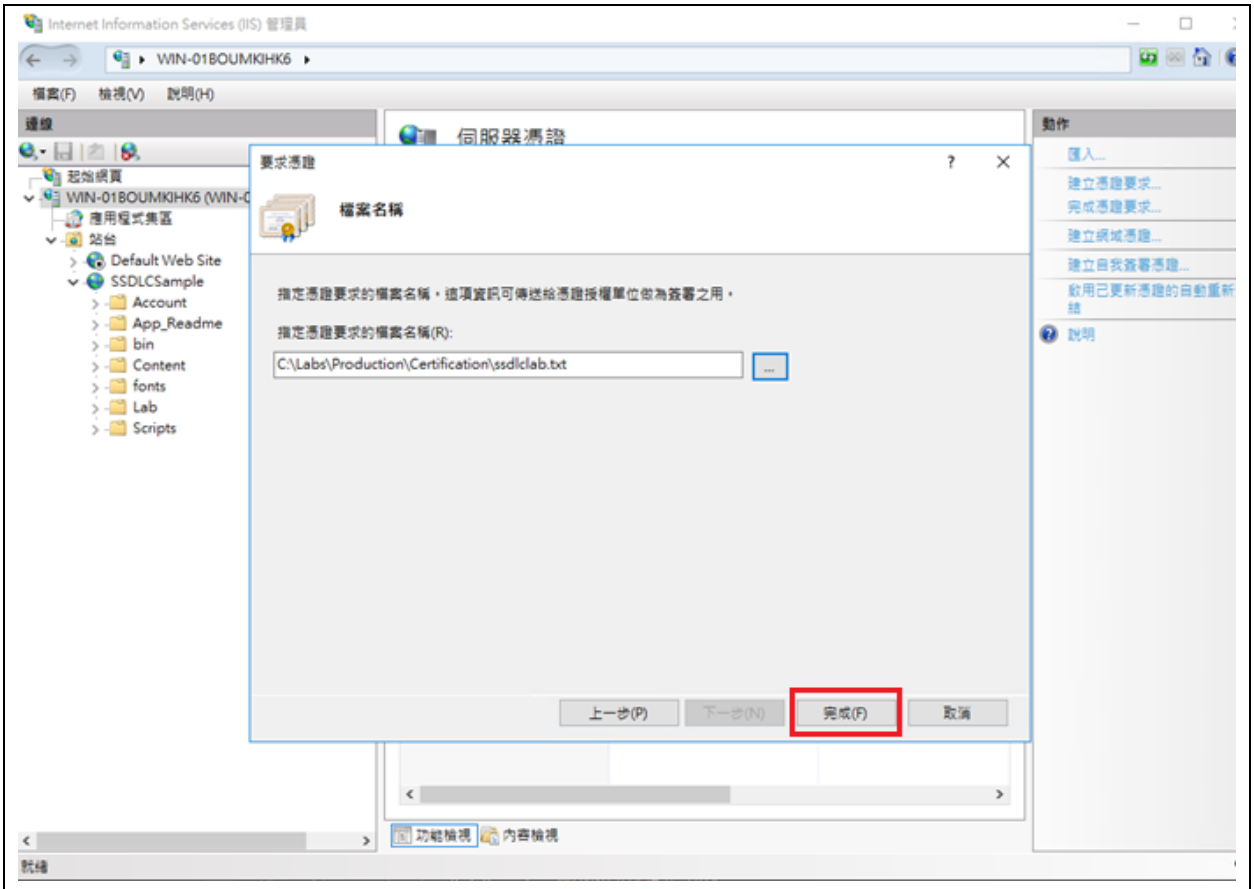


資料來源：本計畫整理

圖33 Windows Server 2016 IIS 建立憑證要求圖 3

按下「完成」按鈕，畫面詳見圖 34。

本文件之智慧財產權屬數位發展部資通安全署擁有。

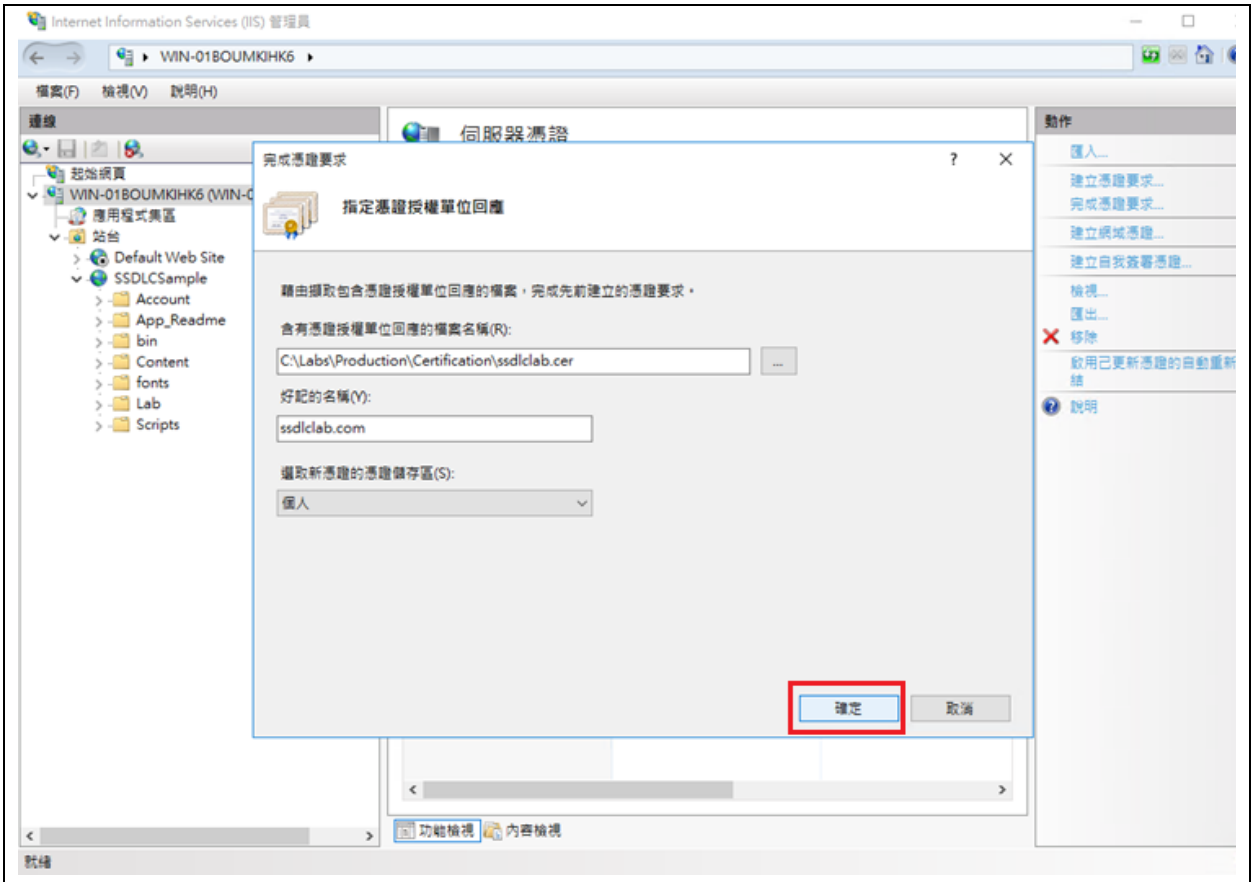


資料來源：本計畫整理

圖34 Windows Server 2016 IIS 建立憑證要求圖 4

按下「建立」按鈕，畫面詳見圖 35。

本文件之智慧財產權屬數位發展部資通安全署擁有。

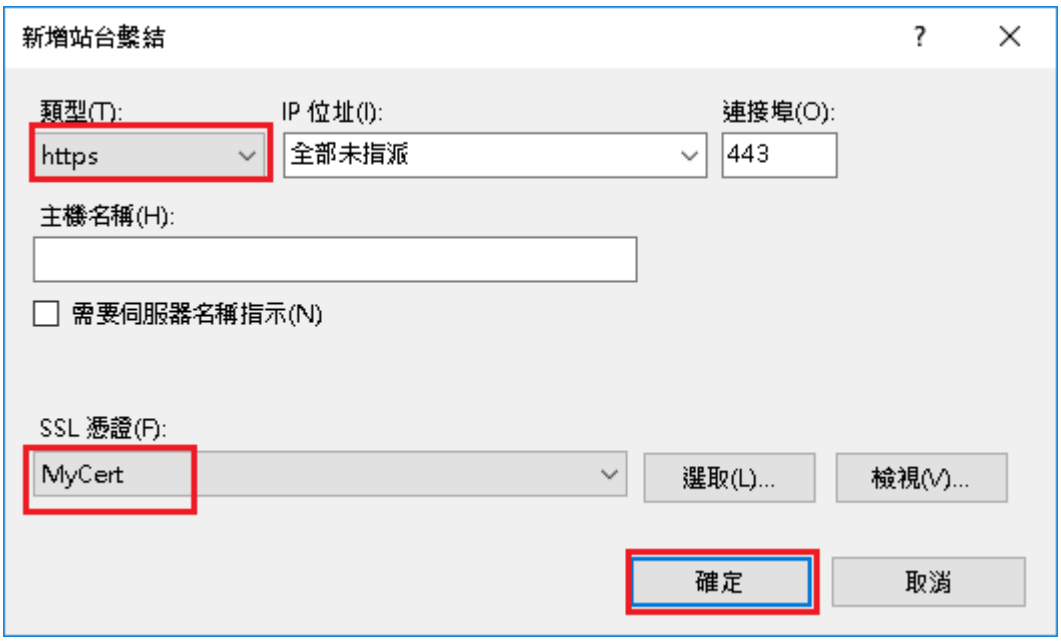


資料來源：本計畫整理

圖35 Windows Server 2016 IIS 建立憑證要求圖 5

要求送出後，等待憑證管理員審核和提供憑證，按照之前的步驟，「SSL 憑證」改選擇申請得到憑證，畫面詳見圖 36。

本文件之智慧財產權屬數位發展部資通安全署擁有。



資料來源：本計畫整理

圖36 Windows Server 2016 IIS 建立憑證要求圖 6

依照上述步驟設定後，IIS 即具備 HTTPS 連線加密能力。

參考連結：

- 在 IIS 上建置 ASP.NET 網站
  https://technet.microsoft.com/zh-tw/library/hh831550(v=ws.11).aspx
- 如何設定 IIS 中 HTTPS 服務
  https://support.microsoft.com/zh-tw/help/324069/how-to-set-up-an-https-service-in-iis
- 購買與安裝 SSL 憑證完全攻略(以 IIS 7.0 為例)
  https://technet.microsoft.com/zh-tw/ff469731.aspx

Java 實作範例：

在 Java 網站中，可以利用 server.xml 中的設定，設定加密連線及使用的憑證。

<Connector

本文件之智慧財產權屬數位發展部資通安全署擁有。

protocol="org.apache.coyote.http11.Http11NioProtocol"

port="443" maxThreads="200“

scheme="https" secure="true" SSLEnabled="true"

keystoreFile="%HOME%/.keystore" keystorePass="changeit"

sslProtocol="TLSv1.2" sslEnabledProtocols="TLSv1.1,TLSv1.2"

clientAuth="false“

ciphers=“TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA,

TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA,

TLS_RSA_WITH_AES_256_CBC_SHA,

TLS_RSA_WITH_AES_128_CBC_SHA”/>

參考連結：

- Elements in server.xml

  https://docs.oracle.com/middleware/1221/otd/cfrref/elements_server.htm

PHP 實作範例：

AppServ 是一套整合 Apache Web Server、PHP、MySQL，支援 HTTPS 加密連線、運行於 Microsoft Windows 的軟體，安裝完成後 Apache Web Server 即支援 HTTPS 連線加密。

參考連結：

- AppServ

  https://www.appserv.org/en/

資料來源： 本計畫整理

4.6.1.2 避免使用已遭破解之加密演算法

本項目實作項目包含以下 1 項：

本文件之智慧財產權屬數位發展部資通安全署擁有。

●使用公開、國際機構驗證且未遭破解的演算法。

– 相關實作建議，詳見表 84。

表84 傳輸之機密性與完整性-實作建議 2

適用分級			類別	實作項目
普	中	高		
		◎	傳輸之機密性與完整性	使用公開、國際機構驗證且未遭破解的演算法
查核方式：☐自動化工具檢測　☒人工審查				
控制措施： 不使用自行創造的加密方式。採用公開、國際認可之演算法，例如 AES 對稱式加密演算法、RSA 非對稱式演算法及 SHA 安全雜湊演算法等。 **實作指導：** 網頁程式中使用加密演算法，不使用自行創造的加密方式。採用公開、國際認可之演算法。				

資料來源： 本計畫整理

– 相關程式範例，詳見表 85。

表85 傳輸之機密性與完整性-程式範例 2

Microsoft Windows Server 的 IIS 實作範例：
▪ IIS 的 SSL 安裝後，已經預設啟用了某些加密演算法(Cipher)，使用 nmap 軟體可以列出所啟用的加密演算法(Cipher)和安全等級(A~F)，以及是否有弱點或安全疑慮，例如用 nmap 掃描 www.test.idv.tw 網站(假設) nmap --script ssl-cert,ssl-enum-ciphers -p 443 www.test.idv.tw ▪ 結果

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
Starting Nmap 7.40 ( https://nmap.org ) at 2017-04-25 08:23  ￥x￥_?D·CRE?!
Nmap scan report for www.test.idv.tw (***.***.***.***)
Host is up (0.00s latency).
rDNS record for ***.***.***.***:
PORT       STATE SERVICE
443/tcp open    https
| ssl-cert: Subject:
        commonName=www.test.idv.tw/organizationName=\xE8\xA1\x8C\xE6\x94\xBF\x
        E9\x99\xA2/countryName=TW
| Subject Alternative Name: DNS:www.test.idv.tw
| Issuer: organizationName=\xE8\xA1\x8C\xE6\x94\xBF\xE9\x99\xA2/countryName=TW
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2015-05-12T02:08:55
| Not valid after:    2018-05-12T02:08:55
| MD5:      97cb ef80 b922 8383 3d84 305d 482c 67fb
|_SHA-1: 1ebc bcdc fc69 3417 8507 a88e 299d 4c65 d7ad de48
| ssl-enum-ciphers:
|     TLSv1.0:
|         ciphers:
|             TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - A
|             TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (rsa 2048) - A
|             TLS_DHE_RSA_WITH_AES_256_CBC_SHA (dh 2048) - A
|             TLS_DHE_RSA_WITH_AES_128_CBC_SHA (dh 2048) - A
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
|           TLS_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - A
|           TLS_RSA_WITH_AES_128_CBC_SHA (rsa 2048) - A
|           TLS_RSA_WITH_3DES_EDE_CBC_SHA (rsa 2048) - C
|           TLS_RSA_WITH_RC4_128_SHA (rsa 2048) - C
|           TLS_RSA_WITH_RC4_128_MD5 (rsa 2048) - C
|       compressors:
|           NULL
|       cipher preference: server
|       warnings:
|           64-bit block cipher 3DES vulnerable to SWEET32 attack
|           Broken cipher RC4 is deprecated by RFC 7465
|           Ciphersuite uses MD5 for message integrity
|   TLSv1.1:
|       ciphers:
|           TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - A
|           TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (rsa 2048) - A
|           TLS_DHE_RSA_WITH_AES_256_CBC_SHA (dh 2048) - A
|           TLS_DHE_RSA_WITH_AES_128_CBC_SHA (dh 2048) - A
|           TLS_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - A
|           TLS_RSA_WITH_AES_128_CBC_SHA (rsa 2048) - A
|           TLS_RSA_WITH_3DES_EDE_CBC_SHA (rsa 2048) - C
|           TLS_RSA_WITH_RC4_128_SHA (rsa 2048) - C
|           TLS_RSA_WITH_RC4_128_MD5 (rsa 2048) - C
|       compressors:
|           NULL
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
|       cipher preference: server
|       warnings:
|         64-bit block cipher 3DES vulnerable to SWEET32 attack
|         Broken cipher RC4 is deprecated by RFC 7465
|         Ciphersuite uses MD5 for message integrity
|   TLSv1.2:
|       ciphers:
|         TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (rsa 2048) - A
|         TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (rsa 2048) - A
|         TLS_DHE_RSA_WITH_AES_256_GCM_SHA384 (dh 2048) - A
|         TLS_DHE_RSA_WITH_AES_128_GCM_SHA256 (dh 2048) - A
|         TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (rsa 2048) - A
|         TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (rsa 2048) - A
|         TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - A
|         TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (rsa 2048) - A
|         TLS_DHE_RSA_WITH_AES_256_CBC_SHA (dh 2048) - A
|         TLS_DHE_RSA_WITH_AES_128_CBC_SHA (dh 2048) - A
|         TLS_RSA_WITH_AES_256_GCM_SHA384 (rsa 2048) - A
|         TLS_RSA_WITH_AES_128_GCM_SHA256 (rsa 2048) - A
|         TLS_RSA_WITH_AES_256_CBC_SHA256 (rsa 2048) - A
|         TLS_RSA_WITH_AES_128_CBC_SHA256 (rsa 2048) - A
|         TLS_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - A
|         TLS_RSA_WITH_AES_128_CBC_SHA (rsa 2048) - A
|         TLS_RSA_WITH_3DES_EDE_CBC_SHA (rsa 2048) - C
|         TLS_RSA_WITH_RC4_128_SHA (rsa 2048) - C
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
|           TLS_RSA_WITH_RC4_128_MD5 (rsa 2048) - C
|       compressors:
|           NULL
|       cipher preference: server
|       warnings:
|           64-bit block cipher 3DES vulnerable to SWEET32 attack
|           Broken cipher RC4 is deprecated by RFC 7465
|           Ciphersuite uses MD5 for message integrity
|_  least strength: C

Nmap done: 1 IP address (1 host up) scanned in 5.80 seconds
```

可以發現有 3 已有安全疑慮

```
|           64-bit block cipher 3DES vulnerable to SWEET32 attack
|           Broken cipher RC4 is deprecated by RFC 7465
|           Ciphersuite uses MD5 for message integrity
```

此時可考慮使用 IIS Crypto 2.0 工具把某些加密予以關閉。(Windows 本身沒有方便的工具可以進行修改，只能用登錄編輯程式(Regedit.exe)修改)

註：用戶端和伺服器必須有共通的演算法可用，才能使用 HTTPS 加密連線。將不安全的加密演算法移除後，要注意使用較舊版本之作業系統或瀏覽器是否仍可進行加密連線。

參考連結：

- Nmap ("Network Mapper")
  https://nmap.org/
- IIS Crypto 2.0 Build 11 - Released July 15, 2016 (支援 Windows Server 2008, 2012, 2016)
  https://www.nartac.com/Products/IISCrypto

本文件之智慧財產權屬數位發展部資通安全署擁有。

資料來源： 本計畫整理

4.6.2 資料儲存之安全(Protection of Information at Rest)

資料儲存之安全類別之控制措施包含以下 2 項：

- 靜置資訊指資訊位於資訊系統特定元件，如儲存設備上之狀態。與系統相關需要保護的資訊，例如：資訊系統組態設定。該等資訊應予以保護。
- 機密資訊應加密儲存。

與資料儲存之安全控制措施相關的應用程式技術面項目，整理如下：

4.6.2.1 靜置資訊指資訊位於資訊系統特定元件，如儲存設備上之狀態。與系統相關需要保護的資訊，例如：資訊系統組態設定。該等資訊應予以保護

本項目實作項目包含以下 1 項：

- 參數設定或系統設定存放處，限制存取或進行適當保護。

  – 相關實作建議，詳見表 86。

表86 資料儲存之安全-實作建議 1

適用分級			類別	實作項目
普	中	高		
		◎	資料儲存之安全	參數設定或系統設定存放處，限制存取或進行適當保護
查核方式：☒自動化工具檢測 ☒人工審查				
控制措施： 系統參數設定檔案，應設置適當檔案權限，避免被非授權存取。				

本文件之智慧財產權屬數位發展部資通安全署擁有。

實作指導：

預設情況下，參數設定或系統設定會集中存放在一個或少數幾個檔案中，內容無法被使用者直接存取。

若欲限制使用者存取的目錄，可設定 Web 應用程式伺服器，例如於 Apache 伺服器設定檔(http.conf)內可限制使用瀏覽器瀏覽目錄檔案清單，設定方式例如：

<Directory />

Options None

Order allow, deny

Allow from all

</Directory>

參考連結：Apache Configuration Files

http://httpd.apache.org/docs/current/configuring.html

資料來源： 本計畫整理

– 相關程式範例，詳見表 87。

表87 資料儲存之安全-程式範例 1

ASP.NET 實作範例：
在 ASP.NET 網站中，參數設定一般放在 Web.Config 設定檔中，網站瀏覽者無法直接存取其內容。 參考連結： ▪ ASP.NET Web Configuration Guidelines https://msdn.microsoft.com/en-us/library/ff400235.aspx
Java 實作範例：
在 Java Web 網站中，參數設定一般放在 web.xml 設定檔中，網站瀏覽者

本文件之智慧財產權屬數位發展部資通安全署擁有。

無法直接存取其內容。 參考連結： ▪ Apache Tomcat 7 Default Servlet Reference https://tomcat.apache.org/tomcat-7.0-doc/default-servlet.html
PHP 實作範例：
一般用 php 開發之系統，會有一個檔案存放參數設定或系統設定，例如：config.inc.php、config.php 或其他自訂名稱。 參考連結： ▪ PHP: require_once - Manual http://php.net/manual/en/function.require-once.php ▪ PHP: include_once - Manual http://php.net/manual/en/function.include-once.php ▪ PHP: require - Manual http://php.net/manual/en/function.require.php ▪ PHP: include - Manual http://php.net/manual/en/function.include.php

資料來源： 本計畫整理

4.6.2.2 機密資訊應加密儲存

本項目實作項目包含以下 1 項：

●機敏資料儲存時，採用加密機制。

– 相關實作建議，詳見表 88。

表88 資料儲存之安全-實作建議 2

適用分級	類別	實作項目

本文件之智慧財產權屬數位發展部資通安全署擁有。

普	中	高		
		◎	資料儲存之安全	機敏資料儲存時，採用加密機制

查核方式：☐自動化工具檢測　☒人工審查

控制措施：

機敏資料存於資料庫或其他儲存媒體時，採用對稱式或其他加密方式，將機敏資料加密成密文後儲存，並於需要取得原始明文時解密還原。此作法可減少機敏資料因儲存媒體有其他存取管道而洩漏的風險。

實作指導：

將機敏資料加密成密文後儲存，並於需要取得原始明文時解密還原。

postgres 的 SQL 加密函式實作範例：

```
CREATE EXTENSION pgcrypto;
select pgp_sym_decrypt(pgp_sym_encrypt('Secret.', 'key'), 'key');
select pgp_sym_decrypt( pgp_sym_encrypt('Secret.', 'key','cipher-algo=aes256'), 'key',
'expect-cipher-algo=aes256');
```

參考連結：

- PostgreSQL: Documentation: 8.3: pgcrypto
  https://www.postgresql.org/docs/8.3/static/pgcrypto.html

資料來源： 本計畫整理

– 相關程式範例，詳見表 89。

表89 資料儲存之安全-程式範例 2

postgres 的 SQL 加密函式實作範例：

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
CREATE EXTENSION pgcrypto;
select pgp_sym_decrypt(pgp_sym_encrypt('Secret.', 'key'), 'key');
select pgp_sym_decrypt( pgp_sym_encrypt('Secret.', 'key','cipher-algo=aes256'), 'key',
'expect-cipher-algo=aes256');
```

參考連結：

- PostgreSQL: Documentation: 8.3: pgcrypto
  https://www.postgresql.org/docs/8.3/static/pgcrypto.html

資料來源： 本計畫整理

4.7 系統與資訊完整性(System and Information Integrity)

系統與資訊完整性分為「漏洞修復」、「資訊系統監控」以及「軟體及資訊完整性」等 3 項控制措施，說明如下。

4.7.1 漏洞修復(Flaw Remediation)

漏洞修復類別之控制措施包含以下 2 項：

- 系統的漏洞修復應測試有效性及潛在影響，並依律定之時間週期更新。
- 定期確認資訊系統相關漏洞修復之狀態。

漏洞修復控制措施並無相關的應用程式技術面項目，故不在此份文件描述。

4.7.2 資訊系統監控(Information System Monitoring)

資訊系統監控類別之控制措施包含以下 3 項：

- 發現資訊系統有被入侵跡象時，應通報機關特定人員。
- 監控資訊系統，以偵測攻擊和未授權之連線，並識別資訊系統之未授權使用。

本文件之智慧財產權屬數位發展部資通安全署擁有。

●資訊系統應採用自動化工具監控進出之通信流量，並於發現不尋常或未授權之活動時針對該事件進行分析。

與資訊系統監控控制措施相關的應用程式技術面實作建議，詳見表 90。

表90 資訊系統監控-實作建議

適用分級			類別	實作項目
普	中	高		
◎	◎	◎	資訊系統監控	(1)發現資訊系統有被入侵跡象時，應通報機關特定人員。 (2)監控資訊系統，以偵測攻擊和未授權之連線，並識別資訊系統之未授權使用。(適用於中等級) (3)資訊系統應採用自動化工具監控進出之通信流量，並於發現不尋常或未授權之活動時針對該事件進行分析。(適用於高等級)
查核方式：☒自動化工具檢測　☒人工審查				
控制措施： (1)發現資訊系統有被入侵跡象時，應通報機關特定人員。 (2)監控資訊系統，以偵測攻擊和未授權之連線，並識別資訊系統之未授權使用。 (3)資訊系統應採用自動化工具監控進出之通信流量，並於發現不尋常或未授權之活動時針對該事件進行分析。 **實作指導：** (1)可評估架設 WAF、IDS 及 IPS 等監控系統。				

本文件之智慧財產權屬數位發展部資通安全署擁有。

(2)可評估自行建置或委外資訊安全監控中心 (Security Operation Center，SOC)進行監控服務。
實作範例：無，請參考實作指導。

資料來源： 本計畫整理

4.7.3 軟體及資訊完整性(Software, Firmware, and Information Integrity)

軟體及資訊完整性之控制措施包含以下 4 項：

●使用完整性驗證工具以偵測未授權變更特定軟體。

●使用者輸入資料合法性檢查應置放於應用系統伺服器。

●當發現違反完整性時，資訊系統應實施機關指定之安全保護措施。

●應定期執行軟體和資訊完整性檢查。

與軟體及資訊完整性控制措施相關的應用程式技術面項目，整理如下：

4.7.3.1 於資訊系統伺服器端檢查使用者輸入資料合法性

本項目實作項目包含以下 1 項：

●於伺服器端以正規表示式(Regular Expression)方式，檢查使用者輸入資料合法性。

– 相關實作建議，詳見表 91。

表91 軟體及資訊完整性-實作建議

適用分級			類別	實作項目
普	中	高		
	◎	◎	軟體及資訊	於伺服器端以正規表示式(Regular

本文件之智慧財產權屬數位發展部資通安全署擁有。

			完整性	Expression)方式，檢查使用者輸入資料合法性
查核方式：☐自動化工具檢測　☒人工審查				
控制措施： 對於使用者輸入欄位資料，採用正規表示式進行檢查，僅允許輸入特定白名單內容，檢查其邏輯規則是否合法。 **實作指導：** 當系統因功能需求必須取用或儲存使用者所傳入的資料內容時，必須使用統一驗證樣板驗證判斷處理後才可使用，以避免所傳入的資料對系統造成危害。				

資料來源： 本計畫整理

– 相關程式範例，詳見表 92。

表92 軟體及資訊完整性-程式範例

ASP.NET 實作範例：

在 ASP.NET 網站中，可依照所需的資料建立其資料規則，並以此規則對所輸入的資料做驗證，在驗證通過後方可使用其輸入資料，以下依微軟的建議處理方式實作程式碼示範：
▪ 設置一個表單讓使用者輸入，在使用者輸入後，會先驗證其資料內容，處理方式如下所示：
//驗證資料方式，使用正規表示式確認其輸入格式是否符合。
protected void ButtonSubmit_Click(object sender, EventArgs e)
{
if (UserInputValidate())
{
LabelShow.Text = "驗證通過";

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
                //可以再對資料做處理。
            }
            else
            {
                LabelShow.Text = "驗證未通過，請確認輸入是否正確!!";
            }
        }
        bool UserInputValidate()
        {
            return DataValidator("url", this.TextBoxURL.Text) &&
DataValidator("number", this.TextBoxNumber.Text) && DataValidator("email",
this.TextBoxEmail.Text);
        }
        bool DataValidator(string CheckType, string Data)
        {
            Dictionary<string, string> TypePattern = new Dictionary<string, string>()
            {
                {"number",@"^\d+$"},       {"url",@"^(ht|f)tp(s?)\:\/\/[0-9a-zA-
Z]([-.\w]*[0-9a-zA-Z])*(:(0-9)*)*(\/?)([a-zA-Z 0-9\-\.\?\,\'\/\\\+&amp;%\$#_]*)?$"},
{"email",@"^(?("")(""".+?""@)|(([0-9a-zA-
Z]((\.(?!\.))|[-!#\$%&'\*\+/=\?\^`\{\}\|~\w])*)(?<=[0-9a-zA-
Z])@))(?(\[)(\[(\d{1,3}\.){3}\d{1,3}\])|(([0-9a-zA-Z][-\w]*[0-9a-zA-Z]\.)+[a-zA-
Z]{2,6}))$"}
            };
            if (!string.IsNullOrEmpty(Data) &&
                System.Text.RegularExpressions.Regex.IsMatch(Data,
TypePattern[CheckType]))
            {
                return true;
            }
            return false;
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
        }
```

參考連結：

- How To: Use Regular Expressions to Constrain Input in ASP.NET

  http://msdn.microsoft.com/en-us/library/ff650303.aspx

Java 實作範例：

在 Java 網站中，可依照所需的資料建立其資料規則，並以此規則對所輸入的資料進行驗證，在驗證通過後，方可使用其輸入資料，以下依微軟的建議處理方式實作程式碼示範：

- 設置一個表單讓使用者輸入，在使用者輸入後，會先驗證其資料內容，處理方式如下所示：

```
//驗證資料方式，使用正規表示式確認其輸入格式是否符合。

public void doGet(HttpServletRequest req, HttpServletResponse resp) throws
    ServletException, IOException {
    req.setCharacterEncoding("UTF-8");
  String url = req.getParameter("url");
  String num = req.getParameter("num");
  String email = req.getParameter("email");
  resp.setContentType("text/html;charset=utf-8");
  if(userInputValidate(url,num,email)){
    resp.getWriter().print("驗證通過");
  }else{
    resp.getWriter().print("驗證未通過,請確認輸入是否正確");
  }
  }
  private boolean userInputValidate(String url, String num, String email) {
      return dataValidator("url", url) && dataValidator("number", num)&&
          dataValidator("email", email);
   }
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
    private boolean dataValidator(String filterType, String data) {
       Map<String,String> masks = new HashMap<String,String>();
          masks.put("url", "^(ht|f)tp(s?):\\/\\/[0-9a-zA-Z]([-.\\w]*[0-9a-zA-Z])*(:(0-
              9)*)*(\\/?)([a-zA-Z0-9\\-\\.\\?,\\'\\/\\+&amp;%\\$#_]*)?$");
       masks.put("number", "^\\d+$");
       masks.put("email", "^[\\w-]+(\\.[\\w-]+)*@[\\w-]+(\\.[\\w-]+)+$");
       return data.matches(masks.get(filterType));
    }
```

參考連結：

- Managing Matches and Match Exceptions - Oracle Help Center
  https://docs.oracle.com/cd/E39583_01/fscm92pbr0/eng/fscm/fmpy/task_ManagingMatchesandMatchExceptions-9f3ff3.html

PHP 實作範例：

- 設置一個表單讓使用者輸入，在使用者輸入後，會先驗證其資料內容，處理方式如下所示：

```
//驗證資料方式，使用正規表示式確認其輸入格式是否符合。
    $urlStr = $_GET['url'];
    $numStr = $_GET['num'];
    $emailStr = $_GET['email'];
    if (user_input_validate($urlStr,$numStr,$emailStr)){
    echo "驗證通過";
    //可以再對資料做處理。
    }else{
    echo "驗證未通過，請確認輸入是否正確!!";
    }
    function user_input_validate($urlStr,$numStr,$emailStr){
        return data_validator("url",$urlStr) && data_validator("number",$numStr) &&
```

本文件之智慧財產權屬數位發展部資通安全署擁有。

```
            data_validator("email",$emailStr);
    }
    function data_validator($check_type,$data){
        $masks["url"] = "/^(ht|f)tp(s?)\:\/\/[0-9a-zA-Z]([-.\w]*[0-9a-zA-Z])*(:(0-
            9)*)*(\/?)([a-zA-Z0-9\-\.\?\,\'\/\\\+&amp;%\$#_]*)?$/";
      $masks["number"] = "/^\d+$/";
        $masks["email"] = '/^([a-z0-9])(([-a-z0-9._])*([a-z0-9]))*\@([a-z0-9])' . '(([a-z0-
            9-])*([a-z0-9]))+' . '(\.([a-z0-9])([-a-z0-9_-])?([a-z0-9])+)+$/i';
      if(preg_match($masks[$check_type],$data) == "0"){
      return false;
      }
      return true;
    }
```

參考連結：

- PHP: preg_match - Manual
  http://php.net/manual/en/function.preg-match.php

資料來源： 本計畫整理

本文件之智慧財產權屬數位發展部資通安全署擁有。

5. 結論

本指引針對 Web 應用程式應注意之資安事項進行說明並提供實作指引，旨在協助政府機關於開發及維運資訊系統時，妥善進行 Web 應用程式的安全防護工作，期能符合「資通安全責任等級分級辦法(附表十)資通系統防護基準」。

本指引依照資通安全管理法子法「資通安全責任等級分級辦法(附表十)資通系統防護基準」之分類方式進行分類，利用實作說明與範例程式，讓開發者重視 Web 應用程式安全性的問題，進一步在開發時期建立開發慣例，以預防常見與容易疏忽的安全性議題，再以範例程式進行延伸，加強其 Web 應用程式的安全性。而針對現有 Web 應用程式亦可參考範例，進一步提升系統安全性，進而強化 Web 應用程式安全。

藉由各章節的介紹，期望機關不論是自行開發或委外開發 Web 應用程式時，皆能將安全需求在設計時明確定義，利用開發工具進行實作，並確保正確實作相對應的安控措施，以提升政府機關資訊系統安全性。

本文件之智慧財產權屬數位發展部資通安全署擁有。

6. 參考文獻

[1] 資通安全管理法子法(108 年 1 月)。「資通安全責任等級分級辦法(附表十)資通系統防護基準」

[2]What is the Security Development Lifecycle ?
https://www.microsoft.com/en-us/sdl/default.aspx

[3]The WASC Threat Classification v2.0
http://projects.webappsec.org/w/page/13246978/Threat%20Classification

[4]CWE/SANS Top 25 http://cwe.mitre.org/top25/

本文件之智慧財產權屬數位發展部資通安全署擁有。

7. 附件

附件 1. Web 應用程式安全查檢表

附件 2.專有名詞英中對照表

附件 3. HTTP 安全標頭防護設定

本文件之智慧財產權屬數位發展部資通安全署擁有。